

ATHENS 2023

7

6

Annual Activity Report 2022

TABLE OF CONTENTS

FOREWORD	8
INTRODUCTION	12
1.1. MISSION AND COMPETENCIES OF THE AUTHORITY	12
1.2. COMPOSITION OF THE AUTHORITY	15
1.3. HUMAN RESOURCES	16
1.4. FINANCIAL DATA	19
1.5. OPERATIONAL ISSUES, GOALS, AND PROPOSALS	20
STATISTICS	28
AREAS OF ACTIVITY	54
3.1. COMPLAINTS	54
3.1.1. NATIONAL DEFENSE	54
3.1.2. PUBLIC ADMINISTRATION AND SELF-GOVERNMENT	55
3.1.3. EDUCATION AND RESEARCH	58
3.1.4. HEALTH	60
3.1.4.1. Pandemic Management	65
3.1.5. PRIVATE INSURANCE	66
3.1.6. FINANCIAL SECTOR AND PRIVATE ECONOMY	67
3.1.6.1. Credit/Financial Institutions	67
3.1.6.1.1. Debt Collection Companies	71
3.1.6.2. Private Economy	73
3.1.6.3. Internet Services – New Technologies – Biometrics – Artificial Intelligence	76
3.1.6.3.1. Search Engines, Removal of Links from Online Search Results	77
3.1.6.3.2. Deletion of Public Posts with Personal Data on the Internet/Social Media	77
3.1.7. ELECTRONIC COMMUNICATIONS	78
3.1.7.1. Incident of Breach at Cosmote	78
3.1.7.2. ‘Sim Swap’ Breach Incidents	79
3.1.7.3. Recording and Listening to Phone Calls	79
3.1.7.4. Unsolicited Electronic Communications for the Purpose of Promoting Products or Services	81
3.1.7.5. Phone Calls and Complaints Regarding Potential	

Electronic Fraud	82
3.1.8. POLITICAL COMMUNICATION	83
3.1.9. FIELD OF LABOR RELATIONS	84
3.1.10. ASSOCIATIONS, NON-PROFIT ORGANIZATIONS, PROFESSIONAL ASSOCIATIONS, AND POLITICAL PARTIES	87
3.1.11. MASS MEDIA	89
3.1.12. VIDEO SURVEILLANCE SYSTEMS	90
3.1.12.1. Residences	92
3.1.13. JURISDICTION OF THE AUTHORITY	93
3.1.14. OTHER SECTORS	94
3.2. ADVISORY – CONSULTATIVE WORK	94
3.3. AUDITS	103
3.4. INCIDENTS OF BREACH	104
3.5. IMPACT ASSESSMENT AND PRIOR CONSULTATION	105
3.6. DATA TRANSFERS OUTSIDE THE EU	109
3.7. COOPERATION WITH EQUIVALENT AUTHORITIES OF EU MEMBER STATES, MUTUAL ASSISTANCE, JOINT VENTURES	109
3.8. OTHER ACTIVITIES	110
3.8.1. CODE OF ETHICS	110
3.8.2. MECHANISMS AND CERTIFICATION CRITERIA	110
3.8.3. PARTICIPATION OF THE AUTHORITY IN PROGRAMS/PROJECTS	111
3.8.3.1. Project "byDesign"	111
3.8.3.2. Project "byDefault"	114
3.9. ORGANIZATIONAL ISSUES	114
3.10. COMMUNICATION POLICY	118
3.11. EXTENSION OF THE INFORMATION SYSTEM	126
EUROPEAN AND INTERNATIONAL COOPERATION	128
4.1. EUROPEAN DATA PROTECTION BOARD	128
4.1.1. COORDINATED SUPERVISION COMMITTEE – CSC	136
4.2. JOINT SUPERVISORY AUTHORITIES AND COORDINATION GROUPS FOR THE SUPERVISION OF INFORMATION SYSTEMS	140
4.2.1. COORDINATION GROUP FOR THE SUPERVISION OF THE SECOND GENERATION SCHENGEN INFORMATION SYSTEM (SIS II)	140
4.2.2. EUROJUST COOPERATION COUNCIL	143
4.2.3. COORDINATION GROUP FOR THE SUPERVISION OF THE CUSTOMS INFORMATION SYSTEM AND COMMON CUSTOMS CONTROL AUTHORITY	145
4.2.4. COORDINATION GROUP FOR THE SUPERVISION OF THE VISA INFORMATION SYSTEM (VIS)	147
4.2.5. COORDINATION GROUP FOR THE SUPERVISION OF EURODAC	150

9

8

The annual reports and acts of the Authority
are available on the website www.dpa.gr

Acronyms

Acronym

Explanation

GDPR

General Data Protection Regulation

EDPB

European Data Protection Board

DPO

Data Protection Officer

EDPS

European Data Protection Supervisor

EU

European Union

CJEU

Court of Justice of the European Union

IMI

Internal Market Information System

LSA

Lead Supervisory Authority

BCR

Binding Corporate Rules

WP29

Article 29 Working Party

11

10

Annual Activity Report 2022

Foreword

Note

It is with great satisfaction that I introduce the annual activity report of the Data Protection Authority for 2022. The report presents in detail the actions of the independent authority in all areas of its competence, as well as useful statistical data. At the same time, it reflects the work of the members and staff of the Authority who have exhausted the possibilities of maximizing the resources available to them for the fulfillment of the mission assigned to them by the State.

In 2022, four years have passed since the implementation of the General Data Protection Regulation (GDPR) began. This fundamental piece of legislation of the European Union aims to enhance the protection of personal data and, by extension, privacy in its broader form, which constitutes a fundamental value of European legal culture; it also aims to ensure the free movement of such data within the framework of the functioning of the internal market in the European Union, in light of technological developments and the rapidly increasing cross-border flow of personal data.

It is well known that the GDPR has expanded the legal framework of the previous Directive 95/46/EC by providing for new measures and procedures, as well as by tightening the enforcement arsenal, based on which the possibility of imposing extremely high fines is granted. We observe, in fact, that national data protection authorities have also practically applied the stipulated high fines. It is

characteristic that from the milestone date of May 25, 2018, until December 2022, the total amount of fines imposed by data protection authorities at the European level exceeds 2 billion euros. At the same time, there has been a gradual increase in the total amount of fines imposed by the Greek Data Protection Authority since the beginning of the GDPR's implementation. In the year 2022, which this annual report concerns, fines exceeding 30 million euros were imposed, compared to fines of 414 thousand euros that were imposed the previous year. However, it should be clarified that the Authority, acting in accordance with the general spirit of the legislation on the protection of personal data, does not aim at the imposition of sanctions, which is applied as a repressive measure with a deterrent purpose. The amount of fines imposed is not presented as a positive assessment of the Authority's work, but as an indication that towards the end of the first five years of the GDPR's implementation, significant violations of the rules that can no longer be justified continue to be identified. A general conclusion that has emerged from the first years of the Regulation's implementation is that compliance with its rules and, primarily, the incorporation of the spirit that governs data protection principles is a continuous exercise for organizations and businesses, but also that, in any case, the European Regulation has yielded results.

The Data Protection Authority has responded to the maximum possible extent to the responsibilities and duties assigned to it by the European Regulation and national law, despite the longstanding problems arising from understaffing and lack of adequate resources combined with the continuously increasing flow of cases and other duties.

I would like to mention, as an example, that, as evidenced by the data presented in the following pages, in 2022 the number of incoming cases of appeals/complaints, as well as the number of corresponding cases that were processed, increased by approximately 8% compared to 2021. In addition to examining complaints, the Authority consistently prioritizes the development of its proactive work, particularly its ex officio auditing activities, guidance actions, information – awareness-raising, as well as the analysis of new technologies and business models from the perspective of data protection, and finally, contributing to research efforts in the field of data protection and information security. Specifically, as indicative examples of exercising ex officio authority in 2022, the cases in which the Authority examined the processing of personal data that took place based on measures provided for by law to address the coronavirus and issues that arose in the context of modern distance education in primary and secondary education units following a decision from the previous year, in which the Authority had imposed a corrective measure and had issued recommendations to the Ministry of Education, are mentioned. Furthermore, following actions from previous years and after it was found that many websites do not provide visitors with the ability to accept or reject trackers through banners with the same ease, the Authority called in 2022...

13

12

Annual Activity Report 2022

Overall, another 60 sites with visitor criteria complied with this requirement. This action was successfully completed.

The opinions issued by the Authority in 2022 include those issued on the draft Presidential Decree of the Ministry of Interior regarding the protection of personal data during teleworking in the public sector, on the draft Ministerial Decision concerning the exemption of students from the obligation to attend religious education classes, as well as on the draft law regarding the process of lifting the confidentiality of communications, cybersecurity, and the protection of citizens' personal data.

The Authority continuously makes systematic efforts to raise awareness regarding the protection of personal data and to provide appropriate tools to facilitate compliance with the relevant protection rules. Given the limited financial resources, it utilizes funding opportunities provided by the European Commission through relevant programs for these actions. I note that in 2022, a project was successfully completed by the Authority in collaboration with the University of Piraeus and the company ABOVO. The project aimed to facilitate compliance for small and medium-sized enterprises through the provision of specialized guidance in the form of a compliance toolkit and specialized information for those involved in the development of applications and IT services on data protection by design and by default.

Additionally, in September 2022, the Authority began implementing a new project, discreetly titled "byDefault," which involves the creation of a special platform for providing specialized information to Data Protection Officers (DPOs) and professionals in the field of data protection, as well as the creation of educational material on data protection for primary and secondary school students. On another level of action, the Authority proceeded to sign Memoranda of Cooperation with the National Accreditation System (ESYD), as well as with the Competition Commission, with the aim of substantial cooperation between the parties when examining issues that fall within the interest or the responsibilities of both. The signing of Memoranda of Cooperation is part of initiatives that must continue in the coming years as it facilitates the work of the Authority and contributes to a more comprehensive handling of cases in areas where its responsibilities intersect with the work of other entities.

Furthermore, the Authority responded to its ongoing European and international obligations and was actively present at the European Data Protection Board (EDPB), as well as in the working groups and committees operating under European data protection legislation. It should be noted that the EDPB has intensified its work. I mention, for example, that it issued nine Guidelines in 2022 on significant substantive and procedural issues, 32 opinions, as well as four joint opinions with the European Data Protection Supervisor (EDPS) on proposals for Regulations from the European Parliament and the Council.

National data protection authorities are firmly committed to the coherent implementation of the General Regulation using all means at their disposal. It is characteristic that during the EDPB Summit in Vienna at the end of April, they committed to further strengthen and expand their cooperation on strategically significant cases (e.g., cases involving a large number of subjects in the EEA, cases concerning a structural or recurring problem in the member states), so that the implementation of the Regulation becomes more effective. Beyond this, within the framework of the EDPB, national authorities undertake joint actions, such as the coordinated action regarding the use of cloud services by public authorities, which was initiated in 2022 and in which the Greek Authority also participates.

In the coming years, both the EDPB and the national data protection supervisory authorities will need to devote significant effort to analyzing the impacts of the ever-increasing implementation of artificial intelligence systems in every area of activity and to formulating relevant recommendations and guidelines. Additionally, the impacts of the developing legal framework regarding the data strategy and the digital transformation strategy of the European Union should be analyzed, and effective cooperation mechanisms with other competent authorities should be established as appropriate. However, apart from the intensive efforts made by the Greek Authority to respond with its proactive and sanctioning actions to the high expectations of society and citizens, as it is obliged to do, it is crucial to emphasize once again that the competent state bodies must ensure that it has the necessary resources, in implementation of the relevant provisions of the Regulation. The rest is obviously our own responsibility and duty.

Konstantinos Menoudakos

President of the Data Protection Authority

1 https://edpb.europa.eu/our-work-tools/our-documents/statements/statement-enforcement-cooperation_en

15

14

Annual Activity Report 2022

1.

Introduction

1.1. MISSION AND COMPETENCIES OF THE AUTHORITY

The

Data Protection Authority

is a constitutionally established independent public Authority (Article 9A of the Constitution) founded by Law 2472/1997, which incorporated into Greek law the European Directive 95/46/EC on the protection of individuals with regard to the processing of personal data and on the free movement of such data. It is served by its own Secretariat operating at the Directorate level and has its own budget.

With Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation - GDPR), which came into effect on 25/5/2018 in all EU countries, Directive 95/46/EC was repealed. From 29/8/2019, Law 4624/2019 ("Data Protection Authority, measures for the implementation of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, for the protection of individuals with regard to the processing of personal data and incorporation into national legislation of Directive (EU) 2016/680 of the European Parliament and of the Council of April 27, 2016, and other provisions") is in effect. In the aforementioned law, Articles 9 to 20 refer to the Data Protection Authority (supervisory authority). Law 2472/1997 has been repealed except for certain provisions explicitly mentioned in Article 84 of Law 4624/2019. Law 4624/2019 also includes the incorporation into the Greek legal order of Directive (EU) 2016/680 of the European Parliament and of the Council of April 27, 2016, on the protection of individuals with regard to the processing of personal data by competent authorities for the purposes of preventing, investigating, detecting, or prosecuting criminal offenses or the execution of criminal sanctions and for the free movement of such data and the repeal of Framework Decision 2008/977/JHA of the Council. Furthermore, regarding the protection of personal data in the field of electronic communications, the Authority implements Law 3471/2006, which similarly incorporates the European Directive 2002/58/EC into national law.

The Authority is responsible for overseeing the application of the provisions of the GDPR (Article 51 para. 1, rec. 123), Law 4624/2019, and other regulations concerning the protection of individuals from the processing of personal data (Article 9 of Law 4624/2019).

It contributes to the coherent application of the GDPR throughout the Union and for this purpose collaborates with the supervisory authorities of the EU member states and with the Commission (Article 51 para. 2, rec. 123 of the GDPR; Article 10 of Law 4624/2019). The Authority represents Greece in the European Data Protection Board (EDPB) and in other committees or bodies concerning data protection and collaborates with corresponding authorities of third countries and international organizations (Article 50 of the GDPR, Article 10 of Law 4624/2019).

The Authority is competent to perform its duties (Articles 57 of the GDPR and 13 of Law 4624/2019) and to exercise the powers conferred upon it (Articles 58 of the GDPR and 15 of Law 4624/2019) within its territory (Article 55 para. 1, rec. 122, 129 of the GDPR; Article 9 of Law 4624/2019) with full independence (Article 52, rec. 117-118, 121 of the GDPR; Article 11 of Law 4624/2019).

In particular, the Authority is, among other things, responsible for the following (Article 57 GDPR, Article 13 of Law 4624/2019):

- To monitor and enforce the application of the GDPR, Law 4624/2019, and other regulations concerning the protection of individuals against the processing of personal data.
- To promote public awareness on issues of personal data protection and of those responsible for and executing the processing regarding their obligations. Special attention is given to activities aimed at children.
- To provide opinions on any regulation intended to be included in a law or regulatory act concerning data processing.
- To issue guidelines and make recommendations on any matter concerning data processing, subject to the duties of the EDPB.
- To provide information upon request to data subjects regarding the exercise of their rights.
- To handle complaints submitted for violations of the provisions of the GDPR.
- To conduct investigations or audits regarding the application of data protection legislation.

17

16

Annual Activity Report 2022

on the protection of personal data.

- To prepare and maintain a list regarding the requirement for conducting a impact assessment (Article 35, paragraph 4 of the GDPR) and to provide advice on the processing operations of Article 36, paragraph 2 of the GDPR.
- To encourage the development of codes of conduct and to approve codes of conduct that provide adequate guarantees.

- To promote the establishment of data protection certification mechanisms and seals and marks for data protection and to approve the certification criteria.
- To design and publish accreditation requirements for monitoring codes of conduct and certification bodies.
- To cooperate with other supervisory authorities through information exchange and to provide mutual assistance to them in order to ensure a more coherent application of the GDPR.
- To contribute to the activities of the EDPB.

In addition, the Authority has control powers, as well as corrective, advisory, and licensing powers, as specified and analyzed in Article 58 of the GDPR and in Article 15 of Law 4624/2019.

When the processing of personal data is carried out by public authorities or by private entities acting under Article 6, paragraph 1, subparagraphs c or e of the GDPR (Article 55, paragraph 2, recital 128 of the GDPR), only the Authority is competent as the exclusively responsible body, and the rules of cooperation and coherence mentioned below regarding the Lead Supervisory Authority (LSA) and the "one-stop-shop mechanism" do not apply (recital 128 of the GDPR).

Furthermore, the Authority prepares an annual report of its activities, which it submits to the national parliament, the government, and other authorities and makes available to the public, the Commission, and the EDPB (Article 59 of the GDPR, Article 14 of Law 4624/2019).

Cooperation and Coherence

In cases where cross-border data processing is conducted (Article 4, paragraph 23 of the GDPR), the cooperation mechanism between the LSA and the concerned supervisory authorities generally applies, for which the primary responsibility for supervision lies with the LSA (Article 60, recitals 124-126 of the GDPR; WP244rev.01). The Authority is competent to act as the LSA for cross-border processing carried out by a data controller or processor who has its main or sole establishment in its territory, in accordance with the procedure provided for in Article 60 of the GDPR (Article 56, paragraph 1, recital 124 of the GDPR). In cases where one of the conditions mentioned in Article 4, paragraph 22 of the GDPR applies, the Authority acts as a concerned supervisory authority (Articles 60, 66, recitals 124-125, 130-131, 143 of the GDPR). Additionally, it cooperates with the supervisory authorities of the EU member states by providing mutual assistance and conducting joint operations, on a bilateral or multilateral basis, to ensure the coherent application of the GDPR and the adoption of common control measures (Articles 61-62, recitals 133-134, 138 of the GDPR).

By way of derogation from the general rule, the Authority is competent to examine a submitted complaint or to address a potential violation of the GDPR in cases where cross-border processing has local impacts in its territory (cross-border processing with local impact), if the LSA decides not to take up the case after being informed by the Authority (Article 56, paragraphs 2-5, recital 127 of the GDPR). In such cases, the Authority takes up the case in accordance with Articles 61 and 62 of the GDPR (Article 56, paragraph 5 of the GDPR).

Moreover, the Authority applies the consistency mechanism (recital 135 of the GDPR) when it intends to adopt any of the measures provided for in Article 64, paragraph 1 of the GDPR (recital 136 of the GDPR) or upon request for an opinion to the EDPB regarding any issue of general application of the GDPR or an issue that produces effects in more than one member state (Article 64, paragraph 2 of the GDPR) or in the context of resolving disputes between supervisory authorities from the EDPB (Article 65, recital 136 of the GDPR) and the urgent procedure (Article 66, recital 137 of the GDPR).

1.2. COMPOSITION OF THE AUTHORITY

The President of the Authority in 2022 was Konstantinos Menoudakos, Honorary President of the Council of State, with his deputy Georgios Batzalexis, Honorary Areopagite.

Regular and alternate members were as follows:

Spyridon Vlachopoulos, Professor of the Law School of the National and Kapodistrian University of Athens, with his deputy Christos Papadodouros, Professor in the Department of History and Philosophy of Science at the National and Kapodistrian University of Athens.

Konstantinos Lamprinoudakis, Professor in the Department of Digital Systems of the University of Piraeus, with his deputy Dimosthenis Bougioukas, Professor in the Department of Information and Communication Systems Engineering of the Polytechnic School of the University of the Aegean, Electrical Engineer NTUA.

Charalampos Anthopoulos, Professor of Law and Administration at the Hellenic Open University, with his deputy Nikolaos Libos, Associate Professor of Criminal Law at the Law School of the National and Kapodistrian University of Athens.

Christos Kalloniatis, Associate Professor in the Department of Cultural Technology and Communication of the School of Social Sciences at the University of the Aegean, as a regular member, with his deputy Georgios Kontis, Doctor of Political Science.

19

18

Annual Activity Report 2022

of the Legal School of the National and Kapodistrian University of Athens.

Aikaterini Iliadou, Associate Professor of Public Law at the Legal School of the National and Kapodistrian University of Athens, as a regular member, with her substitute Nikolaos Faldamis, President of the Hellenic Network of IT Professionals and representative for Greece of the European Council of IT Professionals.

Grigorios Tsolias,

Lawyer,

Doctor of the

Department of Law

of the University of Athens in Criminal Law, as a regular member, with his substitute Maria Psalla, Lawyer.

1.3. HUMAN RESOURCES

The Authority, according to Article 20 paragraph 1 of its founding law 2472/1997 and Presidential Decree 207/1998 "Organization of the Secretariat of the Personal Data Protection Authority and establishment of organic positions," which remains in force under Article 18 paragraph 3 of Law 4624/2019, is served by a Secretariat that operates at the Directorate level and consists of four Departments: 1) the Auditors' Department, 2) the Communication Department, 3) the Administrative Affairs Department, and 4) the Financial Services Department, which was established according to the decision number G/EX/1435/21-2-2017 "Transfer and allocation of the responsibilities of Article 69Γ of Law 4270/2014 to the organic units of the Directorate of the Secretariat of the Authority. Establishment of a department of purely economic interest therein."

1. Auditors' Department

It has decisive responsibilities for fulfilling the mission of the Authority. Indicatively, this department is responsible for conducting administrative audits on any file, the preparation of regulatory acts for the regulation of specific, technical, and detailed issues, drafting guidance plans aimed at the uniform application of protective legislation for individuals, examining complaints, and preparing recommendations. Additionally, the Auditors' Department is involved in drafting the annual report of the Authority under the coordination of the Director of the Secretariat. Furthermore, the Auditors assist

categories of data controllers in the preparation of codes of conduct and support their updating on personal data protection issues with presentations at conferences and seminars. They represent the Authority in European Union bodies, as well as in international working groups and conferences. They participate in the work of the European Data Protection Board and its expert subgroups. The responsibilities of the Department include the preparation of files, conducting studies, submitting recommendations, and generally assisting the Authority in the exercise of its responsibilities. The Department is staffed by legal and IT specialists, following the conversion of the organic positions of university education category into positions of specialized scientific personnel with an indefinite private law employment relationship, according to Law 4055/2012.

The number of paid organic positions in the Auditors' Department in 2022 was 29, of which 17 were lawyers and 12 were IT specialists, including the Director of the Secretariat of the Authority. It is noted that one lawyer (EEP-IDACH) is on long-term unpaid leave as she works in a European organization in which Greece is also a participant, one lawyer (EEP-IDACH) has been seconded to the Ministry of Health for five years, one lawyer (EEP-IDACH) is on secondment to a European organization, and one IT specialist (EEP-IDACH) was absent on a nine-month leave for the upbringing of his minor child.

Consequently, the number of personnel serving in the Auditors' Department in 2022 was 25 (14 lawyers and 11 IT specialists).

2. Communication Department

It has extremely significant responsibilities for achieving the mission of the Authority. In general, the main responsibility of the Department is to assist the Authority in shaping and implementing its communication policy as well as submitting relevant recommendations. Specifically, the Communication Department is tasked with organizing informational and scientific workshops, seminars, and conferences on issues related to the Authority's field of responsibilities, managing public relations with other public services and organizations, private individuals, and foreign services, including the relevant bodies of the European Union, issuing informational bulletins, brochures, and press releases, as well as creating radio and television messages for the Authority. Additionally, its responsibilities include creating and editing content for the Authority's website, monitoring and summarizing the media on personal data protection issues, as well as internal communication, organizing press conferences, and managing journalistic inquiries and requests for statements or interviews, ensuring the editing, publication, and dissemination of the Authority's annual activity report, as well as drafting the section on communication policy under the coordination of the Director of the Secretariat, and finally maintaining the Authority's library. The Communication Department also represents the Authority in the Communication Network of the European Data Protection Board (EDPB Communication Network).

The Department is staffed by communication and translation specialists following the conversion of the organic positions of scientific personnel of university education category in the communication sector of the Authority into positions of specialized scientific personnel according to Article 18 paragraph 8.

21

20

Annual Activity Report 2022
of Law 4624/2019.

In the Communication Department, two specialized scientists served in 2022, including the Head. It is noted that one EEP-IDAX is on unpaid leave for the upbringing of her minor child. Therefore, the number of those serving in 2022 was two EEP-IDAX.

3. Department of Administrative Affairs

The Department of Administrative Affairs consists of personnel with university, technological, secondary, and compulsory education. The specialized personnel with university and technological education in the Department hold degrees and postgraduate qualifications in public administration and informatics. The employees of the Department are responsible for the secretarial support of the Authority (electronic protocol maintenance, minutes of meetings, typing of texts, classification and updating of files, and management of personnel issues, maintenance of individual personnel files and

their updates, and maintenance of all kinds of leaves). The Department's duties also include drafting, posting, and notifying announcements for the recruitment of permanent staff and EEP-IDAX, participation in the personnel evaluation process, participation and compliance with the requirements for the Unified Mobility System, promotion and implementation of the circulars of the Ministry of Interior, and drafting of DAUK reports. Additionally, the issuance of certificates of prior service, employment, and all kinds of certificates requested by the Authority's employees, regardless of Department, for any lawful use is included in the Department's duties. The Department is also responsible for all kinds of management of the Authority's computing and networking infrastructure. The permanent positions in the Department of Administrative Affairs amount to 15, including the position of its Head. In 2022, 13 employees served in the Department, including its Head. It is noted that one employee with a degree in Informatics from the Administrative Department is absent on long-term unpaid leave and is working in a European Organization, and one employee with a secondary education in Administrative – Accounting from the Administrative Department was absent on a nine-month leave for the upbringing of his minor child.

Therefore, in 2022, the total number of those serving in the department was 13.

4. Department of Financial Services

The Department of Financial Services consists of two offices: a) the Budget Execution Office and b) the Budget Preparation and Payments Office, and is staffed by specialized employees with university and secondary education.

The personnel in the permanent positions of the Department amount to four, including the Head.

The responsibilities of the Department include the preparation, execution, and monitoring of the Authority's budget, the management of payroll for members and staff, the procurement of necessary goods and services for the smooth operation of the Authority, the arrangement of transportation for members and staff, the maintenance of necessary accounting and other books, the control and settlement of expenses incurred by the Authority, the issuance of payment orders and their payment through the Integrated Financial Management Information System (IFMIS), the certification of fines to the competent tax offices, and the provision of financial data monthly and as required to the General Accounting Office of the State and to auditing bodies.

No changes occurred in the personnel of the department in 2022.

Staff Recruitment – Mobility

Regarding staff recruitment, in 2022, procedures were initiated for the announcement to fill two EEP-IDAX positions in Communication through ASEP, as well as two PE Administrative – Economic positions (one for the Administrative and one for the Economic Department respectively), one TE Administrative – Accounting position for the Economic Department, one DE Administrative – Accounting position for the Administrative Department, and finally one YD Assistant position for the Administrative Department.

Finally, through mobility, in which the service participated, two secondments were carried out, with one being revoked by the employee who submitted it; ultimately, the second employee, who came from the Ministry of Labor and Social Affairs in the category of PE Administrative-Economic, presented herself and took up a position as EEP-IDAX Auditor with legal responsibilities.

1.4. FINANCIAL DATA

According to the provisions of Article 19 of Law 4624/2019, the Personal Data Protection Authority, as an independent public authority, prepares its own budget, which is drafted under the responsibility of its President and submitted directly to the General Accounting Office of the State, in accordance with the procedure provided in the Public Accounting. The execution of the Authority's budget belongs exclusively to it, within the framework of its full autonomy, and the authorizer of the expenses is its President.

For the fiscal year 2022, the Authority's budget was set at the amount of €2,523,000. The approved budget for 2023 amounts to €2,219,000.

23

22

Annual Activity Report 2022

1.5. OPERATIONAL PROBLEMS, GOALS, AND PROPOSALS

Among the most serious operational issues that concerned the Authority in 2022 were the acute problem of housing, the pressing need to strengthen the human resources and resources of the Authority, the related exemption of the Authority from the ASEP procedures, the reorganization of its Secretariat, and the institutional strengthening of the Authority, mainly in its auditing work. The following sections describe these problems in more detail and present actions, goals, and proposals of the Authority for improving its operational framework.

Since 2019, the Authority has foreseen that the issue of its housing was evolving into a particularly serious problem. The Authority communicated to the Real Estate Service and the Ministry of Finance the need to adjust the rent of office spaces to market prices, but without any response. In 2020, the Authority revised its building program and submitted a relevant housing request to the Athens Real Estate Service, and since then, until today, summer 2023, six announcements for bidding for property leasing have been published, which were unsuccessful, as well as five invitations for direct leasing without success. After the sixth invitation for direct leasing, two offers were submitted, which were rejected by the relevant Housing Committee (formed by the Real Estate Service). It is emphasized at this point that the limit on the rent amount per unit area that applies to the Public Sector is low, which is far from the prevailing rental prices in the real estate market in recent years, making the entire endeavor of finding housing for the Authority even more difficult. The problem would have been resolved if the Real Estate Service had the flexibility to respond to the conditions of the real estate market, even at a lower level than current prices. The current housing situation of the Authority's offices is as follows: In March 2023, the Authority was forced to vacate one of the two floors it occupied, as a result of a temporarily enforceable court decision regarding an eviction lawsuit by the owner of that floor, leading to the inability to house a large part of its services. There is an immediate risk for the office spaces of the floor to which the Authority has been restricted, as the owner of that floor has requested an increase in rent, which the Ministry of Finance does not accept based on the applicable legislation, and has already filed an eviction lawsuit in the Single-Member Court of First Instance of Athens, for which the hearing is set for 06.10.2023.

The risk of complete inability to house the Authority is evident, and for this reason, it is necessary to seek measures to resolve the problem, possibly by taking the necessary legislative or other measures, such as providing the Authority with a suitable building from the broader Public Sector for its housing or allocating the necessary funds at a level that reflects the actual market conditions.

As emphasized on every occasion, since its establishment, the Authority has been characterized by particularly inadequate staffing. It has never been possible to harmonize its staffing with the broad range of responsibilities arising from European and national legislation and the workload that these entail. The continuously increasing volume of incoming cases is a significant inhibiting factor in the Authority's efforts to fully respond to its mission. The negative impact of understaffing, combined with the Authority's low budget, is greater in the development of preventive work, such as systematic audits, and in the awareness-raising of data subjects, responsible parties, and processors. The current active staff of the Authority's Secretariat amounts to approximately 50, out of the 75 planned positions, distributed among specialized scientific personnel in legal and IT fields and communication, as well as administrative and financial staff. The staffing of the Authority significantly lags behind that of equivalent supervisory authorities in other member states. For example, in Hungary, the corresponding Authority has a staff of 128, while in the Netherlands, the staff is 270. The filling of 13 positions for Auditors (legal and IT) requested by the Authority and announced through ASEP in 2018 was completed, despite its urgent nature, after three years, and mainly constitutes a replacement of vacant positions due to departures during the economic crisis, and is included in the aforementioned 50 paid active positions. According to a related study accompanying the draft Organization for the reorganization of the Secretariat, the work that the Authority is called upon to perform requires a minimum total staff of 135 positions, which it assessed as necessary to meet its basic obligations. For this reason, the initial draft of its Organization provided for a corresponding number of positions, but this number was reduced to 91, following a relevant indication from the Ministry of the Interior. Therefore, it is necessary to fill these positions as soon as possible after the completion of the approval process of the Organization.

At the same time, it becomes necessary to increase the financial resources allocated to the Authority

for its operational expenses, beyond the funds intended for staff salaries.

It is also noted that the GDPR, in paragraph 4 of Article 52, provides as an obligation for each member state to allocate to the national supervisory authority "...the necessary human, technical, and financial resources and the necessary facilities and infrastructures for the effective performance of its duties and the exercise of its powers, including those exercised within the framework of mutual assistance, cooperation, and participation in the Data Protection Council." The

The country's response to this obligation remains pending. Since its establishment and until the early years of the economic crisis, the Authority was exempt from the ASEP procedures for hiring its personnel, which aligned with its independence. Despite the fact that ASEP is also an independent authority, its involvement deprives the Authority of the ability to precisely determine the timing of the announcement for filling positions, the duration of the process, and the final selection of personnel, thus violating its independence. The following experience of the Authority regarding the mandatory involvement of ASEP in its personnel recruitment is particularly revealing. In 2018, immediately after the implementation of the GDPR and when the Authority had an urgent need to strengthen its human resources due to departures in the previous years of the economic crisis, the filling of 20 permanent positions was approved: 13 auditor positions, 2 communication positions, and 5 administrative-economic positions. ASEP agreed to announce only the 13 auditor positions, the filling of which was completed in 3 years, while the announcement of the remaining 7 positions was delayed by 4 years, and their filling is still pending, 5 years later. Despite the urgent need to strengthen the Authority with personnel, the provision from national law for hiring only through ASEP deprives the Authority of the ability to manage its human resource needs in a timely and effective manner, as it can be inferred from the aforementioned, ASEP's procedures are particularly rigid and time-consuming, suitable for large organizations with long-term planning and low sensitivity to sudden reductions in their personnel, but completely unsuitable for smaller authorities and other entities, such as the Authority, which must flexibly address sudden departures of even 1 or 2 of its staff members. For this reason, given the urgent need to strengthen the Authority with human resources, it is absolutely necessary to legislate full management of its personnel by the Authority itself, including the filling of approved vacant positions, as required by the GDPR. It is recalled that paragraph 5 of Article 52 of the GDPR states, "Each member state ensures that each supervisory authority selects and employs its own staff who are managed exclusively by the member or members..."

In addition to the above, it is noted that, despite the aforementioned provision of the GDPR and the continuous requests of the Authority for its exemption from ASEP procedures, legislation was promoted and passed to exempt other independent authorities and committees from ASEP procedures, such as EETT, the Competition Commission, and the Single Public Procurement Authority (see the relevant articles on hiring, Articles 56 and 57, and on secondments and transfers, Article 58 of Law 5043/2023 [Government Gazette Issue A' 91/13.04.2023]). Following this recent legislative regulation, it is required that the Authority be included in the scope of Articles 56, 57, and 58 of Law 5043/2023. The inclusion of the Authority in the scope of the aforementioned articles constitutes a rational regulation and does not overturn the rule of filling public service positions through ASEP procedures due to its small size and therefore greater sensitivity to sudden reductions in its personnel, compared to larger committees or authorities (e.g., EETT and the Competition Commission) that are already covered by these regulations. Furthermore, the inclusion of the Authority in these regulations would also be a response from the State to the provisions of paragraph 5 of Article 52 of the GDPR mentioned above.

Regarding the reorganization of its Secretariat, the Authority submitted a draft presidential decree for the approval of a relevant Organization, according to the authorization of paragraph 3 of Article 18 of Law 4624/2019, yet the process has not yet been completed (as of early September 2023). The reorganization of the Authority's services became necessary due to the new data protection framework in the European Union and the country. Initially, the draft Organization was submitted to the Ministry of Justice on 22.11.2022, and subsequently, with significant delays, it was forwarded to the Ministry of the Interior and finally to the Ministry of Finance, taking into account all the comments made by the Authority, including the serious reduction of the projected necessary number of permanent positions

from 135 to 91, following a relevant suggestion from the Ministry of the Interior. This process is being repeated for the third time after the elections of June 25, 2023, without having been completed by early September.

Regarding the institutional strengthening of the Authority, it is first proposed to establish a process for amicable settlement for the rapid handling of complaints in cases of minor significance for the rights of data subjects, and secondly, to give the Authority the ability to obtain necessary information for the audits it conducts from any other public authority that may possess it, in order to make its auditing powers more effective. Furthermore, amendments to Law 4624/2019 are proposed to eliminate contradictory provisions. Specifically, regarding the first two, the following are proposed:

1. The addition of a paragraph to Article 13 of Law 4624/2019 with the following content: "By decision of the Authority, amicable settlement procedures may be applied according to what is stipulated in the Regulation issued under Article 17 of this law, for the resolution of complaints concerning alleged violations, which are estimated to: (a) affect a limited number of data subjects or (b) have limited consequences for the rights and freedoms of data subjects." This process may...

****1.**** It applies in cases of complaints which the Authority assesses as having limited consequences for the data subjects, while aiming to satisfy the data subjects and simultaneously ensure the compliance of the data controller with the legislation. If the process proves unsuccessful or is time-consuming, the Authority exercises the full range of its powers, while in any case retains the discretion to examine any issue concerning the processing of personal data ex officio. It is noted that, based on Article 58(6) of the GDPR, Member States have the option to provide by law that the supervisory authority has additional powers.

****2.**** The replacement of Article 15(1), second paragraph of Law 4624/2019 with the following:

"During the conduct of investigations and audits, the Authority has the power to obtain from the data controller, the processor, and any third natural or legal person, access to all personal data that is subject to processing and all information required for the purposes of the relevant audit and the execution of its duties, without any kind of confidentiality being able to be invoked against it."

Additionally, the addition of a paragraph to Article 39 of Law 4624/2019 with the following content: "In the case of refusal to provide information, data, documents, and personal data, obstruction or hindrance of the Authority's investigations and audits in the case of Article 15(1), second paragraph, including the case of providing inaccurate, misleading, or incomplete information and personal data, an administrative fine of up to €1,000,000 shall be imposed on third natural or legal persons. For determining the amount of the fine, the criteria mentioned in paragraph 2 shall be taken into account, to the extent that they are relevant."

Another issue related to ensuring adequate staffing of the Authority is the provision of incentives for the retention of its personnel. As previously mentioned, particularly during the years of the economic crisis, a large percentage of specialized scientific personnel left, mainly in search of better working conditions. Moreover, as was found during the selection process of the 13 auditors mentioned above, most of the initially selected candidates did not accept due to excessively low remuneration for their qualifications. To retain the personnel of the Authority, particularly the specialized scientific personnel, which constitutes approximately 2/3 of the total, a significant improvement in their remuneration is required, in relation to their contribution to the Authority's work. Furthermore, with Article 59 of the recent Law 5043/2023, special provisions were established for the personnel of seven legally (and not constitutionally) provided independent authorities. Specifically, paragraphs 1 to 6 of this article establish a system of incentives and rewards, paragraph 7 provides for the establishment of committees and working groups to examine issues that require special management or immediate resolution, and sets a maximum percentage of personnel that may participate in these committees and a maximum limit for additional remuneration, while paragraph 8 sets the maximum allowable limit for overtime. It is considered reasonable or even necessary to include the personnel of the Authority in the above provisions in order to enhance the likelihood of their retention in the Authority and to eliminate any discrimination against them in this matter. Furthermore, it is proposed that the provisions of paragraph 1 of Article 25 of Law 4940/2022, which concerns the financial services of public entities, be

applied accordingly to the personnel of the Authority.

For the smooth and effective operation of the Authority, in addition to strengthening the human resources to a satisfactory number and ensuring adequate financial resources, the creation of advanced computing and networking infrastructures is also necessary, including electronic services for use by the controllers, processors, and data subjects. In this direction, following the upgrade of the integrated information system (IIS) and the new online portal of the Authority, which were put into full productive operation at the beginning of 2021, in 2022 the implementation of the project for the expansion of the Authority's IIS began with new, more automated electronic services, such as management of data breach incidents, (self) assessment of security and data protection, and management of audits, as well as the creation of informative content to raise awareness among children on data protection issues. It is noted that this project has been included in the Operational Program "Public Sector Reform" of the NSRF and utilizes funding from the European Union. Furthermore, in 2022, the implementation of the project funded by a European Commission program, byDesign, was completed, with the main results being the creation of a supportive online application for use by controllers and processors (mainly small and medium-sized enterprises) to facilitate their compliance with the GDPR, and the creation of a training program and materials on data protection by design and by default aimed at professionals involved in the development, promotion, and use of information and communication products and services that are also used for the processing of personal data. Additionally, in September 2022, the implementation of another project of the Authority, also funded by a European Commission program, the project byDefault, began following a relevant proposal from the Authority and its successful evaluation by the European Commission. This project aims to create appropriate educational materials for primary and secondary education students on the subject of data protection.

****Data Protection Authority Annual Activity Report 2022****

On one hand, the development of educational programs for educators at the same levels, and on the other hand, the creation of a collaborative electronic space (platform) for use by data protection officers and generally professionals in the field of data protection.

Regarding financial matters, the available credits for the year 2022 decreased again compared to the previous year by approximately 10%, mainly in the major category "Employee Benefits." The available credits for operational expenses did not show a positive change, despite continuous requests for a significant increase. Thus, the necessary credits for the ongoing upgrade of technological infrastructure, including the development and provision of data protection tools to stakeholders, are being sought from other funding sources, as previously mentioned in relation to the current expansion of the Authority's Information System and the byDesign and byDefault projects.

Finally, the establishment of a framework for conducting internships at the Authority and the drafting of a code of ethics for its members and staff is pending.

The following points are also highlighted, as in the reports of previous years:

- The Authority's efforts are guided by the best possible effectiveness in its work, which generally aims to create an overall environment friendly to data protection in our country. To achieve its mission, the Authority must necessarily have adequate staffing, sufficient financial resources, and the necessary technical means and facilities, and it expects the State to respond to these requirements, in compliance with the aforementioned relevant provisions of the GDPR.
- Legislative initiative should also be undertaken to review the legislation on access to public documents and related specific provisions, in order to establish a coherent and clear legislative framework to resolve conflicts of jurisdiction and ensure effective protection of personal data.

31

30

Annual Activity Report 2022

2.

Statistics

In 2022, the number of incoming cases of appeals/complaints amounted to 1,250, an increase of approximately 8% compared to 2021 (from 1,160), while 876 cases of appeals/complaints were processed, also showing an increase of approximately 8% compared to the previous year (from 811). The number of data breach incidents reported to the Authority under the GDPR was 174, a decrease of approximately 4% compared to the previous year (from 181 in 2021), while 35 notifications of data breaches were submitted by electronic communications service providers, based on Law 3471/2006, showing a decrease of approximately 20% (from 44 in 2021), as well as 1 incident according to Article 63 of Law 4624/2019, meaning that the total incidents of breaches showed a decrease of approximately 7%. In 67 cases, the examination of the cases was completed with a decision issued by the Plenary or the Department. Additionally, in 2022, the Authority issued 5 opinions.

It is noted that since 2018, the presented statistical data differ from those of previous years, reflecting changes in the Authority's responsibilities that primarily occurred with the implementation of the GDPR. Specifically, statistical data for inquiries from data controllers are no longer presented, as the Authority no longer has this duty, nor for notifications of processing records or international transfers and licenses, as there is no corresponding obligation for data controllers or authority jurisdiction, respectively. On the other hand, the cooperation of the Authority with counterpart supervisory authorities of member states for cross-border cases (one-stop-shop mechanism) is now provided for, as well as within the framework of the European Data Protection Board (consistency mechanism), the prior consultation with the Authority for high residual risk processing after conducting a data protection impact assessment, the examination and approval by the Authority of codes of conduct and certification criteria of relevant schemes, etc., with the related activities described in the following Chapter 3. Beyond these, the provision of information to data subjects, upon request, for the exercise of their rights is also provided, which is done either orally or with a written response.

The total number of incoming documents to the Authority in 2022 amounted to 12,917, an increase of approximately 55% compared to 2021 (from 8,320). Compared to 2017 – when the highest annual number of incoming documents (10,991) was recorded before 2022 – the increase in incoming documents amounts to approximately 18%. In the years 2018 to 2021, the flow of incoming documents was restrained, initially due to the implementation of the GDPR and in 2020 and 2021 due to the pandemic. As expected, there is now a significant increase in the flow of incoming documents and, correspondingly, in cases for the Authority, an element that indicates the urgent need to increase its human resources and the resources available to it. Regarding the method of submission of incoming documents to the Authority, the very high percentage of electronic submissions in 2020 and 2021 was maintained in 2022, as it reached approximately 96% (from about 90% in 2020 and 96.8% in 2021), and specifically, submissions via email accounted for approximately 70% (from 64.82% in 2021) and through the online portal accounted for 26.2% (from 32% in 2021 and 5% in 2020). We observe a stabilization in the degree of use of email and the electronic services of the Authority offered through the online portal. Of course, the Authority seeks to maximize the use of its electronic services, with the greatest possible margin for the automation of document management tasks, and for this reason, it makes continuous efforts to utilize technological capabilities and generally improve its computing infrastructure.

Regarding the aforementioned notifications of data breach incidents provided for in the GDPR, out of the 174, 12 concerned cross-border processing and in 57 cases, data subjects were informed, while of those related to electronic communications, only one concerned cross-border processing and in 5 cases, data subjects were informed. Regarding data breach incidents, in addition to the statistics of this chapter, see also section 3.4.

In 51 of the Authority's decisions, sanctions were imposed on data controllers. In 12 cases, the sanction of reprimand - warning for compliance was imposed after a complaint and hearing, and in 39 cases, a fine was imposed, the amount of which ranged from €1,000 to €20,000,000. It is clarified that in 6 of these 39 decisions of the Authority, in addition to the monetary sanction...

33

32

Annual Activity Report 2022

of fines and the sanction of reprimand - warning. In total, fines amounting to €30,060,000 were

imposed. The Authority imposed the sanctions for violations of the provisions of the GDPR, Article 2: Material scope, Article 3: Territorial scope, Article 4.1: Personal data (definition), Article 4.2: Processing (definition), Article 4.6: Filing system (definition), Article 4.7: Data controller (definition), Article 4.5: Pseudonymization (definition), Article 4.12: Personal data breach (definition), Article 4.15: Data concerning health (definition), Article 5.1: Principles of data processing, Article 5.1.a: Principle of lawfulness, fairness, and transparency, Article 5.1.b: Principle of purpose limitation, Article 5.1.c: Principle of data minimization, Article 5.1.d: Principle of accuracy, Article 5.1.e: Principle of storage limitation, Article 5.1.f: Principle of integrity and confidentiality, Article 5.2: Principle of accountability, Article 6.1.a: Legal basis of consent, Article 6.1.b: Legal basis of contract performance, Article 6.1.c: Legal basis of compliance with a legal obligation, Article 6.1.d: Legal basis of vital interests, Article 6.1.e: Legal basis of public task performance, Article 6.1.f: Legal basis of legitimate interests, Article 6.4: Compatibility of processing for another purpose, Article 7: Conditions for consent, Article 9.1: Special categories of personal data, Article 9.2.a: Explicit consent, Article 9.2.e: Manifestly made public, Article 12: Transparent information, Article 12.2: Facilitation of the exercise of rights, Article 12.3: Deadline for response to a right, Article 12.4: Deadline for informing non-action on a right, Article 13: Information when collecting from the data subject, Article 14: Information when collection is not from the data subject, Article 15: Right of access, Article 17: Right to erasure, Article 21: Right to object, Article 24: Responsibility of the data controller, Article 24.2: Implementation of appropriate policies for data protection, Article 25.1: Data protection by design, Article 25.2: Data protection by default, Article 26: Joint controllers, Article 27: Representatives of controllers or processors outside the EU, Article 28: Processor (arrangements), Article 29: Processing under the authority of the controller or processor, Article 30: Records of processing activities, Article 31 - Law 4624/2019 Article 66: Cooperation with the supervisory authority, Article 32: Security of processing, Article 33: Notification of a personal data breach, Article 34: Communication of a personal data breach, Article 35: Data protection impact assessment, Article 37 - Law 4624/2019 Article 6: Definition of the data protection officer, Article 55: Competence of the supervisory authority, Article 83: General conditions for imposing administrative fines, the provisions of Law 3471/2006 Article 2.3: Traffic data (definition), Article 2.4: Location data (definition), Article 5: Processing rules (ePrivacy), Article 6: Processing of traffic and location data (ePrivacy), Article 11.1: Unsolicited electronic communications, Article 11.3: Use of previous contact details for electronic communications, Article 12.1: Security of Processing (ePrivacy), Article 12.5: Notification of personal data breach (ePrivacy), Article 12.6: Communication of personal data breach (ePrivacy), Article 95: Relationship with Directive 2002/58/EC and the provisions of Law 4624/2019 Article 27: Processing of data in the context of employment relationships.

The above 51 decisions of the Authority are categorized into the main thematic areas as follows: 6 in the Health sector, 7 in the Private Economy sector, 5 in the Promotion of Products and Services sector (advertising, spam, telemarketing), 1 in the Education – Research sector, 6 in the Labor Relations sector, 4 in the Closed-Circuit Television sector, 8 in the Public Administration – Local Government – State action sector, 2 in the Mass Media sector, 7 in the Financial sector, 4 in the Electronic Communications Services sector, and 1 in Others.

In 2022, the Authority was informed of the submission to the Council of State (CoS) of 11 annulment applications, of which 3 concerned decisions of the Authority from the year 2022 and the remaining 8 decisions of the Authority from the year 2021. 12 annulment applications against decisions of the Authority from previous years were discussed, in one case the applicant withdrew, and 7 decisions of the CoS were issued, of which 3 rejected and 4 accepted (of the last 4, 3 concern cases of political communication).

In this chapter, statistical data are presented regarding incoming documents, their categorization and submission methods, the analysis of incoming, processed, and pending cases of appeals/complaints in thematic areas, incoming and processed requests for information from data subjects and requests from entities, as well as comparative tables of incoming and outgoing documents, cases of appeals/complaints, decisions and opinions of the Authority, and applications for registration in the registry of Article 13, for the period 1999/2000 to 2022. Additionally, statistics related to incidents of data breaches reported to the Authority are included, reflecting their monthly flow and the security objectives they concern, as well as their cross-border or non-cross-border nature. Furthermore,

specific statistical data regarding the number of incoming and processed requests in 2022 related to registrations of foreigners in the Schengen Information System and the country of origin of the applicants are included. Finally, statistics regarding the cooperation of the supervisory authorities of the member states and the implementation of the consistency mechanism (see section 3.7) are also included, as well as categorization.

****Annual Activity Report 2022****

****Decisions of the Authority by thematic unit and applicable provision.****

35

34

With 51 decisions, fines amounting to €30,060,000 were imposed.

174 incidents of violation were reported based on GDPR and 35 based on Law 3471/2006.

****Fines****

****Violation Incidents****

67 decisions and 5 opinions were issued.

****Decisions - Opinions****

876 appeals - complaints were processed.

****Complaints****

2022

****Significant statistical data****

37

36

****Web Portal****

3383

****E-mail****

9045

****Mail****

160

****Courier****

29

****Registered****

137

****In person****

131

****Bailiff****

32

****Total****

12917

13%

2%

8%

10%

0%

67%

****Complaints / Requests****

1695

****Incident Notifications****

256

****European - International****

1086

****Appointment / Change / Deletion of DPO****

1247

****Confidential Incoming****

19

****Other Incoming****

8614

****Total****

12917

****Complaints****

1245

****Requests for information****

166

****Requests from entities****

125

****Requests for Article 13 list****

159

****Total****

1695

****Annual Activity Report 2022****

****CATEGORIZATION OF INCOMING DOCUMENTS****

****Diagram 1 - Incoming documents****

****Diagram 2 - Method of submission****

26%

70%

1%

0%

1%

1%

1%

****Diagram 3 - Categorization of incoming documents regarding appeals/complaints, inquiries, and requests for the Article 13 registry****

****Notes:****

1. The above total of appeals/complaints includes confidential appeals/complaints.

2. The number of incoming documents by category does not match the number of cases shown in the following tables, as some documents pertain to the same case.

74%

10%

7%

9%

39

38

****Annual Activity Report 2022****

****CATEGORIZATION OF INCOMING, PROCESSED, AND PENDING CASES OF COMPLAINTS BY THEMATIC SECTORS****

****Diagram 4 - Incoming cases of complaints****

****Law Enforcement Authorities - Security****

27

****National Defense****

1

****Public Administration - Local Government - State action (tax/insurance)****

73

****Health****

62

****Private Insurance****

6
Education and Research (education, research institutions)
26
Financial
90
Private Economy
148
Promotion of products and services (advertising, spam, telemarketing)
419
Electronic communication services (telecom providers)
45
Labor Relations
51
Mass Media
21
Internet Services (search engines, social networks)
38
New Technologies
17
Video Surveillance
191
Others
35
Total
1250
2%
0%
6%
5%
0%
2%
7%
12%
34%
4%
4%
2%
3%
1%
15%
3%
Diagram 5 - Processed cases of complaints
Law Enforcement Authorities - Security
4
National Defense
1
Public Administration - Local Government - State action (tax/insurance)
45
Health
40
Private Insurance
6
Education and Research (education, research institutions)

16

****Financial****

73

****Private Economy****

110

****Promotion of products and services (advertising, spam, telemarketing)****

276

****Electronic communication services (telecom providers)****

53

****Labor Relations****

20

****Mass Media****

9

****Internet Services (search engines, social networks)****

20

****New Technologies****

10

****Video Surveillance****

167

****Others****

26

****Total****

876

0%

0%

5%

5%

1%

2%

8%

13%

32%

6%

2%

1%

2%

1%

19%

3%

41

40

****Annual Activity Report 2022****

****Diagram 6 - Pending cases of complaints****

****Note:**** From the 2014 Report, newly incoming, processed, and pending Schengen appeals are included in the thematic unit "Sector of law enforcement authorities and public order," which were previously recorded separately.

****Law Enforcement Authorities - Security****

250

****National Defense****

7

****Public Administration - Local Government - State action (tax/insurance)****

197

****Health****

117

****Private Insurance****

24

****Education and Research (education, research institutions)****

65

****Financial****

206

****Private Economy****

415

****Promotion of products and services (advertising, spam, telemarketing)****

775

****Electronic communication services (telecom providers)****

201

****Labor Relations****

159

****Mass Media****

78

****Internet Services (search engines, social networks)****

38

****New Technologies****

39

****Video Surveillance****

205

****Others****

1,741

****Total****

4,517

6%

0%

4%

3%

1%

1%

5%

9%

17%

4%

4%

2%

1%

1%

5%

39%

****CATEGORIZATION OF INCOMING AND PROCESSED CASES OF REQUESTS FOR INFORMATION BY THEMATIC SECTORS****

****Diagram 7 - Incoming cases of requests for information****

****Law Enforcement Authorities - Security****

5

****National Defense****

1

****Public Administration - Local Government - State action (tax/insurance)****

19

****Health****

10

****Education and Research (education, research institutions)****

7

****Financial****

27

****Private Economy****

10

****Promotion of products and services (advertising, spam, telemarketing)****

4

****Electronic communication services (telecom providers)****

5

****Labor Relations****

9

****New Technologies****

2

****Video Surveillance****

26

****Others****

20

****Total****

145

3%

1%

13%

7%

5%

19%

7%

3%

3%

6%

1%

18%

14%

43

42

****Annual Activity Report 2022****

****Diagram 8 - Processed cases of requests for information****

2%

1%

9%

6%

3%

15%

6%

2%

8%

3%

2%

5%

30%

11%

****Law Enforcement Authorities - Security****

4

****National Defense****

1

****Public Administration - Local Government - State action (tax/insurance)****

17

****Health****

12

****Education and Research (education, research institutions)****

5

****Financial****

29

****Private Economy****

11

****Promotion of products and services (advertising, spam, telemarketing)****

4

****Electronic communication services (telecom providers)****

15

****Labor Relations****

6

****Internet Services (search engines, social networks)****

3

****New Technologies****

10

****Video Surveillance****

58

****Others****

21

****Total****

196

****CATEGORIZATION OF INCOMING AND PROCESSED CASES OF REQUESTS FROM ENTITIES BY THEMATIC SECTORS****

****Diagram 9 - Incoming cases of requests from entities****

****Law Enforcement Authorities - Security****

8

****Public Administration - Local Government - State action (tax/insurance)****

34

****Health****

13

****Education and Research (education, research institutions)****

10

****Private Economy****

7

****Electronic communication services (telecom providers)****

1

****Labor Relations****

7

****Mass Media****

1

****Internet Services (search engines, social networks)****

2

****New Technologies****

3
Video Surveillance
23
Others
5
Total
114
7%
30%
11%
9%
6%
1%
6%
1%
2%
3%
20%
4%
Annual Activity Report 2022
Chart 10 - Completed Cases of Requests from Entities
Law Enforcement Authorities - Security
11
Public Administration - Local Government - State Action (tax/insurance)
31
Health
12
Education and Research (education, research institutions)
4
Financial Services
1
Private Economy
13
Promotion of Products and Services (advertising, spam, telemarketing)
6
Electronic Communication Services (telecom providers)
4
Labor Relations
3
Mass Media
1
Internet Services (search engines, social networks)
2
New Technologies
3
Video Surveillance
25
Others
8
Total
124
9%
25%

10%
3%
1%
10%
5%
3%
2%
1%
2%
2%
20%
6%

****NOTIFICATIONS OF BREACH INCIDENTS****

****Chart 11 - Notifications of Breach Incidents 2022 by Month****

10
15
17
6
15
8
18
14
31
22
11
7
6
1
1
2
5
4
1
3
5
2
5
1
0
5
10
15
20
25
30
35

****General Data Protection Regulation****

****ePrivacy****

****Art. 63 of Law 4624/2019****

****Annual Activity Report 2022****

****Chart 12 - Update of Subjects of Breach Incidents 2022****

****Chart 13 - Breach Incidents under GDPR Regarding Security Objectives****

****Integrity + Availability****

1

****Availability****

43

****Confidentiality****

100

****Confidentiality + Integrity****

5

****Confidentiality + Availability****

15

****All****

10

****Total****

174

57

117

5

30

****Yes****

****No****

0

20

40

60

80

100

120

140

****General Data Protection Regulation****

****ePrivacy****

****Art. 63 of Law 4624/2019****

0%

25%

57%

3%

9%

6%

****Chart 15 - Cross-Border Breach Incidents 2022****

12

162

34

****Yes****

****No****

0

20

40

60

80

100

120

140

160

180

****General Data Protection Regulation****

****ePrivacy****

****Chart 14 - Breach Incidents under ePrivacy Regarding Security Objectives****

****Integrity****

1

****Confidentiality****

33

****All****

1

****Total****

35

3%

94%

3%

****Annual Activity Report 2022****

****NOTIFICATIONS - REQUESTS FOR CROSS-BORDER COOPERATION****

****LEGITIMACY CHECK OF ENTRIES IN THE SCHENGEN INFORMATION SYSTEM****

****Chart 16 - Notifications - Requests for Cross-Border Cooperation****

0

100

200

300

400

500

600

700

****Greek Authority****

****Cooperation****

****Consistency****

2022

0

2

645

597

5

168

39

****Article 56 - Request for Local Handling****

****Article 56 - Recognition of the Head and Interested Supervisory Authorities****

****Article 60 - One-Stop Service - Cooperation****

****Article 61 - Mutual Assistance****

****Article 64 - Opinion from the EDPB****

****Chart 17 - Deletion Requests from the SIS****

****Deletion Requests from the Schengen Information System in 2022****

****Submitted Requests****

17

****Albania****

10

****Russia****

1

****Bangladesh****

1

****Pakistan****

1

****Turkey****

4

****Total****

17

59%

6%

6%

6%

23%

****COMPARATIVE STATISTICAL DATA****

The following charts depict the annual numbers of incoming and outgoing documents, cases of appeals/complaints, decisions and opinions of the Authority, registration requests in the registry of Article 13 for the period 2000 - 2022, as well as the annual numbers of incoming documents via web portal and email (since 2007).

****Note:**** Since 2008, the statistics of appeals/complaints are drawn from the new information system of the Authority, which allows the registration of incoming documents by case.

1229

3369

3804

4494

4930

6416

7609

9963

6706

7150

7321779974617746

82637929

9292

10991

10468

7563

76968320

12917

0

2000

4000

6000

8000

10000

12000

14000

2000

2001

2002

2003

2004

2005

2006

2007

2008

2009

2010

2011

2012

2013

2014

2015

2016

2017

2018

2019

2020

2021

2022

****Incoming Documents****

583

3142

2838

3039

3050

4762

5896

5053

3680

3719

38564286

42634442

4678

3788

4408

4180

2760

3031

26042766

3466

0

1000

2000

3000

4000

5000

6000

7000

2000

2001

2002

2003

2004

2005

2006

2007

2008

2009

2010
2011
2012
2013
2014
2015
2016
2017
2018
2019
2020
2021
2022

****Outgoing Documents****

13
719 663
905
1865
1095
469
260 282
231
171
231 245
128 158
220
153
91
54
172 159
0
200
400
600
800
1000
1200
1400
1600
1800
2000

2002 2003 2004 2005 2006 2007 2008 2009 2010 2011 2012 2013 2014 2015 2016 2017 2018 2019
2020 2021 2022

****Article 13 Registry Applications****

233
285
663
904
236
626
816
1095
1054

670
702674
812
675
562
659
506
714
921
847
983973
1160
1250
0
200
400
600
800
1000
1200
1400
1999
2000
2001
2002
2003
2004
2005
2006
2007
2008
2009
2010
2011
2012
2013
2014
2015
2016
2017
2018
2019
2020
2021
2022
Complaints
22
83
163
100
63
72
81

68 65 69

91

84

168

194

158

202

138

132

152

75

48 51

61

67

0

50

100

150

200

250

1999

2000

2001

2002

2003

2004

2005

2006

2007

2008

2009

2010

2011

2012

2013

2014

2015

2016

2017

2018

2019

2020

2021

2022

****Decisions****

****Annual Activity Report 2022****

****ISSUED DECISIONS 2022 IN THEMATIC AREAS****

****National Defense****

2

****Decisions No. 2 and 3****

****Public Administration - Local Government - State Action****

8

****Decisions No. 14, 15, 27, 29, 42, 47, 58, and 59****

****Health****

6

****Decisions No. 7, 8, 28, 36, 37, and 41****

****Education - Research****

4

****Decisions No. 44, 45, 61, and 62****

****Financial Services****

7

****Decisions No. 6, 25, 52, 53, 54, 55, and 56****

****Private Economy****

6

****Decisions No. 11, 35, 40, 46, 51, and 66****

****Electronic Communication Services****

5

****Decisions No. 4, 23, 38, 39, and 57****

****Promotion of Products and Services (advertising, spam, telemarketing)****

9

****Decisions No. 16, 17, 18, 20, 21, 26, 30, 48, and 63****

****Labor Relations****

6

****Decisions No. 12, 19, 24, 32, 49, and 68****

****Mass Media****

2

****Chart 18 - Comparative Statistical Data****

7

3

3

4

3

2

0

4

4

7

5

6

5

7

8

7

3

1

5

8

5

0

1

2

3

4

5

6

7
8
9
2002 2003 2004 2005 2006 2007 2008 2009 2010 2011 2012 2013 2014 2015 2016 2017 2018 2019
2020 2021 2022
Opinions
0
652
635
831
859
918 1127 1227 1119
1530
1866
1151
379
353
2660
3383
289
1017
1475
1884
2183 2007 1949
2346 2434
3045
4014
6033
5618
6441
5393
9045
0
1000
2000
3000
4000
5000
6000
7000
8000
9000
10000
2007
2008
2009
2010
2011
2012
2013
2014
2015
2016

2017

2018

2019

2020

2021

2022

****Electronic Submission of Documents****

****Web Portal****

****Email****

****Decisions No. 31 and 67****

****New Technologies****

1

****Decision Number: 43****

****Video Surveillance****

6

****Decisions No. 1, 5, 10, 34, 50, and 60****

****Others****

5

****Decisions No. 9, 13, 64, 65, and 69****

****Total****

67

****ISSUED DECISIONS 2022 & APPLICABLE PROVISIONS****

53

52

Annual Activity Report 2022

55

54

Annual Activity Report 2022

57

56

Annual Activity Report 2022

3.

Sectors

3.1. COMPLAINTS

In 2022, the Authority received 1,259 complaints and issued 67 decisions and 5 opinions. Specifically, 442 complaints were submitted regarding illegal processing of personal data, 298 complaints concerning unsolicited marketing calls for products and services, 19 Schengen appeals, 356 complaints regarding violations of the rights of data subjects, and 144 complaints about unsolicited electronic communications (SPAM/email-SMS).

The largest number of incoming complaints concerned illegal processing of personal data, electronic communications, and specifically unsolicited marketing calls for products and services, unsolicited electronic communications (SPAM), followed by complaints regarding the private economy, video surveillance, public administration, labor relations, the financial sector, and health.

Regarding the decisions issued, most pertained to electronic communications, public administration, and labor relations.

3.1.1. NATIONAL DEFENSE

In the context of the above thematic area, the Authority examined a series of issues presented to it, which pertain to the protection of personal data and involve the processing of personal data primarily by the Ministry of National Defense.

Specifically, following a complaint that the issued type A military certificate unlawfully contained the information that the complainant had not fulfilled his military obligations and that he had been

exempted from the obligation to serve, the Authority determined that it was sufficient to certify that the complainant had no military obligations, and called upon the Ministry of National Defense, as the data controller, to reissue the military status certificate type A for the complainant, stating only that he no longer has any military obligations (decision 2/2022).

Additionally, following a complaint that the issued type A military certificate, in addition to certifying that the complainant has no military obligation, also included his military changes and the fact that he has completed alternative service, without these pieces of information being necessary for the specific purpose for which the certificate was requested, the Authority determined that it was sufficient to certify that the complainant has no military obligations, and called upon the Ministry of National Defense, as the data controller, to reissue the military status certificate type A for the complainant, stating only that he no longer has any military obligations (decision 3/2022).

3.1.2. PUBLIC ADMINISTRATION AND SELF-GOVERNMENT

The Authority examined a citizen's complaint regarding the sending of a mail folder to his residential address, the exterior of which contained personal data more than what was necessary for his identification as the recipient. The Authority determined that this specific incident was due to an oversight, as it was accepted that the standard practice of the complained Municipality is to send folders, the exterior of which only displays the name, surname, and address of the recipient. As a result, the Authority imposed an administrative sanction of reprimand on the data controller for violating Article 5(1)(b), (c), (f) of the GDPR (decision 14/2022).

The Authority also determined that the complained transmission of letters to third parties, unauthorized entities [Workers and Employees Union of the Municipality and the Panhellenic Federation of Workers (P.O.E.) – OTA], during the evaluation stage of the complainant as an evaluated employee, which contained personal data of the complainant, was done in violation of the provision of Article 5(1)(a) of the GDPR and imposed an administrative fine on the respondent (decision 15/2022).

Furthermore, the Authority examined a citizen's complaint regarding the loss of two medical certificates concerning the complainant (who belongs to a vulnerable group) which his wife had attached with his consent to her application to the complained Social Protection Center – where she works – in order to request her transfer to a service position that does not require daily contact with the public (back office), for reasons of protection.

59

58

Annual Activity Report 2022

of her husband due to the coronavirus. The Authority found that a) the complainant's right of access to these opinions was not satisfied, which he had exercised with a relevant written request to the respondent b) the respondent Social Protection Center had not appointed a Data Protection Officer during the relevant period, c) the management process, on the part of the respondent, of this request along with the attached medical opinions did not meet the level of protection of the GDPR and its general spirit, especially the principle of accountability, and that in this case appropriate technical and organizational measures had not been taken. For these reasons, the Authority imposed an administrative fine on the respondent Center in the total amount of 9,000 euros, for the established violations of Articles 15, 32, and 37 of the GDPR, in accordance with Article 58 paragraph 2 (h) of the GDPR in conjunction with Article 83 paragraphs 4 and 5 of the GDPR and Article 39 paragraph 1 of Law 4624/2019 (decision 27/2022).

Furthermore, the Authority examined a citizen's complaint regarding the partial satisfaction of the right to rectification. The complainant alleged that he submitted a request to the competent Civil Registry Office, concerning the correction of his mother's surname in his birth certificate, based on the attached birth certificate of his mother, and that he subsequently requested a copy of his birth certificate after the correction was made. The Civil Registry Office then sent the complainant a copy of his birth certificate, which, according to the complainant, shows that a handwritten correction of his mother's surname has occurred and a corresponding correction in the Citizens' Registry information system, without, however, mentioning the correction in the margin of the original entry of the act in the relevant year's civil registry volume and without mentioning it in the corresponding field "Corrections/Changes"

in its transition to the Citizens' Registry information system.

The Authority determined that the accuracy and completeness of personal data must be assessed based on the purpose for which the data was collected and is being processed, concluding that in this case, considering the purpose of processing (maintaining an accurate record of citizens' personal data for their identification and verification of their civil status, from which rights and obligations arise), it appears that the addition of the aforementioned additional information concerning the correction (e.g., when the correction took place, by whom, on what legal basis, etc.) is necessary in order to reflect the sequence of events—especially since the error was subsequently corrected. Therefore, the right to rectification exercised by the complainant was partially satisfied, as the respondent Municipality responded to it and corrected the erroneous personal data; however, it did not register this change and did not follow a specific archiving procedure for this correction, so that it would be clear to third parties, as well as to the administration itself, when this correction took place, by whom, on what legal basis, and for what reason. For these reasons, the Authority imposed the administrative sanction of reprimand on the respondent for the established violation of Article 5 paragraph 1 (d) of the GDPR (decision 29/2022).

Additionally, the Authority, during the examination of an appeal, issued a warning and reprimand to a data processor for failure to implement organizational measures and for not previously informing the data subject. Specifically, the appealing physician reported the medical association, of which he was a member, for illegal processing and specifically for disclosing to a third party a document containing his personal data from a disciplinary file. The respondent claimed that in an effort to reach a settlement between the parties, he provided the disciplinary procedure file, including the document in question, to a representative of the complainant who had initiated the disciplinary procedure. In fact, the respondent claimed that he had anonymized the aforementioned documents. However, the respondent did not prove before the Authority, within the framework of the accountability principle, the truth of the above claims, as he did not provide relevant evidence. This inability was essentially due to the failure to take appropriate organizational measures and protection policies. Specifically, regarding the obligation to inform the data subject in advance, the respondent did not prove that he took the corresponding action (decision 31/2022).

The Authority imposed the sanction of reprimand on a Municipality for failing to satisfy the right of access and instructed it to satisfy the complainant's right in question. It also issued a recommendation to the Municipality based on Article 19 paragraph 1 (c) of Law 2472/1997 for failing to inform the complainant about the processing of a decision by the Supreme Court in accordance with Article 7A paragraph 1 (a) of Law 2472/1997 (decision 42/2022).

Moreover, the Authority imposed a monetary fine of 5,000 euros on a data processor in the context of electoral processes, for transmitting personal data to third parties, acting in this way as a data controller and without informing the data subjects about this transmission (decision 47/2022).

The Authority examined a complaint from a citizen against the Mayor of his area. The citizen received a congratulatory message from the Mayor, to an email account he had created specifically for the Municipality's electronic services application. The complainant objected, requesting not to receive any further messages, but received another congratulatory message after a few months. After examining the complaint, the Authority found that the Mayor, using the complainant's contact details, violated the principle of data minimization.

****Purpose****, as such use was not expected by the data subject, violated the obligation to provide appropriate information under Article 14 of the GDPR and did not properly satisfy the exercised right, in violation of Article 12 paragraph 3 of the GDPR. For all violations, the Authority imposed a fine of 2,000 euros (decision 48/2022).

Furthermore, the Authority found that the reported processing of sending the tax clearance certificate in an envelope with a window, from which the amount of the complainant's declared income was visible, was carried out in violation of the provisions of Articles 5 paragraph 1 point (f) and 32 of the GDPR, without taking appropriate technical and organizational measures, thus compromising the confidentiality of the data, and imposed a monetary fine of 8,000 euros on the Independent Authority for Public Revenue (AADE), as the data controller (decision 58/2022).

Finally, the Authority determined that the mention of the imposition of a penalty and the relevant applicable provisions on the temporary identity certificate of a member of the Fire Brigade constitutes a violation of the provision of Article 5 paragraph 1 point (c) of the GDPR and imposed an administrative fine on the reported entity, while instructing the Fire Brigade and the Ministry of Citizen Protection to issue relevant guidelines (decision 59/2022).

****3.1.3. EDUCATION AND RESEARCH****

Following a complaint from educators regarding the legality of the processing of personal data carried out in the context of electronic voting for the election of elected representatives of educators in the Primary and Secondary Education Service Councils, the Authority concluded a) that this processing complies with the rules and conditions of personal data protection legislation, b) since the activity is systematic and concerns the introduction and organization of an electronic governance service, specifically electronic voting, the Ministry, as the data controller, was obliged to conduct a Data Protection Impact Assessment (DPIA) prior to the introduction of this method, regardless of whether this is provided for in national law, as the GDPR applies directly, and c) the Electoral Committees cannot be considered Data Controllers either independently or jointly with the Ministry of Education, according to the provisions of Articles 4 point 7 and 26 of the GDPR. For these reasons, the Authority instructed the Ministry of Education and Religious Affairs to conduct a DPIA without delay and in any case before the next electronic voting for Service Councils, and to restore the proper application of the provisions of Articles 4 point 7 and 26 of the GDPR by informing the Authority accordingly (decision 44/22).

The Authority also examined a complaint from an unemployed person against the OAED (Public Employment Service) for the leakage of his personal data and against the vocational training centers KEC MASTER and KEC EXELIXI for the illegal processing of his data. The complainant, an unemployed person registered with the OAED, after expressing interest in participating in a subsidized employment and training program of the Ministry of Labor, received a phone call from the two reported KECs in order to receive the training services provided by them. From the examination of the complaint, no incident of data leakage by the OAED was found. Regarding KEC MASTER, it was found that during the initial phone communication, the complainant believed he was speaking with representatives of the OAED, being confused, which was due, at least in part, to the inadequate and unclear information he received from them. Therefore, the Authority issued a warning to KEC MASTER for the identified failure to comply with the principle of transparency. The reported KEC EXELIXI, while initially claiming that it found the complainant's details from an internet search, later stated that the complainant had filled out an expression of interest form on its website, through which he provided his consent, a fact that the complainant denies. It was found that the consent process invoked by KEC EXELIXI does not meet the requirements of Article 7 of the GDPR and is not valid, particularly due to inadequate information and the lack of confirmation procedures for the provided data, while additionally, the KEC conducted further searches for the complainant's details on the internet in the context of examining the complaint, without substantiating the legality of the above processing actions, nor the adherence to the principle of transparency towards the complainant. For this reason, a fine of 10,000 euros was imposed on KEC EXELIXI (decision 45/2022).

Furthermore, the Authority examined ex officio the compliance of the Ministry of Education and Religious Affairs with the recommendations of decision 50/2021 regarding the compatibility of modern distance education in primary and secondary education schools with the provisions of legislation on the processing of personal data. The Authority concluded that no new corrective measure is required and called on the Ministry to make necessary amendments to improve transparency. Specifically, the information provided to data subjects through the website must follow a multi-layered approach, while improvement is required regarding the use of "cookies." The Authority will examine the broader issue of the application of Chapter V of the GDPR to video conferencing services of companies that belong to a group controlled by an entity subject to U.S. law with other supervisory authorities through the cooperation and consistency procedures of the Regulation (decision 61/2022).

Additionally, the Authority examined a complaint concerning the collection of data from third sources

about a candidate for a teaching position by the reported university, for the purpose of evaluating his candidacy. Due to broader interest, and specifically because, in the opinion of the Department of the Authority that examined the complaint, the search, collection...

****Data Collection and Correlation of Candidate Faculty Members from Third Sources****

The collection and correlation of data regarding candidate faculty members from third sources for the purpose of evaluating their candidacies raises issues concerning the fulfillment of legality, transparency, and the existence of a legal basis, as well as the provision of information to the candidates. These issues present broader interest and concern a significant and indeterminate number of both data subjects and data controllers, namely the candidate faculty members on one hand and the Higher Education Institutions (HEIs) on the other. Therefore, the Department referred the case in question to the Plenary of the Authority for examination (decision 62/2022).

Finally, a complaint by a citizen (a graduate) requesting the deletion of a disciplinary penalty from their "student record" was archived as evidently unfounded, with the act numbered Γ/ΕΞ/1478/17-06-2022, because on one hand, the imposed disciplinary penalty is recorded only in the academic record of the student, which is maintained in the University's archives and is not noted on the diploma, and on the other hand, the retention of the information regarding the imposed disciplinary penalty in the University's archive, to which only the data subject, the President, faculty members, and Secretariat members have access, serves legitimate purposes and does not contravene the legislation on personal data protection. According to Article 17 paragraph 3(d) of the GDPR, the provisions regarding the satisfaction of the right to erasure do not apply to the extent that processing is necessary for archiving purposes in the public interest.

****3.1.4. HEALTH****

****Vaccination/Illness Certificates****

Complaints were submitted to the Authority regarding the collection of vaccination/illness certificates within the framework of the mandatory vaccination of the staff of OKANA, in accordance with the provisions of paragraphs 1 and 2 of Article 206 of Law 4820/2021. The Authority examined these complaints within the scope of its ex officio competence, pursuant to Articles 57 paragraph 1(a) and (h) of the GDPR and 13 paragraph 1(h) of Law 4624/2019, as on one hand, personal data of the complainants were not processed by OKANA, and on the other hand, in any case, processing (collection) of copies of vaccination/illness certificates of OKANA employees fell under the regulatory scope of Articles 2 paragraph 1 of the GDPR and 2 of Law 4624/2019. Specifically, the Authority, in decisions 7/2022 and 8/2022, found that vaccination/illness certificates related to COVID-19, as well as equivalent certificates or attestations provided for in the provisions of Articles 205 and 206 paragraph 5 of Law 4820/2021, constitute health-related data under Article 4(15) of the GDPR, and their processing is subject to the formalities regarding the processing of special categories of personal data under Articles 9 of the GDPR and 22 of Law 4624/2019. Furthermore, the Authority, in decisions 7/2022 and 8/2022, concluded that the complained processing of the collection of vaccination/illness certificates of employees by OKANA, both pursuant to the provision of Article 205 of Law 4820/2021 – that is, at a time before it was clarified whether OKANA staff were subject to mandatory vaccination – and pursuant to the provision of Article 206 of Law 4820/2021, as well as after the issuance of decision Δ1α/ΓΠ.οικ.52796 (Government Gazette B 3959/27.8.2021) and prior to the interoperability of the relevant information systems, was carried out in violation of the principle of Article 5 paragraph 1(a) of the GDPR, as the compliance check with the obligation to present the vaccination/illness certificate pursuant to Articles 205 and 206 paragraph 5 of Law 4820/2021 is specifically regulated by the provision of Article 33 of Law 4816/2021. Consequently, the Authority, in decisions 7/2022 and 8/2022, taking into account, among other things, the fact that OKANA securely destroyed the unlawfully collected vaccination/illness certificates, issued a reprimand, pursuant to Article 58 paragraph 2(b) of the GDPR, to OKANA, as the data controller, for the collection of vaccination/illness certificates of its employees in violation of the principles of Article 5 paragraph 1(a) and (c) of the GDPR.

****Right of Access to Health Data****

The Authority examined a complaint from a father of a minor regarding the non-response of the child psychologist, who was monitoring his child, to a related request to provide him with personal data concerning his child. The Authority, in decision 28/2022, found that the complained child psychologist satisfied the father's right of access to his child's data late and inadequately, in violation of the provisions of Articles 12 paragraph 3 and 15 of the GDPR, and issued a reprimand (Article 58 paragraph 2(b) of the GDPR) to the complained child psychologist for these violations and ordered the complained child psychologist (Article 58 paragraph 2(c) of the GDPR) to satisfy the complainant's right of access to the extent that it has been exercised, both regarding his initial request to the complained psychologist and regarding the subsequently submitted request before the Authority, which was forwarded to the complained psychologist and has not yet been satisfied. Additionally, the Authority, in decision 28/2022, emphasizing the independent obligation of the data controller to cooperate with the supervisory authority under Article 31 of the GDPR, found ex officio and within the framework of the examined complaint that the complained child psychologist, by not responding to the relevant requests of the Authority, which explicitly informed her of the obligation to comply with Article 31 of the GDPR, violated the independent obligation to cooperate with the Authority under Article 31 of the GDPR and imposed an administrative fine.

The Authority examined a complaint from a patient regarding the violation of the right of access by a diagnostic center. Specifically, the patient requested to receive copies of the images included in the medical record of the diagnostic center that pertained to the digital mammography conducted approximately two and a half years earlier.

****TERA.**** The diagnostic center, in response to the relevant request from the patient, informed her that there is no possibility of reprinting images from the machine that performed the specific imaging examination, as this particular machine had the capability to store files for 3 months, and for this reason, the diagnostic center proceeded with its replacement. The Authority, with decision 36/2022, taking into account the Guidelines 1/2022 of the European Data Protection Board (hereinafter EDPB Guidelines 1/2022) regarding the rights of data subjects – right of access, concluded that a violation of the patient's right of access could not be established, according to the provisions of Article 15 of the GDPR. This is because, at the time of exercising the right of access, the relevant data from the imaging examination had become unavailable. Furthermore, in the context of examining the complaint regarding the violation of the right of access due to the unavailability of the patient's personal data, the Authority examined ex officio the overall compliance of the diagnostic center with the obligations to maintain the security of processing, the obligation to notify any personal data breach, and the obligation or not to announce any personal data breach as per Articles 32-34 of the GDPR, respectively. With decision 36/2022, the Authority first established that the loss of availability of the relevant imaging examination constitutes a violation of the principle of Article 5(1)(f) of the GDPR, due to the failure to take appropriate technical and organizational measures to ensure an adequate level of security under Article 32 of the GDPR, and imposed an administrative fine on the diagnostic center. Secondly, it found that the notification of the personal data breach to the Authority was made late, in violation of Article 33 of the GDPR, and issued a reprimand to the diagnostic center. Thirdly, the Authority, with this decision, ordered the diagnostic center to notify the affected data subjects of the personal data breach, in accordance with the provisions of Article 34 of the GDPR.

A complaint was submitted to the Authority by the father of a minor regarding the provision of data (medical examinations) of the minor child by the complained pediatrician. The Authority, with decision 37/2022, reiterated its established case law that each parent exercising parental responsibility has, as the legal representative of the minor, the right of access to information concerning their minor child, which is included in a filing system, without the need for a specific legal interest on their part. Additionally, the Authority, in the same decision, countering specific claims of the complained party, emphasized, among other things, that the complained pediatrician, as the data controller, in satisfaction of the right of access, was obliged to respond to the complainant even if only to state that they do not retain any data concerning the minor child in their records, that for the satisfaction of the right of access, there is no legal requirement for the prior personal acquaintance of the data subject with the respective data controller, and that the exercise of the right of access does not need to take

place in a specific form or ceremoniously, e.g., by invoking the provisions of the GDPR or with an explicit reference to its exercise. The Authority, with decision 37/2022, found that the complained pediatrician violated the right of access of the complainant father to data concerning his minor child and imposed an administrative fine. Furthermore, the Authority examined ex officio and in the context of the complained violation the overall compliance of the complained party with the independent obligation to cooperate with the Authority under Article 31 of the GDPR. The Authority, in relation to this violation, assessing the circumstances of the specific case, found with decision 37/2022 that the complained pediatrician violated the obligation to cooperate with the Authority and imposed an administrative fine.

In the context of examining a complaint regarding the violation of the right of access of a father of a minor by a child psychiatrist, the Authority, with document no. G/EXE/94/13.01.2022, pointed out to the complained child psychiatrist that they must respond promptly, even negatively, in case they do not retain any medical data of the respective interested data subject and, in the context of the examined case, provided that they do not retain other medical data of the minor child of the complainant, that they must, on the one hand, provide the complainant with the requested opinion to the extent that it contains personal data of the minor child, and on the other hand, assess as the data controller, based on the principle of accountability (Article 5(2) of the GDPR), whether they have an obligation to provide the complainant with the requested tax document following relevant notification to the mother whose details are recorded on the body of the tax document.

In the context of examining a complaint regarding the violation of the right of access against a psychologist, the Authority, noting that the complained party did not respond to the duly exercised right of access within the legally prescribed deadlines, with document no. G/EXE/2863/14.11.2022, drew the attention of the complained psychologist to the fact that they must respond duly and promptly to the relevant access rights exercised by the data subjects before them, as well as that in this case, they must provide the complainant with the requested opinions to the extent that the latter include personal data of the minor children. Furthermore, the Authority pointed out in relation to the...

α

It is stated above that the data controller is not exempt from its obligation towards the data subject to satisfy the right of access duly exercised by the latter solely on the grounds that the requested information may be known to the data subject from another source.

Data transmission and processing by an occupational physician

The Hospital Workers' Association reported to the Authority that members of the Association discovered that their personal records at EOPYY showed that they had received paid visits from EOPYY and had conducted them with a specific occupational physician, who had been assigned to the Hospital following a relevant contract between the Hospital and a specific company, without the employees ever being informed about it and, in any case, without having conducted the contested medical visits. The Authority took up this specific case within the framework of its ex officio competence and with decision 68/2022 found that, firstly, the Hospital failed to inform the employees, pursuant to Article 13 paragraph 1 point e of the GDPR, about the transmission of their personal data to the occupational physician and did not implement policies and procedures, in accordance with Article 24 paragraph 1 of the GDPR, for the processing of its employees' data that was carried out for the promotion of their health and safety at work according to the provisions of Law 3850/2010, nor had specific technical and organizational measures been provided in the contract that the Hospital had concluded with the contracting company for the provision of an occupational physician to it, and imposed an administrative fine on the Hospital for these violations. Secondly, the Authority found that the contracting company, which had undertaken the processing on behalf of the Hospital for the provision of an occupational physician to the employees, violated the obligations established by the provision of Article 28 paragraph 4 of the GDPR, as it did not take specific organizational and technical measures to ensure that the processing of data by the occupational physician would be carried out in accordance with the requirements of the GDPR and imposed an administrative fine on the company. And thirdly, the Authority found that the occupational physician, acting as a data controller beyond the powers assigned to him under the assignment contract, pursuant to Article 28 paragraph 10 of the

GDPR, processed health data of the Hospital's employees without their knowledge in violation of the principle of legality of Article 5 paragraph 1 point a of the GDPR and imposed an administrative fine on the physician.

Inadequate security measures due to design failure

A complaint was submitted to the Authority by a physician-employee of the Hospital, who reported to the Authority that there was a leak and improper use of her credentials on the electronic platform for managing ICU beds by the Hospital. From the case file, it emerged that there was no record of any incident in the specific electronic application using the credentials of the complainant that would prove the alleged leak and improper use of her personal credentials. However, following the complaint, it was determined by EOPYY, which as the executor has taken on the authentication of physicians as users on the specific platform, that there was a design failure in it, which was subsequently corrected.

Following this, the Authority, with document no. G/EXE/1799/13.07.2022, pointed out to both the reported Hospital and EOPYY the obligation to ensure data protection from the design stage, pursuant to Article 25 paragraph 1 of the GDPR, as well as the obligation to reassess the technical and organizational security measures taken and the need to update them, according to the provisions of Article 24 paragraph 1 point b of the GDPR.

Incident of violation of encrypted data

The Authority examined a complaint from a patient against a diagnostic center, which concerned the sending of medical examination results via email to a third party (recipient). From the case file, it emerged that the sending of the file containing the examination results of the complainant via email to an unauthorized person was carried out by the diagnostic center in encrypted form and that the ability to decrypt it was provided using the client code, which is stated in the body of the service provision receipt. Therefore, the reading of the said file was not possible by the third (unauthorized) person/recipient of the relevant email message, since that person did not have access to the complainant's client code. Consequently, it was found that with the erroneous sending of the relevant email message of the complainant to a third unauthorized person-recipient, there was no disclosure of the complainant's personal data to a third party that would justify a violation of the confidentiality of Article 5 paragraph 1 point f of the GDPR. Following the above, the Authority, with document no. G/EXE/3421/07.12.2022, drew the attention of the reported diagnostic center that, as the data controller, it must take and implement in every case the technical and organizational security measures of the processing in accordance with Articles 24 and 32 paragraph 1 of the GDPR. Specifically, there must be verification of the identity of the examined person using further identification details beyond the surname (indicatively: AMKA, email, phone number), in order to avoid any incidents of violation of data confidentiality, in the absence of appropriate technical and organizational security measures.

3.1.4.1. Pandemic management

The Authority, taking into account the fact that in the context of addressing the pandemic crisis due to the coronavirus COVID-19...

9 and for the prevention of its spread in the community, systematic processing of personal data of minors (students) and adults took place during the implementation of the mandatory diagnostic testing measure for coronavirus infection across a wide range of professional, social, and economic activities. Furthermore, inquiries were submitted to the Authority by data subjects regarding the implementation of the mandatory self-testing measure, within the framework of exercising its ex officio jurisdiction, and following the announcement under protocol number Γ/ΕΞΕ/1278/21.05.2021, the processing of personal data that occurred under seven total Joint Ministerial Decisions was examined, as amended and in force, by virtue of relevant legal provisions (articles 2 par. 1 and 46 of law 4790/2021 and 27 par. 6 of law 4792/2021) concerning the free provision of self-tests to eligible individuals, the declaration of the results of the relevant tests in the special electronic application self-testing.gov.gr, and the further processing of data after the declaration of results. In this context, the compliance of the five named data controllers in the relevant Joint Ministerial Decisions was examined, namely of ΗΔΙΚΑ ΑΕ, the Ministry of Labor and Social Affairs, the Ministry of Interior, the Ministry of Education and Religious Affairs, and the NAT, with specific requirements of the legislation on personal data protection. With decision 41/2022, it was initially established that although the examined Joint

Ministerial Decisions were repealed, the Authority has the jurisdiction to address the processing of personal data, as extensive and systematic processing of special categories of data took place, which had legal consequences (salary deductions, exemption from the obligation to pay salaries).

Subsequently, it was determined that the Ministry of Education and Religious Affairs was incorrectly identified as the data controller in the specific Joint Ministerial Decision, for the category of religious officials registered in the registry of article 14 of law 4301/2014, according to article 1 subparagraph.

69

68

Annual Activity Report 2022

b'. Furthermore, the Authority, in decision 41/2022, found that HDIKA S.A., the Ministry of Labor and Social Affairs, the Ministry of Interior, and NAT, as data controllers under the relevant Joint Ministerial Decisions (KYA), failed to include in the information provided to the data subjects specific details of Article 13 of the GDPR to ensure the requirement for transparent information, and issued a reprimand for this violation. Furthermore, it was found that HDIKA S.A., as a data controller under the relevant KYA, violated the principle of storage limitation (Article 5(1)(e) of the GDPR) due to the failure to take appropriate organizational and technical security measures (pursuant to Article 25 of the GDPR) and an administrative fine was imposed. Additionally, regarding compliance with the principle of storage limitation, the Authority instructed NAT to remove the application it developed in its information system pursuant to decision no. D1/G.P.οικ.26389/24-04-2021 (Government Gazette B'1685) and to delete any data of seafarers-crew members of ships that may exist therein in compliance with the principle of Article 5(1)(e) of the GDPR. Finally, the Authority, in decision 41/2022, reprimanded HDIKA S.A. and the Ministry of Labor and Social Affairs for the late preparation and inadequate impact assessment they submitted, and imposed an administrative fine on the Ministry of Interior and NAT for their non-compliance with the obligation to conduct an impact assessment.

In light of announcements from Palantir Technologies and numerous related publications in the press regarding the collaboration of the Greek government with this company to address the pandemic, the Authority, within the scope of its ex officio competence, called upon the Ministries of Digital Governance and Health, the General Secretariat for Civil Protection, and the National Public Health Organization to provide specific clarifications. In decision 43/2022, the Authority found that the data transmitted to Palantir could no longer be attributed to a specific data subject, that the level of data protection was satisfactory, and that the potential risks to the data subjects were extremely low. Furthermore, given that Palantir has permanently deleted and destroyed all data, the Authority concluded its ex officio investigation on the matter, unless new evidence arises.

3.1.5. PRIVATE INSURANCE

A complaint was submitted to the Authority by an insured individual regarding unlawful processing. Specifically, the insured complained about the sending of a folder to him (which contained a letter regarding the expiration of the premium payment deadline), on the external side of which was indicated the subject of the letter (warning of cancellation of the insurance policy), resulting in personal data of the complainant being disclosed to third parties (see also section 3.1.2 Public Administration and Local Government, decision 14/2022). In decision 1/2022, the Authority determined that the complained processing was carried out in violation of the principle of data minimization under Article 5(1)(c) of the GDPR, as for the sending of the folder to the insured complainant and his identification, it was sufficient to include the full name, postal address, and postal code of the complainant/insured, and the further information indicated on the external side of the folder was not appropriate and proportionate in relation to the purpose served by the specific processing, and issued a reprimand to the insurance company for the aforementioned violation. Additionally, in the same decision, the Authority instructed the insurance company to henceforth process personal data in compliance with the requirements of the GDPR, including the principle of proportionality.

3.1.6. FINANCIAL SECTOR AND PRIVATE ECONOMY

3.1.6.1. Credit/Financial Institutions

The Authority examined the compliance of four banks with the provisions of its decision no. 48/2018, which addressed the issue of processing personal data through contactless transactions with debit/credit cards, the arising security issues of such processing, and the related risks. Specifically,

during the examination of the banks' compliance with the aspect of the aforementioned decision, which concerned the retention in the chip of Mastercard debit/credit cards of the banks' customers of the history of recent (specifically the last 10) transactions conducted using these cards, which (transaction history) can also be read contactlessly, the Authority determined that the banks should provide specific information to the data subjects; however, the banks in question had not complied, as they did not provide relevant information but proceeded with the replacement of the aforementioned cards. The Authority, in its decisions no. 53/2022, 54/2022, 55/2022, and 56/2022, imposed an administrative fine of 20,000 euros on each of these banks for violation of Article 13 of the General Regulation (EU) 2016/679, pursuant to Article 58(2)(h) of the GDPR in conjunction with Article 83(5) of the GDPR. A complaint was submitted to the Authority against a bank for a personal data breach incident, consisting of the sending of Winbank Alerts notifications to a third party, with the full name of the complainant, which continued despite the relevant notification to the bank. The Authority, after investigating the incident, found that it was due to the incorrect declaration of the email address by the beneficiary of the complainant, and although the bank was notified accordingly, it did not stop sending the notifications but indicated to the complainant the way to... the right to rectification should be exercised by the data subject, as the subject. The Authority, with its decision No. 6/2002, found a violation of the principle of confidentiality (Article 5 paragraph 1 subparagraphs d and e) of the GDPR, and a violation of the bank's obligations to notify the incident to the Authority and to the data subject (Articles 33 and 34 of the GDPR), for which violations an administrative fine of a total amount of €10,000 was imposed. Additionally, the Authority issued a warning to the bank regarding the inadequate technical and organizational security measures (Articles 24 and 32 of the GDPR) that were identified, due to the lack of measures to verify the electronic addresses provided for the purpose of sending Winbank Alerts notifications.

Complaints were submitted to the Authority regarding the securitization of a claim without the consent of the debtor or for the provision of borrower data to Debt Management Companies and Debt Acquisition Companies, similarly, without prior consent and notification. The Authority examined and archived the complaints (see, for example, G/EXE/281, 605, 781, 965, 1406, 1679, 1686, 2295, 2346, 2682/2022), which were vague and inadmissible, without prior adherence to the pre-litigation procedure (i.e., the complainant had not exercised any specific right of theirs, according to Articles 12-22 of the GDPR towards the data controller, where applicable). Regarding the substance of the complaints, it was noted that according to Article 10 of Law 3156/2003 on the securitization of claims, the consent of the debtor is not required. Furthermore, Law 4354/2015 provided for two new categories of companies, the Debt Management Companies from Loans and Credits (E.D.A.D.P.) and the Debt Acquisition Companies from Loans and Credits (E.A.A.D.P.), as lawful recipients of bank debtor data under the aforementioned law, without requiring the consent of the debtors. Moreover, the Authority, under the regime of Law 2472/1997, issued relevant decisions (see particularly decisions 87 and 134/2017), which refer to the manner of informing debtors about the provision of their data to these companies. The complaints were archived, in which, upon examination, it was found that, beyond any other notification (e.g., through the media), individualized notification had also been made regarding the aforementioned actions with a letter to the debtor.

However, in another case of a complaint by a data subject against a Debt Management Company: a) for illegal processing of personal data consisting of continuous phone harassment of a debtor, who, to the knowledge of the complained company (which managed the relevant claims against her with powers, according to the applicable legislative framework, as a creditor), had a judicial discharge from her remaining debts, and b) for not substantively examining the rights exercised by the complainant, as a data subject, claiming the alleged inability to identify her, the Authority, with its decision No. 25/2022, found that in this specific case, the complained company unjustifiably obstructed the exercise of the complainant's rights, in violation of the provision of paragraph 2 of Article 12 of the GDPR, and that the relevant processing took place without a legal basis due to the encompassing nature of the complainant's judicial discharge from the relevant debts. Furthermore, the Authority in this specific case found a violation of the provisions of Articles 5 paragraph 1 subparagraph a, 5 paragraph 2, and 6 of the GDPR. With the aforementioned decision, the Authority imposed an administrative fine of

€10,000 on the complained company for the violation of the provision of Article 12 paragraph 2 of the GDPR and €10,000 for the violations of Articles 5 paragraph 1 case a, 5 paragraph 2, and 6 of the GDPR.

The Authority examined a complaint against a bank from a customer who is in litigation with the bank and the former manager of the branch where he maintains a safe deposit box, for the illegal transmission to his adversary of a document containing his personal data. Specifically, the complained bank provided the complainant's adversary with a document (Notification of Operational Risk Event), which details the complainant's visit to the said branch and other information that falls under his banking confidentiality, at a time when the complainant's adversary was no longer the branch manager, thus being a third party in relation to the bank concerning this specific processing. The Authority, with its decision No. 52/2022, found that the collection, recording, and retention of the complainant's data in the aforementioned document, as well as its transmission to his adversary, had taken place in violation of the principle of legality, objectivity, and transparency of the processing, because the bank did not sufficiently document the legal basis for the initial collection and processing, while the complainant had not been informed as a subject about the relevant processing of his data nor was he informed prior to the transmission of the document, so he had the opportunity to exercise his rights as a subject, and imposed an administrative fine of €40,000 on the complained bank.

Following a complaint from a bank customer regarding the non-fulfillment of the right of access to recorded telephone conversations with its representatives, the Authority issued a recommendation to the bank (G/EXE/1085/2022), stating that it must process and satisfy the relevant requests of data subjects within the deadlines provided in Article 12 paragraph 3 of the GDPR, ensuring the adoption of appropriate organizational and technical measures, where necessary. In other cases, the Authority took actions...

****1. Archiving of Complaints Against Banks for Non-Compliance with Right of Access to Recorded Conversations****

As without object (G/EXE/985/2022, G/EXE/1358/2022, and G/EXE/3284/2022), given that it was found that the right had been satisfied by the complained banks before their opinions were requested, while the delay in providing the requested data was justified in the aforementioned cases.

Complaints were submitted to the Authority against a bank, according to which the bank allegedly requested the complainant to unlawfully update their information. The Authority archived the complaints as unfounded (see indicatively G/EXE/1220, 1421, 1676/2022), as according to the Acts 281/2009, 2652/2012, 94/2013 of the Hellenic Data Protection Authority (HDPa), financial institutions are obliged, in accordance with the provisions of the law for the prevention and suppression of money laundering (see provisions of Law 4557/2018 and the earlier Law 3691/2008), to ascertain and verify the identity of their clients or counterparties and to request documents that certify the specific details of the natural person. Among these details are those concerning income (see also the 2652/2012 Act of the Governor of the Bank of Greece "the income of the client-natural person is verified by the bank based on the income tax clearance certificate", see also relevant information on the Authority's website under the thematic section Financial and Informative Bulletin of the Authority July 2015).

****2. Another Case of Complaint Against a Bank for Excessive Data Collection****

In another case of a complaint against a bank for excessive data collection, according to the complainant's claims, in order to satisfy her request for correction of her identity details and specifically her surname, based on a court decision and a decision of the Mayor, the Authority archived the complaint (G/EXE/3169/2022), as it deemed that the bank responded satisfactorily to the said request, considering that according to Law 4557/2018 for the prevention and suppression of money laundering and the financing of terrorism (incorporation of Directive 2015/849/EU) and other provisions, and the relevant Acts of the Bank of Greece, financial institutions are obliged to certify and verify the identity of the counterparty, applying due diligence procedures to existing clients and to request documents that certify the specific details of the individual. According to the aforementioned regulatory framework, in application of due diligence measures, the bank, determining the extent of due diligence measures,

may request, beyond the minimum required details for the certification of natural persons, any relevant information that certifies the change of the client's identity details (such as in this case a family status certificate).

****3. Further Complaints Submitted to the Authority****

Furthermore, a complaint was submitted to the Authority regarding a violation of rights against a bank concerning a request for copies of withdrawal slips from a joint account. The Authority archived the complaint (G/EXE/1473/2022), as it found that the bank's response was satisfactory from the perspective of the GDPR and that regarding the data on the provided receipts, namely the names of those who received the relevant amounts, which were deleted by the bank, the complainant is considered a third party. Therefore, the Authority does not have the jurisdiction to order the satisfaction of requests from third parties for the provision of information nor can it impose sanctions for the non-provision of personal data to third-party requesters (see relevant opinion 4/2009, available on the Authority's website), given that the GDPR does not establish claims for third parties for the provision of information, nor does it establish as a rule the right of access for a third party to the personal data of the subject.

The assessment of whether the conditions set out in Article 6(1) of the GDPR (under which the processing of simple data is exceptionally permitted without the consent of the subjects) are met and the decision to transmit personal data to the requesting third party (e.g., based on the overriding legitimate interest) ultimately belongs to the data controller (in this specific case, the bank), which is subject to the control of the civil courts.

****4. Complaints Against TEIRESIAS S.A. for Non-Compliance with Right to Deletion of Entries Regarding Debts****

Finally, complaints were submitted to the Authority against TEIRESIAS S.A. for non-compliance with the right to deletion of entries regarding debts in the credit registry (SCR). These complaints were examined and archived as unfounded (G/EXE/1510, 1960, 2519/2022), as no violation of the complainant's rights was found. According to the Authority's assessment, TEIRESIAS S.A.'s response regarding the request for deletion of the mentioned loan, with the indication "closure of credit with repayment," is, in principle, reasonable and satisfactory from the perspective of the GDPR, see the Authority's decisions 86/2002, 68/2005, and Article 40(2) of Law 3259/2004, as amended and in force, regarding the prescribed retention period of the relevant financial data, namely data retained in the credit registry (SCR or "White" List) by TEIRESIAS S.A., for the benefit of credit or financing institutions. This registry includes data concerning information about risks that natural and legal persons have received from all types of financing, including those arising in the context of the application of laws for debt regulation or relevant decisions of the Bank of Greece. It is another matter that the complainant may, if and whenever they wish, request the non-transmission of the aforementioned data, in which case the relevant indication will be transmitted (as was also pointed out to them in TEIRESIAS S.A.'s response).

****3.1.6.1.1. Debt Information Companies** Submitted...**

****3.1.6.1. Complaints Regarding Disturbances in the Context of Debtor Notifications****

If the Authority received various complaints regarding disturbances in the context of notifying debtors, claiming that either the lender themselves (through their employees and/or through their lawyer) disturbed the complainant by phone regarding their overdue debts or that they were disturbed, on behalf of the lender, by a Debt Collection Company, without their own consent, approval, or authorization. The Authority examined and archived the complaints (see, for example, G/EXE/957, 1675, 1914, 2257, 2306, 2775, 2776, 2931, 2932, 3308/2022) which were:

- Clearly unfounded, as the lender has the right to process the debtor's data without the latter's consent. This processing is permitted as necessary for the execution of their contract with the lender, e.g., in the sense of the smooth continuation of the transactional relationship (through telephone reminders of the debt). It was also noted that according to Law 3758/2009, the lender has the right,

under specific conditions, to provide Debt Collection Companies with information regarding overdue claims of their debtors and that the consent of the latter is not required for this processing. Regarding the obligation to inform, see decision 98/2017, with the note that this decision was issued based on a legal framework that is no longer in effect, specifically relying on an interpretation of Law 3758/2009 in conjunction with the already repealed Law 2472/1997, while the GDPR and Law 4624/2019 (Government Gazette A' 137/29-08-2019) have already come into effect, the provisions of which are now applicable for the assessment of this issue. Furthermore, the Authority emphasized that according to the 3/2020 decision of the Plenary of the Supreme Court (contrary to decision 98/2017), it was accepted that in the case of data being provided to a processor, subject to one of the categories of recipients (e.g., Debt Collection Companies) for which notification has been made, there is no obligation for the data controller to provide a new specific notification to the data subject (i.e., at the time of providing the personal data to the specific Debt Collection Company),

- Inadmissible, as the required pre-procedure was not followed, since if the complainant wishes to exercise any of their rights as a data subject, they must first address the data controller (lender) in the appropriate manner, on whose behalf the calls are made. The Authority encourages complainants, if they have no relation to the sought debtor and the debt, to exercise their rights (especially correction/deletion/restriction of their data, e.g., by providing any relevant evidence for the possession of the called telephone number) to the data controller,
- Not falling within the scope of the legislation for the protection of personal data and/or the jurisdiction of the Authority, as the principles and framework within which debtor notifications must occur (e.g., to which phones, with what frequency, etc.) are defined in Law 3758/2009. The competent authority for the reported allegations (e.g., for continuous disturbances at inappropriate hours and/or on work phones and/or disturbances exhibiting offensive/threatening behavior) is the General Secretariat for Commerce and Consumer Protection, which has, under Law 3758/2009, general supervision over the activities of Debt Collection Companies and debtor notifications, whether conducted by Debt Collection Companies or by the lender themselves. Finally, the complaints regarding disturbances from a law firm were archived (see, for example, G/EXE/1084, 2608, 3303, 3304, 3307/2022, as for the assignment of a case to a law firm (for extrajudicial or judicial collection of a debt), no consent, approval, or authorization from the debtor is required (see Article 6 paragraph 1 subparagraphs b and f, Article 9 paragraph 2 subparagraph f of the GDPR), and the competent authority for the reported allegations (regarding repeated disturbances and/or offensive behavior by a lawyer) is the relevant Bar Association (see also decision 49/2011 of the Authority, Opinion 598/2012 of the Legal Council of State, from 14.11.2014 Press Release of the Athens Bar Association).

****3.1.6.2. Private Economy****

The Authority examined a complaint against a OPAP agency, according to which the complainant's police identity card was used by an unknown third party without her knowledge for the purpose of definitively creating an online account that had been created on the OPAP joker website, which requires personal presence at an agency, presentation of the original police identity card, digital photography, and its registration in OPAP's systems. From the examination of the complaint, it was found that OPAP, as the data controller, had taken appropriate technical and organizational security measures and had established procedures that prevented harm to the complainant. The Authority, in its decision No. 11/2022, found that the processing of the complainant's personal data took place without a legal basis and that the relevant violation was due to the inadequate verification of identity by the reported agent, as the processor, who did not follow OPAP's recorded instructions. Therefore, the Authority addressed: a) to the agent, as the processor, a reprimand for violating Articles 6 paragraph 1, 5 paragraph 1 subparagraphs a and f, 24, and 32 of the GDPR due to processing the complainant's personal data without a legal basis and due to inadequate adherence to the identification procedure, and b) to OPAP, as the data controller, a warning to conduct checks and indeed more effective ones on the processing agents, in order to ensure their compliance with the identification instructions for potential customers – players. Furthermore, the Authority examined a complaint from a data subject regarding the non-satisfaction of rights of access and deletion. The complainant, a recipient of a package that had been sent via a courier company...

****Received from a clever point, requested access to all personal data held by the company, information regarding the collection process, and specifically whether the registration of the identity number is necessary in the clever point system, as well as information regarding the company managing the clever points and acting as the data recipient. Additionally, he requested the deletion of his data from both the courier company and the recipient. From the examination of the complaint, it was found that the courier company did not inform the complainant about the details of the data processor, as the recipient of his data, and did not provide him access to all the information it holds about him. Regarding the deletion request, although the courier company forwarded the request to the data processor, which confirmed the deletion of the data, the courier company, as the data controller, did not provide the complainant with any definitive response, while the explanations it provided to the Authority regarding the retention period and data deletion procedures were vague and contradictory. The Authority, in its decision No. 40/2022, found that the complained courier company violated the complainant's right of access under Article 15 of the GDPR and the complainant's right to deletion under Article 17 of the GDPR in conjunction with the principle of accountability (Article 5(2) of the GDPR) and imposed an administrative fine of 30,000 euros for each of the above violations.****

****A complaint was submitted to the Authority by a data subject for the non-fulfillment of the right of access to recorded calls at the call center of an electronic communications service provider. The complainant, a subscriber of the said provider, after an incident of SIM card swapping by an unknown third party impersonating the complainant, contacted the customer service department of the provider on the same day, requesting the deactivation of the second SIM card and subsequently requesting the replacement of his SIM card again. He then filed a complaint with the National Telecommunications and Postal Commission (EETT), in which he requested to be informed about the content of the first call, believing it should have been recorded. The complained company, in a letter to the EETT, which was communicated to the complainant, instructed him to fill out a specific application form for the disclosure of the recorded conversation, which the complainant did, thus requesting copies of the three aforementioned calls. The said company did not respond in any way to the complainant's request, only after the filing of the complaint and the intervention of the Authority, after six months, when it informed him that the requested calls had not been recorded, and the contrary information had been given to the complainant during the procedure before the EETT by mistake. The Authority, in its decision No. 46/2022, reprimanded the company for the established violation of Articles 12(3) and (4) and 15 of the GDPR, due to its late response to the complainant's access request and due to the incorrect information provided to him regarding the fulfillment of his right.****

****Additionally, the Authority examined two related complaints regarding the violation of the right of access to recorded conversations against a polling company. The said right was exercised by the complainants, as participants in a survey conducted by the aforementioned polling company. The Authority, in its decision No. 65/2022, initially accepted the request for withdrawal from the complainant, archiving one complaint, while for the other, it found that a violation of Articles 12(1), (3), (4), and 15(1) of the GDPR occurred, in that the complained company never responded to the exercised right, even to inform that it did not have the requested element in its records, and imposed a reprimand for the above violations. At the same time, it ordered the complained polling company to take action to establish, within two months from the receipt of the decision, procedures to adequately fulfill the rights of data subjects and to inform the Authority accordingly.****

****The Authority examined a complaint against a company providing beauty center services regarding the non-fulfillment of the right of access exercised by the complainant, a client of the company. The Authority, in its decision No. 66/2022, found that the complained company fulfilled the complainant's right of access late and inadequately, in violation of the provisions of Articles 12(3) and 15 of the GDPR, and imposed an administrative fine of 2,000 euros for the violation of these provisions. Furthermore, the Authority ordered the complained company (Article 58(2)(c) of the GDPR) to fulfill the complainant's right of access in the part that has not yet been satisfied. Additionally, the Authority, having determined that in this specific case the complained company violated its independent obligation to cooperate with the Authority under Article 31 of the GDPR, imposed an administrative fine**

of 5,000 euros for this violation.**

****Furthermore, two complaints were submitted to the Authority against an energy provider regarding the non-fulfillment of the right to rectification/deletion of a phone number of a person who is disturbed for a debt of another customer, for which the energy provider requests, from the applicants for rectification, the debtor's supply number. The Authority, after investigating the relevant complaints, sent recommendations to the complained company (Γ/ΕΞΕ/831/2022), noting that it should establish a proper procedure for examining such issues, identifying the relevant parties.****

****Subject and Disconnection of the Relevant Phone Number from the Provision of the Debtor.**** In the same document, it was emphasized that in the event that the data subject informs the company that they have no relation to the sought debtor and the debt, and exercises their right to rectification/deletion through the appropriate procedure in order to disconnect their phone number from the provision of the debtor, they should not be required, in order for their request to be examined and satisfied, to provide information that does not fall within their knowledge (such as, for example, the debtor's provision number), as they cannot know this.

****Complaints Submitted to the Authority Against Another Energy Provider for Violation of Access Rights to Recorded Conversations.**** The Authority examined these complaints and issued a recommendation to the said energy provider (Γ/ΕΞΕ/3195/2022). Specifically, given that in this particular case the complained company satisfied the complainants late, it thoroughly explained to the Authority the reasons for the delay, citing the extremely adverse conditions prevailing in the energy market during the relevant period. The Authority drew the attention of the complained company to the fact that it must process and satisfy the relevant requests of the data subjects within the deadlines provided in Article 12, paragraph 3 of the GDPR, taking into account the existing conditions (and any exceptional circumstances), ensuring the adoption of appropriate organizational and technical measures where necessary.

****Following a Complaint Regarding Possible Leakage of Netflix Codes Stored on a Smart TV,**** the Authority, in its document (Γ/ΕΞΕ/1790/2022), made a recommendation to the complained company to maintain appropriate organizational security measures, in accordance with Article 24 of the GDPR, during the delivery of smart devices for repair, including televisions capable of storing access codes.

****The Authority Examined a Complaint Against an Electronic Communications Service Provider Regarding the Process of Issuing Academic Identity from Its Stores.**** The Authority, having established that indeed upon the receipt of the complainant's academic identity from a store of the company, the Ministry of Education's folder was handed over to the complainant opened, without it being clear whether this occurred with their consent, issued a recommendation (Γ/ΕΞΕ/885/2022) to the complained company for the continuous monitoring of the implementation of the adopted technical and organizational security measures, among which the delivery of the identity to the entitled student should be done in a sealed envelope.

****Finally, a Complaint Was Submitted Regarding the Non-Satisfaction of the Right to Deletion of User Data from an Online Gambling Platform.**** The Authority examined the complaint and archived it (Γ/ΕΞΕ/2679/2022) as inadmissible, as the data subject had not previously approached the data controller in the appropriate manner to exercise the right to deletion mentioned in the complaint, but also as obviously unfounded, noting that according to Article 47, paragraph 5 of Law 4002/2011 (Government Gazette A' 180), as amended by Article 198 of Law 4635/2019 (Government Gazette A' 167), the holder of the license for conducting online gambling is obliged to store in a physical mechanism located in Greece (server or safe) the data related to the conduct of online gambling, as well as the data exchanged between the player, the license holder, the internet service provider, and financial institutions regarding these games. The data is kept in secure means, which allow for the exact reproduction of the stored data by the Gaming Supervision and Control Commission (ΕΕΕΡ), as well as by all competent auditing and judicial authorities, for a period of ten (10) years. Furthermore, according to Article 17, paragraph 3, subparagraph b of the GDPR, the provisions regarding the satisfaction of the right to deletion (right to be forgotten) do not apply to the extent that processing is necessary for compliance with a legal obligation that requires processing under Union law or the law of

the member state to which the data controller is subject.

****3.1.6.3. Internet Services – New Technologies – Biometrics – Artificial Intelligence****

A complaint was submitted to the Authority by the Non-Profit Civil Company named "Homo Digitalis" on behalf of a complainant, who claimed that their right of access exercised towards the company named Clearview AI Inc, based in the USA, was not satisfied. In this complaint, an examination of the overall practices of the complained company from the perspective of personal data protection was also requested. Specifically, the Authority, in its decision No. 35/2022, found that in this particular case the complained company, which trades in facial recognition services, violated the principles of legality and transparency (Articles 5, paragraph 1, subparagraph a, 6, 9 of the GDPR), as well as the obligations arising from the provisions of Articles 12, 14, 15, and 27 of the GDPR, and imposed an administrative fine of 20,000,000 euros. Additionally, the Authority issued a compliance order to the aforementioned company for the satisfaction of the access request filed before it by the complainant. Furthermore, it imposed a prohibition on the collection and processing of personal data of subjects located in Greek territory, using methods that include the facial recognition service. Finally, the Authority issued an order to the complained company for the deletion of the personal data of the aforementioned subjects located in Greek territory, which it collects and processes.

data on the internet/social media. The Authority examined these complaints and noted that individuals have the right to request the removal of personal data that is publicly available online. In such cases, the Authority emphasized the importance of following the appropriate procedures for exercising this right, including contacting the relevant platform or service provider to request the deletion of specific posts that contain personal data.

3.1.6.3.3. Right to erasure and its limitations

The Authority clarified that the right to erasure is not absolute and may be subject to certain limitations as outlined in the General Data Protection Regulation (GDPR). Specifically, the right may not apply if the processing of personal data is necessary for compliance with a legal obligation or for the establishment, exercise, or defense of legal claims. The Authority encouraged individuals to be aware of these limitations when submitting requests for erasure.

3.1.6.3.4. Obligations of data controllers

Data controllers are reminded of their obligations under the GDPR to respond to requests for erasure without undue delay and, in any case, within one month of receipt of the request. If the request is complex or if the data controller receives a high number of requests, this period may be extended by a further two months, provided that the data subject is informed of the extension and the reasons for the delay.

3.1.6.3.5. Conclusion

The Authority continues to monitor compliance with data protection regulations and encourages individuals to exercise their rights regarding personal data. It also urges data controllers to ensure transparency and clarity in their communications with data subjects, particularly concerning their rights under the GDPR.

81

80

Annual Activity Report 2022

data on various websites and/or social media (e.g., Facebook).

The Authority initially noted (G/EXE/3370/2022) that, according to its decision No. 17/2016, any posts on a personal page on the social media platform Facebook, under certain conditions and requirements, may be considered to exceed household or personal use, especially if they involve public or widely disseminated postings of personal data (similar reasoning is found in decision No. 4/2006). Furthermore, if and when public or widely disseminated postings are made online, the Authority guided the complainants to exercise their rights as data subjects towards the respective data controller (see, for example, G/EXE/390, 424, 955, 956, 1391, 2297, 2498, 2720, and 2908/2022). The request for the deletion of data from the internet must primarily be submitted to the data controller (responsible for the specific post/administrator of the respective website or the social media

platform/company operating it), and in case the issue is not resolved, the Authority may accept the complaint and examine whether there is a violation of rights. The Authority also emphasized that regarding any comments/opinions of the respective author and potential infringement of personality rights, the relevant courts are competent (see, for example, decision of the Authority No. 43/2007, para. G.4, decision 11/2008, para. 11, decision 63/2010, para. 16).

Finally, if the complained data controller does not have a registered office in Greece but within the EU, the specific complaint will be examined within the framework of the cooperation mechanism of the supervisory authorities of the GDPR (see Articles 3, 55 - 56, 60 - 62 of the GDPR).

3.1.7. ELECTRONIC COMMUNICATIONS

3.1.7.1. Incident of Breach at Cosmote

Following the notification of a personal data breach by the company COSMOTE (leak of call data of subscribers during the period from 1/9/2020 to 5/9/2020), the Authority investigated the circumstances under which the incident occurred and, in this context, examined the legality of the retention of the leaked records as well as the security measures applied. This concerns a record that includes traffic data of subscribers and which, on the one hand, is retained for the purpose of managing problems and malfunctions for 90 days from the time of the calls, and on the other hand, the record is "anonymized" (pseudonymized) and retained for 12 months for the purpose of extracting statistical conclusions for the optimal design of the mobile phone network, after being enriched with additional simple personal data.

From the investigation of the case, a violation by COSMOTE of the principle of legality (Articles 5 and 6 of Law 3471/2006) and the principle of transparency was found, due to unclear and insufficient information provided to subscribers (Article 5 para. 1 a and 13-14 of the General Data Protection Regulation - GDPR), a violation of Article 35 para. 7 of the GDPR due to inadequate conduct of the impact assessment, a violation of Article 25 para. 1 due to inadequate implementation of the anonymization process, a violation of Article 12 para. 1 of Law 3471/2006 due to insufficient security measures, and a violation of Article 5 para. 2 in conjunction with Articles 26 and 28 due to the lack of allocation of roles between the two companies regarding the processing in question. It was also found that OTE violated Article 32 of the GDPR due to insufficient security measures concerning the infrastructures used in the context of the incident.

For the identified violations and taking into account the criteria of Article 83 para. 2 of the GDPR, the Authority, with decision 4/2022, imposed a total fine of 6,000,000 euros on COSMOTE, as well as a sanction of cessation of processing and destruction of data, while imposing a fine of 3,250,000 euros on OTE.

3.1.7.2. 'Sim swap' Breach Incidents

The Authority became aware, both through complaints and after notifications of personal data breach incidents (based on Article 12 of Law 3471/2006) from two telecommunications service providers regarding numerous incidents of unauthorized access by malicious third parties to subscriber data of mobile phone providers. Specifically, numerous unauthorized SIM card swaps of subscribers by malicious third parties were identified. These individuals then had possession of subscriber connections with the aim of executing financial transactions using the online banking codes that the subscriber would receive on their device. It was found that this access was due to weaknesses in the identification process of subscribers when submitting such requests, either as a result of inadequate policy and security measures during the subscriber identification process or due to poor implementation of the security measures of existing policies. The Authority examined the actions of the respective data controller, assessed the number of incidents, the speed with which they acted to adjust security measures to the new incidents, and ultimately address them, and with decisions 38 and 39/2022 imposed a fine of 150,000 euros on each company for the aforementioned violations of the provisions of Article 12 para. 1 and Article 12 para. 3 (c) of Law 3471/2006.

3.1.7.3. Recording and Listening to Phone Calls

In the context of examining a complaint against a company for violation of the right of access to recorded conversations filed by the data subject, the Authority, studying the case file and weighing the clarifications it requested and received from the complained company, issued a recommendation (G/EXE/1501/2022) for the company to correctly interpret and process as well as to appropriately

respond to the access requests submitted to it (under Article 15 of the GDPR) by the data subjects, within the timeframes provided in Article 1.

2 para. 3 GDPR deadlines, on the other hand, that it must fully comply with the provisions of Article 13 of the GDPR regarding the recording of conversations

83

82

Annual Activity Report 2022

explicitly identifying, among other things, which calls are recorded, for what purpose, with what legal basis, as well as the retention period of these in its corporate systems (see also the principle of accountability under Article 5 para. 2 GDPR). In fact, within the framework of this recommendation, the Authority pointed out to the complained company as the data controller that it is not exempt from its obligation to inform the data subject, even negatively, in cases where it does not maintain a record of the latter's data. Specifically, from the file's elements, it emerged that the competent representative of the complained company erroneously submitted that by resolving the issue concerning a sales contract that had been concluded with the complainant (sending an invoice and crediting the price for an undelivered product), the presumed reason for which the recorded conversations were requested was covered, and therefore the latter were not sent in a timely manner to the complainant, resulting in them having already been deleted when the complainant reiterated his request. Therefore, from the last mentioned time of resubmitting this request and thereafter, and given the two-month retention period, according to the claims of the said company, of the relevant recorded conversations, it was objectively impossible to satisfy the complainant's related request. As the complainant stated, after repeated telephone reminders and reminder emails, he was ultimately informed by the complained company by phone that the relevant recorded conversations had been deleted.

Furthermore, in the context of examining another complaint regarding the violation of the right of access to recorded conversations, a recommendation was addressed to the complained company (G/EXE/2575/2022) under which the Authority, in view of the principle of lawful, fair, and transparent processing, pointed out to the complained company to establish a clear call recording policy, to inform interested parties (e.g., via its website), further reminding that with the prior notification before the recording of calls, according to Article 4 para. 3 of Law 3471/2006, which take place during lawful professional practice for the purpose of providing evidence of a commercial transaction or other professional communication, there should not be created the misleading impression to the data subject that the call is recorded in every case when this is not true, as this results in the data subject being unable to know which of their personal data is being processed by the data controller, so as to be able to effectively exercise their rights provided by the GDPR (see also paragraph 7 of decision No. 71/2017 of the Authority). Therefore, the Authority drew the attention of the complained company to make the appropriate adjustments or deletions of the relevant recorded messages, where necessary, in light of the above.

Finally, in the context of the joint examination of two related complaints against the same company, as the data controller, for the violation of rights of access to recorded conversations, a recommendation was issued (G/EXE/3195/08-12-2022), with which the Authority, taking into account the late responses of the complained company to the complainants from which it emerges, in any case, the satisfaction of the rights exercised by the latter, drew the attention of the complained company to the fact that it must process and satisfy the relevant requests of the data subjects within the deadlines provided in Article 12 para. 3 GDPR, taking into account the existing conditions, ensuring the adoption of appropriate organizational and technical measures, where necessary.

3.1.7.4. Unsolicited electronic communications for the purpose of promoting products or services

In 2022, more than 170 complaints were submitted to the Authority regarding the conduct of unsolicited electronic communications via messages (e-mail or SMS) for the purpose of promoting products or services. In those cases where complete details are provided for their investigation, the Authority requests the views of the complained companies to determine whether there is a violation of the legislation or not.

Within 2022, the Authority examined a request for remedy against decision 44/2021, which had

imposed a fine of 5,000 euros on a commercial company. Specifically, in the aforementioned decision (see the Authority's Annual Report for 2021, 3.1.7.2), which concerned a complaint regarding the sending of advertising emails despite the complainant having repeatedly requested to be removed from the recipient lists, it was found that the failure to satisfy the right to object was due to a technical error, as the company, as the data controller, did not practically have the necessary procedures in place to ensure the deletion of the data, so that the requirements of the GDPR were met. With the examination of the request for remedy against the aforementioned decision, submitted by the complained company, and after assessing the new evidence provided by the applicant, the Authority modified decision 44/2021 and imposed on the applicant, with decision No. 21/2022, a fine of 1,000 euros for the identified violations of Articles 21 para. 3 and 25 para. 1 of the GDPR.

Furthermore, the Authority, with decision No. 30/2022, examined two complaints against a specific company regarding the sending of emails for the purpose of promoting services. In the first case, it was determined that the previous professional contact of the complainant with the legal representative of the company through a professional means of communication...

of consent by the recipients of the messages, and on the other hand, the nature of the communication, which was unsolicited and of a political nature.

85

84

Annual Activity Report 2022

Moreover, the Authority, with decision no. 16/2022, examined a large number of complaints (36) against a matchmaking office regarding unsolicited promotional communication through the sending of short text messages (SMS). With this decision, the Authority found violations of both Article 11 paragraph 3 of Law 3471/2006 and violations of Articles 15, 21, and 31 of the GDPR, as the data controller did not have the prior consent of the data subjects to whom the promotional messages were sent, did not satisfy access and objection rights exercised by data subjects, did not provide a valid address in any of the promotional messages where the recipient could request the termination of communication, and also did not cooperate with the Authority. Based on the above, the Authority imposed a fine of 54,000 euros on the data controller.

Furthermore, the Authority partially revoked decision 13/2021 (see Annual Report of the Authority for 2021, 3.1.7.2), which had imposed a fine of 20,000 euros on a commercial company for sending SMS with a promotional character, even though the complainant had already explicitly expressed his objection to the company. Following the examination of the appeal by the complainant, and after assessing the new evidence submitted by the latter with the said appeal, the Authority evaluated as mitigating circumstances under Article 83 paragraph 2 of the GDPR the fact that a) the violation was due to negligence and not to intent of the applicant, and b) the applicant appears to generally follow appropriate procedures that ensure the satisfaction of the objection and deletion rights of data subjects, and – revoking, as mentioned above, part of decision 13/2021 – imposed on the applicant, with decision no. 20/2022, a fine of 5,000 euros for violations of Article 17 in conjunction with Articles 21 paragraph 1 and 12 paragraph 3 of the GDPR.

3.1.7.5. Telephone Calls and Complaints Regarding Possible Electronic Frauds

In 2022, approximately 300 complaints were submitted to the Authority concerning the conduct of telephone promotional actions. The Authority examined those complaints that were complete to determine whether there was a violation of the legislation or not (especially Article 11 paragraphs 1 and 2 of Law 3471/2006 and the established registry of general objection to receiving such calls). As a matter of routine, complaints are sent to the data controllers for immediate provision of their views and are grouped by the complained data controller to examine their overall behavior on this issue. In cases where the information from the case files indicates that the complaints concern isolated or limited incidents, the Authority issues recommendations to the complained companies.

In one case, the Authority examined complaints regarding telephone disturbances from a telecommunications provider to its subscribers, even though the complainants had registered their phone numbers in the registry of Article 11 paragraph 2 of Law 3471/2006. During the examination of the complaints, it was found that the complained company called its subscribers to inform them about

the availability of new copper technology (VDSL) in their area. The Authority, with its letter no. Γ/ΕΞΕ/2941/21-11-2022, informed the complained company that any call from a telecommunications provider to its customer, for information that is provided and concerns the possibility of improving the services already provided to them and ultimately may lead to a change or renewal of the existing contract, even if the terms of the new contract are preferential for the subscriber, clearly constitutes promotional activity of the provider and, therefore, for each such communication, the registry of Article 11 paragraph 2 of Law 3471/2006 must be checked, provided there is no prior specific consent for this from the subscriber. With the same letter, the Authority drew the attention of the complained company to appropriately adjust its relevant procedures.

Finally, after a relevant examination, the Authority found that 62 of the complaints regarding receiving telephone calls concerned possible electronic frauds, with the overwhelming majority of these being related to investment products. Regarding these complaints, for which the Authority has already issued a relevant announcement since 2020, the Authority requested, within the framework of ex officio action, information from telecommunications service providers regarding the technical and organizational measures taken to address the issue of calls with the caller's phone number being altered. This specific issue (spoofing) appears in many electronic communication protocols, which were designed several years ago.

3.1.8. POLITICAL COMMUNICATION

The Authority, examining a complaint regarding receiving unsolicited political communication, applied Articles 21 of Law 2472/1997 and 13 paragraphs 1 and 4 of Law 3471/2006 and imposed with decision no. 17/2022 a fine of 3,000 euros on a candidate political figure for violating Article 11 of Law 3471/2006 concerning the unlawful conduct of political communication through the sending of electronic messages. For the imposition of this fine, the Authority weighed, among other things, the fact that the recipients of the messages were not given the opportunity to exercise consent.

****3.1.9. FIELD OF LABOR RELATIONS****

The Authority addressed complaints primarily regarding the non-satisfaction of the access and objection rights of the subject – employee, while it also issued a decision concerning the issuance of a temporary order. Specifically, the General Confederation of Greek Workers (GSEE) and the Federation of Bank Employee Unions of Greece (OTOE), targeting the Ministry of Labor and Social Affairs as the data controller of the personal data included and to be included in the General Register of Trade Union Organizations (GEMISO), requested that a temporary order be issued by the President of the Authority to prohibit the operation of GEMISO until a final decision is made by the Authority, citing the following reasons:

- The operation of GEMISO introduces impermissible state supervision and intervention in the process of acquiring legal personality of the organization, in violation of Article 23, paragraph 1 of the Constitution, and control over the exercise of trade union rights.
- The legal provision allowing the services of the Ministry of Labor and Social Affairs to refuse registration in the register equates to a licensing process, that is, an additional and unnecessary administrative criterion for the exercise of the constitutionally guaranteed rights of Articles 2, 22, paragraph 2, and 23, paragraph 1 of the Constitution, and thus, the purpose of processing the data is unlawful.
- When registering data in the register, it is not clearly specified who the data controller is or who the joint data controllers are or who is executing this, making the protection of the data by the obligated parties ineffective.
- The foundation for the disclosure of data concerning participation in a trade union organization is excluded on any legal basis other than the consent of its member.
- Access by third parties to the data recorded in the register and their processing for other purposes is expanded.
- There is no explicit provision for the minimum retention period of the data or at least the criteria for determining it.

- An impact assessment of the processing on personal data was not conducted.

The Authority determined that, regardless of the legality issues of the contested processing of personal data, which arise and will be judged by the Authority during the examination of the reports from the trade union organizations, the necessary condition for the issuance of a temporary order is not met, namely that there is no strong probability that the intended processing may pose a risk to the fundamental rights and freedoms of the subjects.

of data, for which the prohibition or restriction is necessary. It further ruled that with the aforementioned regulations, the circle of persons entitled to access personal data recorded and maintained in the General Commercial Registry (G.E.M.H.S.O.E.) is not expanded, but rather specified in accordance with the provisions of Article 10 of decision no. 62599/2021 (decision 1/2022).

Additionally, the Authority examined a complaint against an employer for failing to satisfy an employee's right to object regarding the possibility of continuous monitoring by the employer of the online courses delivered by the complainant via the online platform "Zoom." The Authority found that the aforementioned right to object was not satisfied by the accused employer and that the processing in question took place in violation of the provisions of Articles 5(1)(a), 5(2), and 13 of the GDPR, and in any case, without clearly identifying the legal basis on which it is founded, according to Article 6 of the GDPR, imposing a monetary fine of 2,000 euros (decision 12/2022).

In a case concerning a complaint by a former employee against the employer company for inadequate satisfaction of the right of access, the Authority ruled that it was not necessary—as claimed by the accused company—to provide a copy of the complainant's identification document, taking into account the factual circumstances of the case under consideration, and therefore there was a violation of Article 12(3) of the GDPR regarding the deadline for informing the data subject about the extension of the response to the right of access and the reasons for it. Furthermore, it ruled that the complainant did not substantiate the necessity of accessing specific messages from the professional email to which she sought access and the exact reason why they were related to the pending trial before a court, especially since in the case under consideration, the said email messages did not concern only the complainant but also the accused company, which was the administrator of the email account. Finally, the Authority issued a reprimand to "Vodafone - (VODAFONE-PANAFON S.A.)" based on Article 58(2)(b) of Regulation (EU) 2016/679 for violating the provisions of Article 12(3) of Regulation (EU) 2016/679 (decision 19/2022).

Moreover, a complaint was submitted to the Authority by an employee against a public service for improper monitoring of the computer she used at work and for failing to satisfy the right of access to documents concerning the imposition of disciplinary sanctions against her. In this case, the Authority found a violation of the principles of legality, transparency, and security under Articles 5(1)(a) and (f), 2 (in conjunction with Article 24(1)(2)), and Articles 32(1)(2) of the GDPR, as well as a failure to satisfy the right of access due to non-compliance with the GDPR and Law 4624/2019. Specifically, the Authority ruled that personal data processing was taking place using a computer and that the GDPR and Law 4624/2019 applied regardless of the fact that the computer belonged to the data controller and that personal data processing was being conducted for the purposes of the public entity. Furthermore, it ruled that the public entity did not implement any technical or organizational compliance measures with the requirements of the GDPR and Law 4624/2019, nor did it have personal data protection policies or implement internal regulations for the proper use and operation of the equipment and the information and communication network by employees. For these reasons, the Authority, on the one hand, ordered compliance with the GDPR and satisfaction of the right of access, and on the other hand, imposed a monetary fine on the public entity (decision 24/2022).

Furthermore, the Authority examined a request for remedy, which it had partially rejected in a previous decision (48/2020), and imposed a fine for failing to satisfy the right of access by an employer company. Specifically, in the aforementioned decision, the Authority had postponed the examination of the aforementioned request for remedy regarding the provision of specific documents by the accused, on the grounds that the provision was not evident from the challenged decision. After calling the

parties and reviewing the case file, the Authority ruled that the initially accused party (now the accused) had deliberately failed to provide the complainant with the aforementioned documents, which contained his name in Latin characters and thus clearly constituted his personal data. Additionally, the Authority emphasized that the classification of information as personal data by the data controller is very important and requires special attention in the relevant assessment by the latter, as this is intrinsically linked to the right of access, because the data controller may, among other things, deliberately claim that the information they process does not constitute personal data in order to avoid satisfying the right of access (decision 32/2022).

Finally, the Authority partially rejected as unfounded a complaint regarding violations of the rights of access, restriction, and objection and ordered, pursuant to Article 58(2)(c) of the GDPR, the data controller to provide the complainant with specific personal data held by the accused company in fulfillment of the right of access under Article 15 of the GDPR for which a relevant request has been submitted by the complainant, as well as the requested copies of requests or "decisions" submitted by a third party to the accused company, provided they have been submitted in writing and are included in a filing system. Additionally, regarding the complaint concerning the unlawful processing...

****3.1.9. Processing of Personal Data****

Regarding the issuance of a letter that referred to the complainant and was drafted by a member of the company and provided to a third party, the Authority concluded that it was lawfully further processed and provided to a third party for judicial use under Article 6(1)(f) of the GDPR. However, the Authority found that its provision was in violation of the provision of Article 13(3) of the GDPR, and issued a reprimand to the complained company, as the data controller, under Article 58(2)(b) for this violation (Decision 49/2022).

****3.1.10. ASSOCIATIONS, NON-PROFIT CORPORATIONS, PROFESSIONAL ASSOCIATIONS, AND POLITICAL PARTIES****

The Authority, in the context of raising awareness among political parties ahead of the national elections of 2023 regarding intended processing of personal data in the context of political communication activities, sent a reminder letter to the data protection officers of the represented parties in Parliament concerning the applicable regulations for political communication. In this letter, political parties were called upon to reflect on their compliance with the existing provisions and procedures and, in case of identifying deficiencies, to initiate the necessary compliance actions, primarily on the following key points:

1. Existence of a provision in the statute regarding the definition of the terms "member" and/or "friend" of the party
2. Specification of conditions in the statute for the transmission of member data to members/friends (specific provisions by type of communication and personal data, e.g., name, postal address, telephone, email address)
3. Method of informing (text, process) new members/friends regarding the applicable processing for political communication
4. Method of obtaining consent (text, process) for the transmission of member/friend data to members
5. Possibility of exercising the right to object to the transmission of member data to members
6. Provision of guidance regarding the obligations of members - candidates during political communication when acting as data controllers (G/EXE/680/14-03-2022 and G/EXE/1132/17-05-2022).

Additionally, the Authority, during the examination of a complaint, issued a warning and reprimand to a data controller for non-compliance with organizational measures and failure to inform the data subject in advance. Specifically, the complaining physician reported the medical association, of which he was a member, for unlawful processing, namely the disclosure to a third party of a document containing his personal data from a disciplinary file. The complained party claimed that in the context of an attempt at extrajudicial settlement between the parties, it provided the file of the disciplinary procedure, including the contested document, to a representative of the complainant who had initiated the said disciplinary procedure. In fact, the complained party claimed that it had anonymized the aforementioned

documents. However, the complained party did not prove before the Authority, under the accountability principle, the veracity of its claims, as it did not provide relevant evidence. This inability was essentially due to the failure to take appropriate organizational measures and protection policies. Specifically, regarding the obligation to inform the data subject in advance, the complained party did not prove that it undertook the corresponding action (Decision 31/2022).

Furthermore, a complaint was submitted to the Authority by a professional football player for violation of provisions under the Authority's jurisdiction, namely the reproduction and publication of the complainant's professional contracts containing his personal data. In the context of examining this complaint, the Authority found that the Hellenic Football Federation (EPO) constitutes the data controller of personal data concerning football players, as it is an organized body, which has a Department of Football Player Registrations, where the files of professional football players are maintained, including the contracts of the players. The Authority further determined that the leak of the contested contracts, which contained personal data, occurred from the filing system of the data controller (EPO) due to a lack of appropriate technical and organizational security measures and overall compliance with the requirements of the GDPR, and imposed a fine of 25,000 euros for violation of Article 5 and Articles 24 and 32 of the GDPR (Decision 67/2022).

****3.1.11. MASS MEDIA****

A complaint was submitted to the Authority against the Hellenic Football Federation (EPO), PAOK FC, and Paralot Media and Marketing Ltd, owner of the electronic sports newspaper SDNA.GR, regarding a posting on the websites of the last two complained parties of publications that primarily concerned sports news and which, however, included verbatim professional contracts of a football player, with his full personal details (including ID number, tax identification number, residential address, etc.). The Authority, in its Decision No. 67/2022, found that the leak of the contested professional contracts, which contained personal data of the complainant football player, occurred from the filing system of the EPO due to a lack of appropriate technical and organizational security measures and overall compliance with the requirements of the GDPR, and imposed a fine of 25,000 euros for violation of Articles 5(1)(a), (f), 2, 24(1), (2), and 32(1), (2) of the GDPR, ordering compliance with the legislative framework for the protection of personal data within 2 months based on Article 58(2)(d) of the GDPR. Regarding the second complained party (PAOK FC), the Authority found that the publication of all the aforementioned personal data contained in the said contracts demonstrates that it did not... received the complaint, and that the destruction of the recorded material was not in compliance with the requirements of the GDPR. The Authority imposed an administrative fine of 2,000 euros on the data controller for violation of Article 5(1)(e) of the GDPR, as the retention period for the recorded data was not justified.

3.1.13. DATA PROTECTION OFFICERS

In 2022, the Authority continued to monitor the appointment and functioning of Data Protection Officers (DPOs) in various organizations. The Authority issued guidance on the role and responsibilities of DPOs, emphasizing the importance of their independence and the need for adequate resources to perform their duties effectively. The Authority also conducted audits to ensure compliance with the GDPR regarding the appointment of DPOs, particularly in public authorities and bodies, as well as in organizations that process large amounts of personal data.

The Authority noted that many organizations still struggle with the implementation of the DPO role, often appointing individuals who do not have the necessary expertise or resources. As a result, the Authority provided additional training sessions and resources to assist organizations in fulfilling their obligations under the GDPR.

3.1.14. INTERNATIONAL COOPERATION

The Authority actively participated in international cooperation efforts related to data protection, particularly within the framework of the European Data Protection Board (EDPB). In 2022, the Authority contributed to various guidelines and opinions issued by the EDPB, focusing on cross-border data processing and the application of the GDPR in different contexts.

The Authority also engaged in bilateral discussions with data protection authorities from other countries to share best practices and address common challenges in the enforcement of data protection laws. This cooperation is essential for ensuring a consistent application of the GDPR across the European Union and beyond.

3.1.15. PUBLIC AWARENESS AND EDUCATION

In 2022, the Authority intensified its efforts to raise public awareness about data protection rights and responsibilities. The Authority launched several campaigns aimed at educating individuals about their rights under the GDPR, including the right to access personal data, the right to rectification, and the right to erasure.

The Authority also developed educational materials for businesses and organizations to help them understand their obligations under the GDPR and to promote a culture of compliance. Workshops, webinars, and informational sessions were organized to engage with various stakeholders, including small and medium-sized enterprises, to ensure that they are equipped to handle personal data responsibly.

Overall, the Authority's activities in 2022 reflected its commitment to protecting personal data and ensuring compliance with the GDPR, while also fostering a culture of transparency and accountability in data processing practices.

operates under a franchise regime, and therefore the Authority, with its decision no. 23/202, imposed an administrative fine of 2,000 euros on the owner of the establishment for violating Article 15 in conjunction with Article 12 paragraph 3 of the GDPR.

Additionally, the Authority examined a complaint regarding the failure to satisfy the right of access to data of the minor child of the complainant, specifically concerning recorded footage from a surveillance system installed in the individual business of the respondent. It was also reported that the material was transmitted to the police authorities during the investigation of an incident without informing the data subject. The Authority, with its decision no. 51/2022, imposed an administrative fine of 3,000 euros for violations of Articles 12 and 14 of the GDPR.

In another case, the Authority examined a complaint from an employee regarding the installation and operation of a surveillance system in a department of a company. The Authority found that the respondent employer failed to conduct, as required, the Data Protection Impact Assessment (DPIA) stipulated in Article 35 paragraph 1 of the GDPR before installing and operating a surveillance system in the said department. In light of this, the Authority determined with its decision no. 5/2022 that, at this stage, an appropriate corrective measure is an order under Article 58, paragraph 2, point (d) of the GDPR to the data controller to bring the processing activities into compliance with the provisions of the GDPR, based on the reasoning set out in the decision. The Authority reserved the right to re-examine the case in its entirety after the necessary time period for the implementation of the corrective measures.

Furthermore, the Authority examined a complaint from a former employee educator regarding the installation and operation of a surveillance system in classrooms at a private educational institution. From the examination of the case's details, it emerged that the surveillance system did not meet the legality requirements. Specifically, violations of Articles 5 paragraph 1(a), 5 paragraph 1(b), and 5 paragraph 2, as well as Articles 6, 12, 13, and 30 of the GDPR were identified, for which the Authority imposed an administrative fine of 15,000 euros on the data controller with its decision no. 50/2022 and issued an order to uninstall the cameras and inform

95

94

Annual Activity Report 2022

in writing to the Authority regarding.

Furthermore, the Authority examined a request for remedy against its decision 31/2020 and proceeded to examine the legality of the operation of the video surveillance system, as reserved in the said decision. From the examined evidence and following an on-site administrative inspection, it concluded

that the video surveillance system did not meet the legality requirements. Specifically, violations of Articles 5 paragraph 1 subparagraphs a, b, and e, and Article 32 of the GDPR were identified, for which the Authority, with its decision no. 60/2022, imposed a fine of 10,000 euros on the data controller, issued a reprimand for the violation of the data retention period, and for the inadequate security measures of the system, and ordered the implementation of the necessary technical and organizational measures. Finally, the Authority rejected the request for remedy as the evidence presented did not undermine the content of the contested decision.

Lastly, the Authority examined a complaint regarding the failure to satisfy the right of access to data from a video surveillance system at a business at the entrance of a parking area. From the examination of the complaint, it emerged that although the complainant did not specify the exact time of the incident, the company in question reviewed the footage from which neither the complainant nor the incident was identified, but subsequently did not inform the complainant. From the above, it follows that the company, as the data controller, was obliged to inform the complainant of the reasons why their request could not be satisfied. The Authority, taking into account that the incident is isolated and given that the data controller had responded to similar requests from the applicant, which appear to have a continuous and recurring nature, issued a recommendation with its document no.

Γ/ΕΞΕ/422/15-02-2022 so that, in the future, in a similar case where the complainant's request cannot be satisfied, it ensures their notification and complies with Article 12 paragraph 4 of the GDPR.

3.1.12.1. Houses

The Authority examined a complaint regarding the installation of a video surveillance system in common areas of a duplex. The Authority, from the examination of the complaint, concluded that the GDPR applies to the video surveillance system and that the terms of Directive 1/2011 of the Authority must be met, as clarified by Opinion 5/2017. Specifically, the data controller for the purpose of protecting persons and property in common areas can be the co-owners jointly, but not an individual owner. When there is no regulation, a majority of 50% + 1 ownership percentage is required for the decision of the co-owners, and additionally, the consent of two-thirds of the tenants is required, for which one vote per inhabited (non-vacant) apartment is taken into account. The Authority, with its decision no. 10/2022, imposed a prohibition on the processing of personal data through the video surveillance system in the common area.

Furthermore, the Authority examined a complaint regarding the installation of a video surveillance system in the pilot area of an apartment building, where it concluded that the respondents maintain the installed video surveillance system in violation of the decision of the General Assembly of the owners according to the conditions set out in Directive 1/2011 of the Authority and issued with its decision no. 4/2022 a compliance order for the aforementioned violation and the cessation of data processing by the video surveillance system.

Finally, the Authority examined a complaint from a co-owner of an apartment in an apartment building against another co-owner, who had installed a video surveillance system at her entrance, as well as in the parking area of her private vehicle without meeting the conditions set out in Directive 1/2011 of the Authority. The Authority, with its decision no. 34, ordered the removal of the system, in accordance with the decision of the General Assembly of the apartment building, since a similar system is now in operation in the building that covers all common areas.

3.1.13. JURISDICTION OF THE AUTHORITY

A complaint was submitted to the Authority against the respondents of the complainant regarding the granting of details of a joint bank account of the complainant with a deceased person, following, according to the complaint, a court decision that obliged the bank to show the disputed documents to the respondents, as well as regarding the subsequent judicial use of these documents before the Single-Member Court of First Instance of Athens in the context of a precautionary measures trial. The Authority, taking into account that the disputed documents have been included in a case file and constitute or have already constituted the subject of judicial assessment, and that the complaint in this case consists in the judicial use of the disputed documents themselves, archived the complaint (Γ/ΕΞΕ/473/2022), as this issue falls outside its jurisdiction. Exclusively competent to assess the legality of the collection and use of personal data before a court is the competent judicial officer before whom the case is pending at any given time (Article 55 paragraph 3 GDPR, Article 10 paragraph 5 Law

4624/2019, see also the established case law of the Authority, e.g., decision 147/2001). Similarly, the Authority archived a complaint (Γ/ΕΞΕ/645/2022) regarding the judicial use of personal data, as it deemed that this falls outside its jurisdiction (Article 55 paragraph 3 GDPR, see also the established case law of the Authority, e.g., decision 147/2001), and the allegations regarding the filing of a lawsuit against multiple debtors for similar reasons or the issuance of a payment order are regulated by the relevant procedural provisions (see Articles 74 et seq. of the Civil Procedure Code).

Furthermore, the Authority examined a complaint regarding the violation of the right (access) concerning a request submitted by the complainant to a bank, in order to provide him, invoking a legitimate interest (as an heir...

mos), certified copy of the investment services provision contract that had been drawn up between the complained bank and the deceased relative of the applicant. The Authority determined that in this case, the applicant is a third party (not the data subject),

97

96

Annual Activity Report 2022

and filed the complaint (G/EXE/380/2022, as well as G/EXE/383/2022), noting that the GDPR does not apply to personal data of deceased individuals (see also Recital No. 27), and the right of access pertains to the data subject and not to third parties. Consequently, for the aforementioned issue, the Data Protection Authority is not competent, but the relevant civil courts are. Finally, complaints were filed as unsubstantiated and inadmissible due to non-compliance with pre-litigation procedures (see, for example, G/EXE/918, 1591, 1931, 2303, 2836, and 3283/2022), as the complainants had not first addressed the respective data controllers as data subjects.

3.1.14. OTHER SECTORS

The Authority, in the context of examining a complaint against the managers of an apartment building for posting the common debts of the complainant at its entrance, sent the latter a document (see, for example, G/EXE/1448 and 1820/2022), in which it highlighted its relevant case law (see its decisions No. 35/2006 and 75/2002), regarding the place where personal data related to legal obligations of the co-ownership of an apartment building may be posted. Specifically, the Authority emphasized that the relevant announcements should preferably be posted in an area of the apartment building that is not accessible to third parties, except for the interested co-owners. If this is not possible, the posting should take place in an area of the apartment building where access for third-party visitors is difficult (e.g., on the wall of the staircase from the first to the second floor or on the wall of the staircase between the ground floor and the basement). Naturally, informing the co-owners through other appropriate means, such as verbally in person, during General Assemblies, or by sending a personal letter in a sealed envelope, does not pose a problem from the perspective of personal data protection. Finally, the Authority archived complaints against managers that were vague and unsubstantiated (G/EXE/1457 and 2862/2022).

3.2. OPINION – ADVISORY WORK

Opinions

In the year 2022, the Authority issued 5 opinions on draft laws, presidential decrees, and ministerial decisions within the framework of its advisory competence, pursuant to Articles 57 par. 3(b) of the GDPR and 13 par. 1(c) of Law 4624/2019.

Specifically, the Authority examined a draft Presidential Decree submitted by the Ministry of Interior under the authorization of par. 1 of Article 19 of Law 4807/2021 regarding teleworking in the public sector. The Authority emphasized that the submitted draft Presidential Decree repeats provisions of Law 4807/2021 and the GDPR, without specifying particular regulated issues, and drew attention to the definition of the role of the data controller in relation to the intended operation of the teleworking online portal in the public sector. Subsequently, it issued an opinion on specific articles of the submitted draft Presidential Decree (Opinion 1/2022).

Additionally, the Authority examined a draft Ministerial Decision from the Ministry of Education regarding the amendment of Article 25 "Exemption of students from active participation in classes" of

Ministerial Decision No. 79942/GD4/21-5-2019 "Registrations, transfers, attendance, and issues of organization of school life in secondary education schools." Regarding the exemption of students from Physical Education and Music classes, the Authority concluded that the processing of students' data, including their health data, through collection, registration in the records of the respective school unit for a period of three months from the end of the school year to which they pertain, and the registration of the exemption in the Minutes Book of the Teaching Staff of the school units for their exemption from active participation in Physical Education and Music classes, respectively, is in accordance with the legality principles of Article 5 of the GDPR. Regarding the exemption of students from Religious Education, the Authority expressed the opinion that the form of exercising the right to exemption from Religious Education that is compliant with the current Greek Constitution and the ECHR is a declaration from the interested parents or students, including Orthodox Christians who may wish to do so, stating simply that "Reasons of conscience do not allow (me or my child) to participate in Religious Education." It is also suggested that the registration of the exemption in the Minutes Book of the Teaching Staff of the school unit should be formulated according to the subject for which the exemption is granted as follows: "Exemption granted from Physical Education," "Exemption granted from Music," "Exemption granted from Religious Education," "Exemption granted from prayer and church attendance." Regarding the registration of the exemption in the information system "myschool," it is suggested:

- to adopt the same wording as that of the Minutes Book of the Teaching Staff,
- to periodically reassess the necessity of retaining the data in the "myschool" system, and in any case, the data recorded in this system should be automatically deleted after the completion of the students' education or the fulfillment of the intended purpose of their retention,
- access to these data should be limited to the respective school unit where the student is enrolled, and specifically to certain, appropriately authorized users.

as long as it relates to their duties. Finally, it is suggested to reconsider the appropriate legal basis for the processing of special categories of data and to justify this choice, as well as to add the

99

98

Annual Activity Report 2022

right of access of data subjects to all data and information concerning them and the right to rectification which should relate, in addition to the correction of inaccurate data, to the completion of any incomplete data (Opinion 2/2022).

Furthermore, the Ministry of Finance submitted to the Authority a draft law for the Central Credit Register requesting an opinion. The Authority, after studying the draft law, issued a relevant opinion emphasizing, on the one hand, the obligation to conduct a data protection impact assessment before the intended processing begins and, on the other hand, the need to review and amend specific provisions of the submitted draft law in order for the intended processing to comply with the GDPR and Law 4624/2019 (Opinion 3/2022).

The Ministry of Finance submitted to the Authority a draft law for the Assessment of the creditworthiness and solvency of natural and legal persons against the State and the establishment of an Independent Credit Rating Authority. The Authority, after studying the draft law, issued a relevant opinion emphasizing, on the one hand, the obligation to conduct a data protection impact assessment before the intended processing begins as well as the development of an algorithmic impact assessment and, on the other hand, the need to review and amend specific provisions of the submitted draft law in order for the intended processing to comply with the GDPR and Law 4624/2019 (Opinion 4/2022).

Finally, the Authority, at the request of the Ministry of Justice, examined Chapter VI of the Draft Law "Procedure for lifting the confidentiality of communications, cybersecurity, and protection of citizens' personal data." At the same time, acting ex officio, it examined the other proposed regulations, to the extent that they affect the right to the protection of personal data. The Authority identified specific points in the draft law that require improvement and/or clarification and submitted relevant observations (Opinion 5/2022).

Observations on draft laws

The Authority, through a series of documents, provided its opinion on proposed provisions (draft laws or draft Presidential Decrees) that concern the processing of personal data. Specifically:

The Authority, with its letter No. G/EXE/1812/13-7-2022, provided its observations to the Ministry of Digital Governance regarding the draft law "Emerging information and communication technologies, enhancement of digital governance and other provisions," following the relevant letter No. G/EIS/8223/24-06-2022 from the said Ministry. In its letter, the Authority pointed out that the draft law makes no reference to the legislative framework for the protection of personal data (GDPR, Law 4624/2019, etc.) despite the fact that the application of many provisions requires the processing of personal data (such as the provisions regarding "use of artificial intelligence systems," regarding "decision-making processes," etc.). Furthermore, the draft law does not adopt a risk-based approach, as is the case in the proposal for a regulation of the European Parliament and the Council for the establishment of harmonized rules regarding artificial intelligence, while it does not define prohibited uses of "algorithmic decision-making." Also, at no point in the draft law is there an explicit and specific provision regarding the effectiveness control of artificial intelligence tools, from which it may possibly be concluded that a tool is not functioning correctly.

Additionally, the Authority, with its letter No. G/EXE/1805/13-07-2022, sent observations to the Ministry of Education and Religious Affairs regarding Article 287 of the draft law "New Horizons in Higher Education Institutions: Enhancing quality, functionality, and the connection of HEIs with society and other provisions," following the letter No. G/EIS/8504/05-07-2022 from the Ministry informing the Authority that a provision for the Academic Identity has been included in the said draft law. Specifically:

1. The Authority pointed out that the provision should be rephrased so that the data controller (or the joint controllers) is clearly identified, and the roles of the involved entities (e.g., those executing the processing) are specified. The Authority also reminded, particularly regarding the principle of purpose limitation (see Article 5(2)(b) of the GDPR), the need to define the specific purposes of processing concerning the intended scope of activities of the use of the Academic Identity, per data controller, especially when the Academic Identity is used for the provision of services, privileges, etc., by entities other than the HEIs, and to eliminate the vague reference to activities, benefits, and facilities arising from the status of the holder.
2. The provision does not specify the duration of data retention, particularly after the expiration of the status of the holder of the Academic Identity.
3. The provision does not clearly identify the recipients of the data. In this regard, it should be clarified who the recipients or categories of recipients are for the purposes outlined in the law.
4. More extensive documentation is required regarding the categories of data that are processed for the purposes of the Academic Identity, taking into account the principle of data minimization (see Article 5(2)(c) of the GDPR). Also, considering that the card may be used for multiple purposes, if one or more of the data is...

****1.**** The necessary data for one of the purposes (and therefore included in the card data) but not for other purposes must be carefully considered, by design, so that the processing of such data is limited only to the specific legitimate purpose and the data is made available only by the entities authorized to process the relevant data in light of the processing purposes. However, it is not necessary to be completed for each category of beneficiary, and the AMKA (Social Security Number) should be examined to determine whether it is necessary to be included in the information displayed in the physical form of the identity card. The Authority also noted that documentation of the application of the principle of data minimization is required, even at the stage of conducting the Data Protection Impact Assessment (DPIA) regarding personal data, and if the necessity of a form of processing for a category of data is not documented, it should be omitted.

****5.**** The Authority positively assessed that the approach of conducting a DPIA is followed for determining the specifications. However, it noted that since the digital card is intended for use in multiple cases and for different purposes, the principles of this approach should be followed in each different use of the card to ensure compliance with the fundamental principles of Article 5 of the GDPR. Therefore, it is emphasized that the preparation of a DPIA for determining the specifications of the card

does not exempt a data controller from the obligation to conduct a DPIA (if required by Article 35 paragraphs 1 and 4 of the GDPR) when designing processing that may pose a high risk to the rights and freedoms of natural persons, in the context of which the Academic Identity will be used.

Furthermore, the Authority, with its letter no. G/EXE/1000/3-05-2022, sent comments to the Ministry of Education and Religious Affairs regarding the basic terms of personal data processing during the operation of video surveillance systems in higher education institutions (HEIs), following the Ministry's letter no. G/EIS/5281/28-03-2022, which transmitted to the Authority a document summarizing the basic terms of the aforementioned processing, as they are to be included in the draft Presidential Decree provided for in Article 12 paragraph 10 of Law 4777/2021, in order to submit initial comments and observations from the Authority before the consultation in accordance with the provisions of Articles 13 paragraph 1 point c and 67 paragraph 2 of Law 4624/2019. Specifically:

****1.**** The Authority pointed out that the prevention and handling of criminal acts (one of the processing purposes as described in Article 12 of Law 4777/2021) cannot be a processing purpose pursued by a HEI, but rather by the competent authorities, particularly the Hellenic Police. The data controller for the video surveillance systems is the respective HEI (independently). The Hellenic Police may become a joint data controller, under certain conditions, taking into account the aforementioned clarifications regarding the intended purpose, and only if deemed necessary for pursuing the purposes that fall within its jurisdiction. The cooperation between the two entities should be formalized with a Memorandum of Cooperation (as provided in Article 12 paragraph 5 of Law 4777/2021) to satisfy the requirement of Article 26 of the GDPR. According to this article, the Memorandum must duly reflect the respective roles and relationships of the joint data controllers towards the data subjects, and the essence of the agreement must be made available to the data subject. The Authority emphasized that, in any case, it is advisable for the process of determining the roles and responsibilities and the characteristics of the Memorandum of Cooperation to be reflected in the forthcoming Presidential Decree, as it constitutes a fundamental aspect of the processing and is closely linked to its transparency towards the data subjects.

****2.**** Although it is appropriate to include the determination of security measures in the security and protection plan of the HEI, it must be ensured that the plan takes into account the measures for addressing risks to the rights and legitimate interests of the data subjects and other interested parties deemed necessary by the DPIA, which must therefore precede the decision to install the cameras. Similarly, periodic evaluation of the system's operation and the possibility of modifications to its operation must be ensured.

****3.**** The provision in the transmitted draft for activating the audio function relates to the purposes of the Hellenic Police and not of the respective HEI, while in this regard, the Authority refers to Opinion 3/2020 (pages 27 to 30) and Opinion 5/2021 of the Authority (pages 7 and 8).

****4.**** The provisions of the GDPR and Directive (EU) 2016/680 (Chapter D of Law 4624/2019) apply, according to the jurisdiction of the data controllers, and cannot be modified by the Presidential Decree, but only specified in their application to the specific case. HEIs, as data controllers, are obliged to apply the provisions of the GDPR and the regulations of Law 4624/2019, which were established based on the authorization and discretion for legislation provided by the GDPR. The Hellenic Police (through the University Protection Teams - UPT) must apply, for the purposes it may pursue concerning the prevention, investigation, detection, or prosecution of criminal offenses, the provisions of Chapter D of Law 4624/2019. Attention should be paid to the differences in provisions between the GDPR and the Directive (e.g., regarding security measures) in cases of processing conducted jointly by HEIs and the Hellenic Police, in order to ensure compliance. It is noted that the entire set of provisions applies, e.g., the stricter conditions and guarantees of the directive.

5. Regarding the issue of recipients, the Authority pointed out that a role for a prosecutorial officer is introduced in administrative procedures (referral to administrative authorities, use by bodies of higher education institutions) without the necessity of their involvement being clear.

Annual Activity Report 2022

Responses to the Hellenic Parliament on Proposals for Regulations of the European Parliament and Council

The Authority provided its views to the Hellenic Parliament on proposals for Regulations of the European Parliament and Council. Specifically:

With the document No. G/EXE/2281/16-9-2022, the Authority transmitted its observations to the European Affairs Department of the Hellenic Parliament regarding the proposal for a Regulation of the European Parliament and the Council for the establishment of rules aimed at the prevention and combating of child sexual abuse and grooming. In particular, the Authority, after highlighting the Joint Opinion 4/2022 of the European Data Protection Board (EDPB) and the European Data Protection Supervisor (EDPS), for which the Authority actively participated as a member of the EDPB, even referring to specific paragraphs of it, stated the following:

1. The said proposal for a Regulation raises serious concerns regarding the proportionality of the proposed intervention and the restrictions on the protection of fundamental rights to privacy, the confidentiality of electronic communications, and the protection of personal data. The proposed procedural guarantees cannot fully replace substantive guarantees. The proposed complex system of escalation, from risk assessment and mitigation measures to the issuance of a detection order, cannot replace the required clarity of substantive obligations.
2. The proposal lacks clarity on key elements, such as the concepts of "significant risk." Furthermore, the entities tasked with implementing these safeguards, ranging from private entities to administrative and/or judicial authorities, enjoy broad discretion, which leads to legal uncertainty regarding how to balance the rights at stake in each individual case.
3. Proportionality issues are also raised by the fact that the available technologies for detecting child sexual abuse material (whether already known material or new material), as well as the available technologies for detecting grooming, appear to be characterized by non-negligible margins of error regarding false detection – which margins of error increase particularly for cases of detecting new child sexual abuse material as well as for cases of detecting grooming.
4. The need for national procedural guarantees to be taken into account by each member state in harmony with the relevant constitutional provisions and, in particular, the requirement for conducting the relevant processing under the guarantees of the judiciary according to Article 19 paragraph 1 subparagraph b of the Constitution, in conjunction with the requirements and guarantees of secondary Union law (Article 15 of Directive 2002/58/EC) should be considered.
5. The impact on the general sentiment of all users of these services, who do not engage in illegal activities, that any such communication may be subject to surveillance/control without their knowledge should also be taken into account – which in turn may restrict other individual rights, such as freedom of speech (Article 14 paragraph 1 of the Constitution).
6. It is deemed necessary for the said Regulation to clarify that no provision of it should be interpreted as a prohibition or weakening of encryption.
7. The relationship between the duties of the coordinating authorities and those of the data protection authorities should be better regulated, and a more significant and specific role should be given to the DPAs within the framework of the proposed Regulation. Additionally, a system should be established for addressing and resolving disputes between the competent authorities and the data protection authorities regarding detection orders. In particular, data protection authorities should have the right to challenge a detection order before the courts of the member state of the competent judicial authority or the independent administrative authority that issued the detection order.
8. Providers should be required to consult with data protection authorities through a prior consultation process, as mentioned in Article 36 of the GDPR, before implementing any measures for detecting child sexual abuse material or grooming, and not only when it concerns a targeted detection order regarding the solicitation of children.
9. The purpose of the proposed opinion of the EDPB regarding the technologies that the EU Center will have for executing detection orders should be clarified throughout the process, as well as how the EU Center will act after receiving the Opinion from the EDPB.

Also, with the document No. G/EXE/314/2022, the Authority transmitted its observations to the

Parliament regarding the proposal for a Regulation of the European Parliament and the Council on the transparency and targeting of political advertising [COM(2021) 731 (review regarding the principles of proportionality and subsidiarity as well as substantive observations based on the Authority's competence]. Furthermore, based on the aforementioned proposal for a Regulation, a continuous (up to the present) dialogue has taken place between the Authority and the Permanent Greek Representation to the EU regarding the placement of the Authority on issues that arose depending on the stage at which they were.

every time the procedures

for processing the relevant Union legislative proposal (see, for example, documents numbered Γ/ΕΞΕ/840/01-04-2022 and Γ/ΕΞΕ/1321/01-06-2022, Γ/ΕΞΕ/1956/01-08-2022 from the Authority).

105

104

Annual Activity Report 2022

Authority's Opinions on Preliminary Questions

In the context of the preliminary question C-61/22 Landeshauptstadt Wiesbaden (Requesting court: Verwaltungsgericht Wiesbaden – Germany) before the Court of Justice of the European Union regarding the provisions of Regulation (EU) 2019/1157 of the European Parliament and of the Council of June 20, 2019, the Authority initially informed that it has not conducted a more specific examination and assessment of individual provisions of the said Regulation and therefore cannot express opinions regarding the matters mentioned concerning the validity of the obligation arising from Article 3 paragraph 5 of the aforementioned Regulation, as outlined in the present preliminary reference. In any case, the Authority referred to its decision no. 65/2018, in the context of which, based on the recommendations of its Opinion no. 7/2018, the list of types of processing operations subject to the requirement for conducting an impact assessment regarding data protection according to Article 35 paragraph 4 of the GDPR was reshaped. Among these operations, the processing of data concerning national identification numbers or other general identification elements or changes to the conditions and terms of processing and use of these and related personal data is explicitly included (Γ/ΕΞΕ/898/12-04-2022).

Furthermore, in the context of the joined Preliminary Cases C-182/22 and C-189/22 Scalable Capital et al. (Requesting court: Amtsgericht München – Germany) before the Court of Justice of the European Union regarding interpretative issues concerning the concept of compensation under Article 82 of the GDPR as well as the criteria for its assessment, the Authority pointed out that it lacks ex lege jurisdiction to rule on the above issues. It was noted in the same response document that from the grammatical wording of Article 82 paragraph 6 interpreted in relation to Article 79 of the GDPR, it follows that the claim for compensation, i.e., monetary satisfaction for material or non-material damage, of the data subject against the data controller and/or processor in the event of a violation of the provisions for the protection of personal data, is legally enforceable. Therefore, the competent courts are responsible for this claim, and thus the respective natural judge who will adjudicate the relevant legal remedies is competent to interpret the meaning of this compensation, so that the criteria for its assessment can be crystallized jurisprudentially (Γ/ΕΞΕ/1309/31-05-2022).

Additionally, in response to the preliminary question C-280/22 before the Court of Justice of the European Union regarding the storage of fingerprint data on identity cards and residence documents in the form of a digital image stored on an electronic microchip that uses RFID technology and can be read wirelessly/contactless, the Authority informed that it has not ruled on the relevant issue, however, it brought to the court's attention:

- the decision no. 510/17/15-05-2000 of the Authority, regarding the identity cards issued to Greek citizens, which were issued in 2000 by the relevant police authority based on Law Decree 127/1969 "on the evidential value of police identities" and contained the fingerprint of the subject, and
- the Opinion no. 3/2014 regarding the process of taking, maintaining, and destroying biometric data that will be incorporated into residence permits for third-country nationals in the form of a standalone document (Γ/ΕΞΕ/1937/28.07.2022).

Finally, in the context of the preliminary question C-807/21 (Requesting court: German Court

Kammergericht) before the Court of Justice of the European Union regarding whether a fine can be imposed directly on a business without requiring, for the imposition of a fine, the establishment of an administrative violation by an identified natural person, the Authority highlighted the following: a) In Greek administrative law, the concept of "governed" refers to both natural and legal persons, and there is no distinction regarding the imposition of administrative sanctions based on the type of person, b) according to the letter and spirit of Regulation (EU) 2016/679, there is clearly the possibility of imposing sanctions, including administrative fines, on both natural and legal persons (see, for example, recitals 143, Article 4 points 7, 8, 17, 18, Article 78, Article 83) with the aim of enhancing the uniform monitoring and enforcement of the rules of the Regulation. A key criterion in this reasoning is the concept of the "data controller," who can be a "natural or legal person, public authority, service, or other body," without limitation as to the type of entity that can assume the role of the data controller, c) provisions of national law that provide for specific conditions for the imposition of sanctions on legal persons are subordinate to the provisions of Article 83 paragraphs 4 to 6 of the Regulation and do not affect their application, and d) in the decisions issued by the Authority regarding cases where the legal person is the data controller to whom administrative sanctions, including administrative fines, must be imposed, the legal person is treated as a single economic and operational entity, and based on Article 58 paragraph 2 of the Regulation, the exercise of its corrective powers imposes the prescribed as

the aforementioned administrative sanctions (G/EXE/567/02.03.2022).

3.3. INSPECTIONS

In 2022, the Authority continued the action it had initiated in 2021 regarding the use of cookies by informational websites (see the Authority's Annual Report for 2021, p. 12). Specifically, after the initial 30 informational websites that had been inspected, the Authority sent letters to another 60 websites, urging them to promptly comply with the following compliance point (based on the relevant guidelines issued by the Authority): to provide visitors with the option to accept or reject trackers via a banner with the same ease, that is, at the same level and with the same number of actions - "clicks", whether to accept the use of trackers for which consent is required or to reject it, either all or each category separately and without differentiation in the formatting of the relevant options (to ensure that the user is not influenced in favor of acceptance over rejection due to the design of the banner – e.g., more intense colors for acceptance, etc.). All websites complied with the relevant requirement.

At the same time, the Authority initiated an ex officio investigation at the end of July 2022 regarding the activities of installing and using spyware in Greece, particularly concerning the monitoring software referred to as "Predator". It also related during its investigation to complaints-reports submitted by individuals. The Authority's jurisdiction in such cases derives from both the General Data Protection Regulation (EU) 2016/679 (GDPR) and the specific legislation (e-privacy) for the protection of personal data in electronic services. Specifically, the activities of installing and using monitoring software on users' mobile devices, without their knowledge, constitute a violation of the relevant legislation (Article 4 par. 5 of Law 3471/2006, as amended and in force – this law transposes Directive 2002/58/EC into national law after its amendment by Directive 2009/136/EC), while any subsequent collection and processing of personal data collected by such software falls within the scope of the GDPR, to the extent that the collected data relates to the actions of a subscriber or user who is a natural person (data subject).

The Authority established a research team for this case and, within 2022, took specific actions based on the findings that emerged during the course of its investigation, which include issuing temporary orders to suspend the deletion of personal data, conducting investigations and on-site inspections, collecting data and information from companies and entities both within and outside Greece, among others. The investigation continues into 2023.

3.4. INCIDENTS OF BREACH

In 2022, the Authority received 174 notifications of personal data breach incidents based on Article 33 of the GDPR. In various cases among these, the Authority requested supplementary information regarding the incident, particularly concerning the security measures that were in place prior to the occurrence of the incident, the actions taken by the data controller from the moment they became aware of it, as well as, in some cases, justification for the delay in submitting the notification beyond 72

hours.

In some cases of data breach incidents, the Authority made written recommendations, including, among others, the following:

- The installation of all security updates (patches) on the software applications supporting processing must, at a minimum, be carried out without delay and systematically, while also any significant change to the information systems that affects processing (for example, the introduction of a new functionality) should, before being implemented in the production environment, be initially tested in a secure environment (e.g., in a testing environment) to ensure that it does not pose a security issue for processing (see document no. G/EXE/2079/17-8-2022).
- Specific security measures should be applied for cases of processing involving special categories of personal data that are stored on portable devices. One such measure could be the encryption of the hard drive at the physical medium level or of the files containing such sensitive personal data (see document no. G/EXE/2014/9-8-2022).

Additionally, in 2022, there was 1 notification of a data breach incident submitted by the Hellenic Police, according to the provision of Article 63 of Law 4624/2019. However, this case concerned an incident that occurred prior to the implementation of the GDPR and which was no longer ongoing, as the necessary actions had been taken by the Hellenic Police to address it.

Finally, in 2022, 35 notifications of personal data breaches were submitted by providers of electronic communications services, based on Law 3471/2006. The majority of the incidents generally involve isolated errors in sending messages or forms to subscribers, which the providers address immediately. Three incidents were submitted by a telecommunications provider and involved the ability to access another subscriber's data through the company's corresponding "smart" application. It is noted that there were 5 notifications concerning incidents known as "sim swapping" or similar, that is, unauthorized replacements of SIM cards by unauthorized persons with the potential intent to commit fraud (see also the Authority's Annual Reports for the years 2020 and 2021). This issue was comprehensively examined by the Authority with the issuance of decisions no. 38/2022 and 39/20.22 relevant decisions (see related section 3.1.7.1 of this document).

3.5. IMPACT ASSESSMENT AND PRIOR CONSULTATION

The obligation to conduct an impact assessment regarding data protection (DPIA) is provided for in Article 35, paragraph 1 of the GDPR. The DPIA is carried out by the data controller when the processing operations are likely to result in a high risk to the rights and freedoms of natural persons, particularly by using new technologies and taking into account the nature, scope, context, and purposes of the processing. Indicative types of processing operations that involve a high risk are listed in Article 35, paragraph 3 of the GDPR (see Recital 91 of the GDPR). The Authority issued a list (Government Gazette B' 1622/10.05.2019) of processing operations for which a DPIA is required, according to Article 35, paragraph 4 of the GDPR, which complements and specifies the relevant guidelines WP 248 rev. 01 of the European Data Protection Board.

Prior consultation with the Authority is provided for in Article 36, paragraph 1 of the GDPR, if the impact assessment regarding data protection (DPIA) (Article 35 of the GDPR) indicates that the processing operations involve a high risk that the data controller cannot sufficiently mitigate with appropriate measures (Recitals 84 and 94 of the GDPR). The data controller submits a request for prior consultation with the Authority if it has verified that the necessary formal completeness criteria of the DPIA study related to the consultation request are met, based on the relevant framework. The request for prior consultation must include, at a minimum, a detailed description of the remaining high risks and their potential impacts, as well as a detailed justification of the reasons why:

- it is not possible to foresee measures to reduce the high risks to an acceptable level, particularly regarding the available technology and the cost of implementing them (Recitals 84 and 94 of the GDPR), and
- the processing is necessary despite the remaining high risks. It must also include the provisions set out in Article 36, paragraph 3 of the GDPR and attach the DPIA.

In 2022, the Authority addressed the issue of DPIA in its decisions. Specifically, the Authority

examined a complaint from an employee regarding the installation and operation of a video surveillance system in a production department of an agricultural cooperative, where high-risk machines operate during the evening and late-night hours. The Authority, in Decision 5/2022, found that the complained employer company failed to carry out, as required, the DPIA study provided for in Article 35, paragraph 1 of the GDPR, before installing and operating a video surveillance system in that department and concluded that the relevant study must be conducted, identifying issues that must be examined and analyzed in detail in this study, in addition to those provided for in Article 35 of the GDPR, taking into account that the employees of that department are already burdened by the night shift. In light of this, the Authority decided that an appropriate corrective measure, at this stage, is to issue a directive to the data controller under Article 58, paragraph 2, point (d) of the GDPR to bring the processing operations into compliance with the provisions of the GDPR, based on what is stated in the reasoning of Decision 5/2022, within two months from its notification to the complained company, reserving the right to re-examine the case in its entirety after the two-month period.

Furthermore, the Authority, in exercising its ex officio powers, examined the processing of personal data that took place under a total of seven Joint Ministerial Decisions (JMD) regarding the free distribution of self-diagnostic tests to eligible persons, the declaration of the results of the relevant tests in the special electronic application self-testing.gov.gr, and the further processing of data after the declaration of the results. In this context, the compliance of the five named data controllers in the relevant JMDs, namely, IDIKA S.A., the Ministry of Labor and Social Affairs, the Ministry of Interior, the Ministry of Education and Religious Affairs, and the Naval Pension Fund (NAT), with specific requirements based on the GDPR and Law 4624/2019 was examined. The Authority issued Decision 41/2022, in which, regarding the obligation to conduct a DPIA, it reprimanded IDIKA S.A. and the Ministry of Labor and Social Affairs for the late preparation and incomplete DPIA study they submitted and imposed an administrative fine of 5,000 euros each on the Ministry of Interior and NAT for their non-compliance with the obligation to conduct a DPIA.

Additionally, the Authority, following the notification of a personal data breach incident by the company COSMOTE, investigated the circumstances under which the incident occurred and, in this context, examined the legality of the maintenance of the leaked records as well as the security measures applied. The Authority issued Decision 4/2022 and found, among other things, a violation of Article 35, paragraph 7 of the GDPR due to inadequate conduct of the DPIA and imposed a fine of 650,000 euros for this violation.

Moreover, the Authority issued Opinions 3/2022 and 4/2022 in which the issue of the obligation to conduct a DPIA regarding intended processing operations was examined. Specifically, the Authority issued Opinion No. 3/2022 following an electronic message dated 22-7-2022 (reference number Authority G/EIΣ/8919/18-7-2022) in which the Ministry of Finance submitted a draft law (hereinafter Draft Law) titled: "Establishment and Operation of a Central Credit Register" requesting an opinion on the said Draft Law. The Authority emphasized in the aforementioned opinion... of the General Data Protection Regulation (GDPR). This includes the establishment of mutual assistance and cooperation between supervisory authorities of EU member states in cross-border cases.

3.6. DATA TRANSFERS OUTSIDE THE EU

Under the GDPR, the only instances in which a transfer authorization from the supervisory authority is required are as follows, according to Article 46, paragraph 3:

1. Ad hoc contractual clauses between the importer and exporter of the data.
2. Administrative arrangements between public authorities or bodies, which include enforceable and substantive rights of the data subjects (e.g., Memorandum of Understanding - MOUs between public authorities with corresponding responsibilities). The authorization of the supervisory authority is necessary because such administrative arrangements are legally non-binding.

In the year 2022, the Authority did not grant any data transfer authorizations outside the EEA.

However, the Authority participated in the work of the European Data Protection Board (EDPB) and its subgroups, including the one dealing with international data transfers.

3.7. COOPERATION WITH COUNTERPART AUTHORITIES OF EU MEMBER STATES, MUTUAL ASSISTANCE, JOINT OPERATIONS

The GDPR ensures the cooperation of national supervisory authorities in cross-border matters (Article 4, paragraph 23 of the GDPR), through the procedures established in the articles.

****Paragraphs 60 to 62 (cooperation within the framework of the "one-stop-shop", see Articles 55, 56 GDPR, mutual assistance, joint ventures).** Cooperation in these matters is conducted by the national supervisory authorities, while the EDPB is only involved in case of disagreement between the national supervisory authorities (Article 65 GDPR) or urgency (Article 66 GDPR). The main objective of the consistency mechanism, as provided in Articles 63 to 67 of the GDPR, is to ensure the coherent and uniform application of the GDPR across all EU member states. To this end, the GDPR mandates the mandatory cooperation of national supervisory authorities and stipulates that before specific decisions are taken by national supervisory authorities (Article 64(1)), as well as in cases of general applicability or issues that produce effects in more than one member state (Article 64(2)), an opinion must be formulated by the EDPB. The coherent application of the GDPR is also ensured through the issuance of guidelines, recommendations, and best practices by the EDPB (Article 70(1)(e) GDPR). The Internal Market Information System (IMI) serves as an IT platform for the exchange of information between national supervisory authorities and the EDPB regarding cross-border issues. In 2022, the Authority received a total of 1,410 notifications-requests within the framework of cooperation among the data protection supervisory authorities of the member states, while it itself introduced 7 cooperation requests into the system. Additionally, 39 cases were introduced into the system for the application of the consistency mechanism for the issuance of an opinion by the EDPB based on Article 64 of the GDPR (see the corresponding statistical analysis in Chapter 2).

****3.8. OTHER ACTIVITIES****

The Authority was also active in examining a draft code of conduct and a certification scheme, as well as in implementing projects primarily funded by the European Commission.

****3.8.1. CODES OF CONDUCT****

Regarding the draft code of conduct submitted to the Authority by the Association of Insurance Companies under Article 40 of the GDPR (see the Authority's Annual Report for 2021, section 3.7.1.), the Authority, following a meeting and given that the Association did not update the draft based on the guidelines and recommendations provided by the Authority, decided (ref. no. G/EXE/2788/4-11-2022) to further communicate with the Association of Insurance Companies in the context of the latter preparing a code of conduct.

****3.8.2. MECHANISMS AND CRITERIA FOR CERTIFICATION****

In 2022, the examination of the draft national certification scheme and its related criteria, which had been submitted to the Authority under Article 42(5) of the GDPR (see the Authority's Annual Report for 2021, section 3.7.2), continued. The owner of the certification scheme submitted to the Authority a newer version of the criteria, to which the Authority provided its comments in its document no. G/EXE/2777/2-11-2022. In this document, the Authority highlighted, among other things, the following general characteristics:

1. The scope of the certification criteria must be absolutely clear, and presumptive conclusions about what is included and what is not should be avoided.
2. The certification criteria must be, among other things, verifiable and validated. The method of checking and assessing/validating a certification criterion constitutes information distinct from the criterion itself, which falls under the certification scheme and essentially "complements" each criterion in order to determine its verifiability and validity. Each criterion, however, must be clearly articulated and distinguishable, regardless of the supplementary information associated with it. Furthermore, considering that the Authority can only approve the certification criteria and cannot take a position on information, such as the effectiveness of methods for checking compliance with the criteria, a clear distinction between the aforementioned concepts is necessary. This does not eliminate the need to record all information; however, the provided information must be appropriately structured so that it is clear what exactly the criteria are—those which the Authority will examine for approval or not, and

subsequently, the European Data Protection Board will issue an opinion—and what the supplementary information is.

3. It should be clarified whether certain criteria apply under conditions or not. This is because the introductory text of the application for the approval of the certification criteria states that "certification is granted provided that all the following criteria are met," thus implying a mandatory character for all criteria; however, from the study of these, it appears that some criteria could potentially not apply in certain cases.

Subsequently, the Authority also made a series of more specific observations on these criteria of the scheme itself. A newer version of the certification criteria for this scheme is expected within 2023.

****3.8.3. PARTICIPATION OF THE AUTHORITY IN PROGRAMS/PROJECTS****

****3.8.3.1. Project "byDesign"*****

In 2022, the Authority continued and completed the implementation of the project titled "byDesign," which had started in 2020 (see also the Authority's Annual Reports for the years 2020 and 2021), in collaboration with the University of Piraeus and the Greek IT company ICT Abovo IKE, co-financed by the European Commission (<https://bydesign-project.eu/>). This project had two main axes: on the one hand, to facilitate small and medium-sized enterprises (SMEs) regarding compliance with the GDPR by offering a tailored compliance package; on the other hand, to promote the creation of ICT products and services that comply with data protection by design, while also raising awareness regarding... in the online toolkit and includes resources tailored for both professionals and students in the field of information technology.

1. Regarding the first axis, the development of an online toolkit to support and facilitate the compliance of SMEs with the effective implementation of the GDPR was completed in 2022. The toolkit is provided to SMEs through an online application (https://www.dpa.gr/el/byDesign_onlinetoolkit), which is available in full Greek and English versions and is accompanied by the corresponding user guide. It was implemented using modern technologies and internet software, as well as with appropriate design of the platform and system architecture, resulting in compliance with usability specifications and providing a user-friendly interface, adaptability and easy customization, scalability, and a user-friendly management environment with the ability to export anonymous usage statistics.

This toolkit provides SMEs with a set of structured template core documents and texts of various categories in an easy-to-use, structured, and friendly manner, including policies, guidelines, informational texts, best practices, templates, forms, FAQs, consolidated lists, and checklists, covering the key pillars of compliance with the GDPR regarding the transparency and legality of processing, adherence to obligations based on the principle of accountability, and the analysis of the core business activities of SMEs that involve the processing of personal data. Additionally, the toolkit features an online wizard with ten (10) simple and concise guiding questions for SMEs, allowing for the customization of the generated material of the template documents based on the specific characteristics and needs of each SME.

Furthermore, in 2022, the two phases of the pilot and full production operation of the online toolkit were completed. The pilot operation lasted one month (from 07/04/2022 to 07/05/2022), during which the toolkit was available, upon invitation, to a representative sample of pilot users, primarily from SMEs that participated in the requirements analysis phase, aiming to evaluate it in a production environment before its general release. After the completion of this phase, the online toolkit was put into full production operation on 28/07/2022, which lasted until the end of the project. During this phase, the toolkit was available to all visitors of the Authority's online portal in both Greek and English versions.

The evaluation of the toolkit during both the pilot and full production phases was conducted through a joint online survey using a structured questionnaire consisting of ten (10) simple and concise closed and open-ended questions. The results of the questionnaires from both phases were very positive and showed that users consider the online toolkit to be user-friendly and easy to use, and that it meets the essential processing actions and needs of SMEs as well as the significant aspects of compliance with the GDPR.

After the completion of the two aforementioned phases with their respective evaluations and the improvements of the online toolkit based on these evaluations, as well as the conclusions of the online conference held on Thursday, September 29, 2022, regarding the overall results of the project (see related report below), the online toolkit became available to the public for future use.

2. Regarding the second axis of providing specialized knowledge and practical guidance to companies operating in ICT and new technologies, so that they incorporate methodologies and modern techniques for data protection by design into their products and services, specialized training activities were conducted in 2022 aimed at professionals in the IT field working in Greek companies.

Specifically:

a) Seven general-purpose seminars were held, each lasting 8 hours, via videoconference, on 8/3/2022, 10/3/2022, 14/3/2022, 21/3/2022, 31/3/2022, 4/4/2022, and 14/4/2022, respectively. An open invitation for these seminars was posted on the Authority's website, and relevant messages were also sent to individuals registered in the Authority's related electronic services to keep them informed, among other things, about the Authority's relevant actions.

b) Subsequently, specialized technical seminars were conducted, each lasting 4 days, also via videoconference, during the following time periods: a) 23/5/2022 - 26/5/2022, b) 6/6/2022 - 9/6/2022, c) 15/6/2022 - 17/6/2022, plus 20/6/2022. For the technical seminars, electronic invitations were sent to all who had attended the general-purpose seminars. The topics covered in each such seminar included: a) Relationship between security risk analysis and impact assessment regarding personal data, b) Extraction of privacy by design requirements, implementation of retention period requirements and satisfaction of rights, c) Management of data breach incidents, d) Encryption, anonymization, and pseudonymization.

In addition to the above technical seminars, an additional seminar was held for participants of the technical seminars on 19/10/2022, which aimed at the practical application of a case study.

c) Finally, two seminars were also conducted for undergraduate and postgraduate students of the Department of Digital Systems at the University of Piraeus, on 10/10/2022 and 17/10/2022. The relevant educational material is available in the online toolkit and includes resources tailored for both professionals and students in the field of information technology.

on, it is important to note that the Authority is the only one among the independent authorities that does not have the ability to establish its own Organization, although Article 20, paragraph 1 of Law 4622/2019 for the central state provides that the Organizations of independent authorities are established by decision of their governing bodies, see also reference in the Annual Report of the Authority for the year 2021, p. 28, available on the Authority's website (www.dpa.gr).

The necessary organizational changes that will allow it to respond more effectively to the ever-increasing obligations at both national and EU levels are aimed to be implemented. Specifically, this need for organizational improvements, including the strengthening of the Authority's Secretariat with human resources, has become imperative, as with the implementation of the GDPR and Law 4624/2019, which also incorporates Directive 2016/680 into national law, the Authority's responsibilities have significantly expanded. In particular, cooperation (coherence mechanism, one-stop-shop), mutual assistance, and joint operations among the supervisory authorities of the Member States are now provided for, with strict deadlines, as well as the competence to participate in the European Data Protection Board, which also addresses and provides opinions on issues raised by national authorities or the Commission. Furthermore, the existing responsibilities of supporting data subjects, data controllers, public awareness, and monitoring developments in information and communication technologies and data processing applications are broadened. In addition to examining complaints and conducting audits, the examination of data breach incidents, prior consultation in cases of high-risk processing, and the evaluation and approval of codes of conduct and certification criteria are also provided for.

Therefore, with the aforementioned draft Organization, it was aimed to more effectively regulate the organization and structure of the Authority's Secretariat, to address personnel-related issues based on the aforementioned enabling provision of Law 4624/2019, and to define the outlines of the proposed

positions of responsibility. This Organization creates an organizational framework that responds to the new conditions and needs arising from the increased and specific responsibilities and duties of the Authority resulting from the implementation of the GDPR. At the same time, it fulfills the obligation of the country to comply with the above provisions of the GDPR. It is noted that the strengthening of the Authority with the necessary human resources and the Authority's ability to select the heads of the organizational units through processes controlled by itself is of critical importance for ensuring smooth operation and respecting its independence.

of the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation), Law 4624/2019, its Operating Regulation, and Law 3051/2002, as well as Chapter I of Law 4727/2020. Weighing the circular No.

ΔΗΔ/Φ.40/407/08.01.2015 of the Ministry of Administrative Reform and E-Governance (ADA: ΩΩPMX-MBA) concerning: "Implementation of the provisions of Chapter A of Law 4305/2014 (Government Gazette 237/A') regarding the 'open availability and further use of documents, information, and data of the public sector, the amendment of the provisions of the first chapter of Law 3448/2006, adaptation of national legislation to the provisions of Directive 2013/37 of the European Parliament and of the Council and further enhancement of transparency in the public sector,' as well as the previous relevant decisions of the Authority itself, the Authority proceeded to categorize all documents, information, and data in its possession into the prescribed categories of availability, in accordance with the provisions of Articles 67 paragraphs 3 and 4 and 59 paragraph 4 of Law 4727/2020, as detailed in the aforementioned decision (Γ/ΕΞΕ/3389/2022).

Finally, the Authority issued decision No. 64/2022 (Γ/ΕΞΕ/3162/2022) which established the rules for the removal of identifying information in the decisions it publishes on its website. In issuing this decision, consideration was given, among other things, to the provisions of the General Data Protection Regulation and Law 4624/2019, the Operating Regulation of the Authority, as well as Chapter I of Law 4727/2020 (Articles 61 paragraph 1 and 59 paragraph 6) concerning Open Data and the further use of public sector information, through which Directive (EU) 2019/1024 of the European Parliament and of the Council, of June 20, 2019, was incorporated into Greek legislation.

From the above provisions, the obligation of the Authority arises, on the one hand, to make its decisions publicly available and open, contributing to the enhancement of transparency and facilitating their further use for the purpose of the public interest, and on the other hand, to protect the personal data of individuals included in these decisions, in accordance with the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, for the protection of individuals against the processing of personal data and on the free movement of such data.

****of the processing of personal data****

and for the free movement of such data and the repeal of Directive 95/46/EC (General Data Protection Regulation) and Law 4624/2019 (Government Gazette A' 137/29.08.2019). According to Article 25, paragraph 1 of the GDPR, the data controller, taking into account the latest developments, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons arising from the processing, effectively applies, both at the time of determining the means of processing and at the time of processing, appropriate technical and organizational measures, such as pseudonymization, designed to implement data protection principles, such as data minimization, and to integrate the necessary safeguards into the processing in such a way as to meet the requirements of the GDPR and protect the rights of data subjects ("data protection by design"). Furthermore, according to paragraph 7 of Article 10 of the Operating Regulation of the Authority, "The decisions of the Authority are posted on its online portal, after the removal of elements that lead to the identification of natural persons, in accordance with relevant rules established by the Authority." In light of the above, the Authority unanimously decided to determine the rules for the removal of identifying elements in its decisions that are posted on its website, as described in the Annex of the aforementioned decision No. 64/2022.

****3.10. COMMUNICATION POLICY****

Promoting awareness among data subjects regarding the understanding of risks, rules, guarantees,

and rights related to the processing of personal data, as well as the responsibilities of data controllers/processors regarding their obligations, has historically been one of the core pillars of the Authority's mission, which is explicitly provided for in the General Data Protection Regulation. In summary, the communication actions carried out during 2022 were as follows: organization of an informational seminar in the context of the celebration of Data Protection Day, contribution to the implementation of educational seminars, research, and other EU-funded projects, participation of representatives of the Authority with speeches-presentations at scientific conferences, seminars, events, and educational seminars, issuance of new issues of its electronic newsletter (e-Newsletter), issuance of press releases and announcements, provision of responses to journalistic inquiries, granting interviews, and publication of articles in the media.

****Data Protection Day, January 28, 2022****

The Committee of Ministers of the Council of Europe has established January 28 of each year as Data Protection Day. The celebration of this day aims to inform and raise awareness among European citizens on data protection issues. Specifically, it seeks to help citizens understand what types of data are collected and processed about them, for what purposes, what their rights are as data subjects, how to exercise those rights, and further, to raise awareness of the risks associated with any unlawful and unfair processing of their personal data.

On the occasion of the celebration of the 16th Data Protection Day, the Data Protection Authority organized an online informational seminar on January 28, 2022. The event began with an introductory speech by the President of the Authority, Honorary President of the Council of State, Konstantinos Menoudakos. Regarding the theme of the first part, the members of the Authority Konstantinos Lamprinouidakis, Professor at the Department of Digital Systems, University of Piraeus, and Grigoris Tsolias, Lawyer, presented papers titled "Management of the COVID-19 Pandemic and Personal Data" and "Teleworking and the Protection of Personal Data," respectively. It is noted that the Deputy President of the Authority, former Areopagite, Georgios Batzalexis, coordinated the first part titled "Current Issues in Personal Data Protection" as well as the discussion with the audience that followed. In the second part titled "The byDesign Project," Dr. Vasileios Zorkadis, Director of the Secretariat of the Authority, initially delivered a speech titled "Participation of the Authority in Projects Funded by the European Commission, Introduction to the byDesign Project." Subsequently, Kalli Karveli (M.Sc.) and Dr. Efrosyni Siougle, legal and IT auditors of the Authority, respectively, presented a paper titled "Creation of a Compliance Support Tool with the GDPR." The event concluded with a presentation titled "Creation of Educational Material and Organization of Seminars on the Subject of 'Data Protection by Design and by Default'" by Dr. Georgios Rousopoulos, IT auditor of the Authority, and Georgia Panagopoulou, IT auditor of the Authority. The President of the Authority, Konstantinos Menoudakos, coordinated the second part as well as the discussion with the audience that followed. The event was broadcast online from the website of the DIAVLOS service of the National Infrastructure, Technology, and Research Network.

****Contribution of the Authority to the Implementation of Educational Seminars and Research and Other EU-Funded Projects****

The Authority, within the framework of its responsibilities for raising awareness among data controllers and processors regarding legislation on the protection of personal data, implemented from 01/11/2020 and for 24 months the project titled "Facilitating Compliance for Small and Medium-Sized Enterprises."

****Eternal****

****Businesses with GDPR and Promotion of Data Protection by Design in ICT Products and Services (byDesign)****. The implementation was carried out jointly with the University of Piraeus and the Greek IT company ICT Abovo IKE, co-financed by the European Commission. The main objective of the project was to provide specialized guidance to small and medium-sized enterprises (SMEs) in the form of a compliance toolkit, which includes user-friendly tools to assist companies and professionals, accompanied by templates of the necessary documents, suitably customizable for each business. The aim was to simplify the compliance process for SMEs and to adopt best practices regarding the personal data they process.

In the context of the project, the Data Protection Authority and the University of Piraeus organized a series of seven online seminars (from 8/3 to 14/4) in which training was provided on issues related to personal data protection that were highlighted as significant for SMEs during the first phase of the project.

4 See related <https://bydesign-project.eu/>

****Annual Activity Report 2022****

These initial general seminars were aimed at administrative executives and analysts/designers of information systems, as well as at officials of the organization involved in compliance with the General Data Protection Regulation (see more in section 3.8 "Other Activities"). Subsequently (23/5 – 20/6 and 19/10), specialized technical seminars were held exclusively for analysts/designers of information systems (see more in section 3.8 "Other Activities"). Additionally, in October, two seminars were conducted for students of the Department of Digital Systems at the University of Piraeus.

In view of the completion of the byDesign project in October 2022, an international online conference titled "Presentation of the project 'byDesign' outcomes" was held on Thursday, September 29, 2022, aimed at the overall official presentation of the findings and results of the project and the exchange of ideas and experiences at national and EU levels. The conference was attended by representatives of SMEs, professional associations, chambers of commerce, and IT professionals.

5 See the presentations here <https://bydesign-project.eu/news-events/>

The opening greeting and introductory speech at the international conference were delivered, respectively, by the President of the Authority, Konstantinos Menoudakos, and the director of the Authority's Secretariat, Dr. Vasilis Zorkadis. In the first session titled "GDPR compliance and the development of an online toolkit for SMEs," which was coordinated by Dr. Georgios Lioudakis, ICT ABOVO, presentations were made by Kalli Karveli, legal auditor ("Need analysis"), Dr. Eufrosyni Siougle, IT auditor ("Methodology and compliance material"), and Nikolaos Dellas, ICT ABOVO ("Online self-assistance compliance tool"). In the second session titled "The development of a training programme on Data Protection by Design," which was coordinated by Dr. Konstantinos Limniotis, IT auditor, presentations were made by the following: Dr. Georgios Rousopoulos, IT auditor ("Training set-up and methodology"), Georgia Panagopoulou, IT auditor M.Sc. ("Training material"), and Kostas Lamprinoudakis, Professor, Department of Digital Systems, University of Piraeus ("Report on Training"). The third session titled "European experience" was coordinated by the director of the Authority's Secretariat, Dr. Vasilios Zorkadis. Speakers included Hristo Alimonov, Head of International Cooperation and Project Management – on behalf of the President of the Bulgarian Data Protection Authority Ventsislav Karadjov – ("SMEDATA another successful story that inspires and serves"), Anamarija Mladinic, Head of Department for Legal Affairs, Cooperation and Projects, Croatian Data Protection Authority (AZOP) ("Awareness raising campaign for SMEs (EU ARC project): overview of project activities, achieved results and GDPR compliance in Croatian SMEs"), Meeri Blomberg, Senior Officer, Office of the Data Protection Ombudsman, Finland ("GDPR opening doors to the digital single market: SME centric online tools and support for leveraging the opportunity"), and Dr. Prokopios Drogkaris, Cybersecurity expert, ENISA ("Engineering Data Protection: The case of Pseudonymisation"). In the fourth session, coordinated by Dr. Ilias Athanasiadis, Head of the Communication Department of the Authority, a discussion took place among representatives of companies, associations, and chambers of commerce. Participants included: Philippos Fratzolas, MBCS CITP, DPO, Palso Federation of Language School Owners, Ioannis Mathes, IT Security Officer, DPO, INFORM P. LYKOS (HELLAS) SA, Barbara Mavrokephalou, DPO, Fais Group of Companies, Eleni Moka, Scientific Officer, Small Enterprises' Institute of the Hellenic Confederation of Professionals, Craftsmen, and Merchants (GSEVEE), Adamantia Plarinou, DPO, Papoutsanis SA, Melina Skondra, Lawyer, CIPP/E, MSc Law and Informatics, Co-chair IAPP Hellenic Chapter. The conference was closed by the director of the Authority's Secretariat, Dr. Vasilis Zorkadis.

Additionally, the Authority, within the framework of its responsibilities for public awareness, data controllers, and processors regarding the legislation on the protection of personal data, has been implementing since 1/9/2022 and for 24 months a new project titled "Informed by Default: Promoting

Awareness among Critical Social and Professional Groups (Children and Data Protection Professionals) - byDefault."6 The implementation is carried out jointly with the University of Piraeus and the Greek IT company ICT-ABOVO, co-financed by the European Commission (see more... in section 3.8 "Other Activities").

Participation in educational seminars/conferences

Initially, it is noted that throughout 2022, the educational seminars at the National Center for Public Administration and Local Government continued with the topic "The General Data Protection Regulation: the obligations of Public Administration," featuring expert speakers from the Authority's auditing department. It is noted that G. Rousopoulos and K. Limniotis, expert scientists of the Authority, created the educational material for the informational program of the EKDDA titled "General Data Protection Regulation: The obligations of Public Administration." The material is available at https://www.dpa.gr/el/enimerwtiko/ta_nea/ekpaideytiko-yliko-gia-enimerotiko-programma-toy-ekdda-me-titlo-genikos.

On 8/2, the Authority's expert Dr. E. Siougle informed high school students of the "Homo Educandus Agogi" school about the protection of personal data and privacy on the internet, as part of an educational event titled "Connecting Safely / Celebration of Safer Internet Day 2022."

On 11/3, the Authority's expert Dr. K. Limniotis delivered a lecture at the 1st Model Gymnasium of Ilioupoli titled "Introduction to Cryptography."

On 4/4, the Authority member Professor Christos Kaloniatis from the Department of Cultural Technology and Communication at the University of the Aegean participated as a trainer in the seminar titled "First Educational Seminar: Theoretical Approach" within the framework of the action "Technical & Operational Support for the provision of open data – Open Data Hub of EESYP," organized by the HELLENIC COMPANY OF PARTICIPATIONS AND PROPERTY S.A. (EESYP, "Superfund"), on the topic "GDPR and methods of data anonymization."

On 6/6, the Authority member Professor Kostas Lamprinoudakis participated as a trainer in the seminar titled "Second Educational Seminar: Practical Workshop on the provision of open data through O2Hub" within the framework of the action "Technical & Operational Support for the provision of open data - Open Data Hub of EESYP," organized by the HELLENIC COMPANY OF PARTICIPATIONS AND PROPERTY S.A. (EESYP, "Superfund"). Title of presentation: Anonymization Techniques.

On 12 and 19/12, the Authority's expert scientists E. Siougle and K. Limniotis participated with a presentation titled "Think more... personally about your data" in an educational program implemented for high school students by the Stavros Niarchos Foundation Cultural Center (SNFCC) in collaboration with the Data Protection Authority and the Institute of Computer Science - Foundation for Research and Technology (ICS-FORTH).

Participation in workshops and conferences

During 2022, the President, members, and expert scientists of the Authority participated as speakers or moderators in scientific conferences and workshops.

Specifically, within the framework of the action "Digital Literacy of the Attica Region," the Regional Development Fund of Attica and the Attica Region organized a webinar on 26/1 with the main speaker being the Authority's expert K. Limniotis. The title of the presentation was "The protection of personal data on the Internet."

On 17/2, the professor from the University of Piraeus and Authority member K. Lamprinoudakis participated in the 9th Information Security Conference ("Enabling a Secure Future: Managing Risks in a Constantly Changing World") with a presentation titled "Protection of personal data in pandemic conditions."

On 24/3, the Council "The South Europe Google Data Governance Chair" organized an online workshop titled "The future of data protection in the new EU digital scenario," in which the Director of the Data Protection Authority Dr. V. Zorkadis participated with a presentation titled "The role of the Data Protection Authorities in the new EU scenario."

On 9/6, Professor Sp. Vlachopoulos, a member of the Authority, participated in the 2nd International Scientific Conference of ASEP on the topic "Career in modern public administration: Challenges and prospects" in Athens (National Gallery) with the topic of his presentation "Staff selection processes and

protection of personal data."

On 15/6, K. Karveli, an expert scientist of the Authority, participated as a speaker in the "General Regulation" course of INEP for integrity advisors, and on the same day in the afternoon as a speaker at a workshop organized by the Piraeus Bar Association, for the 4 years of GDPR implementation, on the topic "COMPLAINTS - DECISIONS - SANCTIONS OF THE AUTHORITY."

On 17/6, the President of the Authority K. Menoudakos participated as a moderator and speaker (2nd Session: Artificial Justice, Surveillance, and Rights) in the 2nd Conference "Quo Vadis AI? What Future for/with Artificial Intelligence?" organized by the Institute for Privacy Law, Personal Data, and Technology.

On 23/6, G. Tsolias, lawyer D.N., a member of the Authority, participated in a discussion at an event organized by Privacy Connect Athens on the topic "The impact of the GDPR and the Whistleblower Directive on the operation of whistleblower schemes," regarding Directive 2019/1937 on "the protection of persons who report breaches of Union law" and its provisions concerning the protection of personal data. On 5/7, he participated with a presentation titled "4 years of GDPR: The experience of the Data Protection Authority" at the 7th Data Privacy & Protection Conference held online.

In July, Professor and Authority member Spiros Vlachopoulos delivered a speech at the educational seminar for students of the 27th class at the National School of Judicial Officers (with a focus on Administrative Justice) on the topic: "Access to public documents and protection of personal data: The practical harmonization of two new rights."

On 7/10, ENIS

A organized a workshop in Brussels on Personal Data Sharing - Emerging Technologies, in which the expert scientist of the Authority, K. Limniotis, participated. His presentation was titled "Data sharing – Use cases in the Health Care Sector," focusing on the use of data protection technologies in cases of health data sharing.

On 10/11, the Association of Compliance Professionals of Greece (SEKASE) in collaboration with the LEGAL LIBRARY organized the "5th Compliance Conference: Seeking certainties in uncertain times," in which the President of the Authority, K. Menoudakos, participated as the coordinator of the last session, and the expert scientist Dr. G. Rousopoulos presented a paper titled "The experience & the challenges of the role of the Hellenic DPA."

On 24/11, the members of the Authority, Professors H. Kalloniatis and K. Lamprinoudakis, participated in a panel discussion at a seminar organized by the Greek branch of ISC2 on the topic "Emerging Cyber Risks demanding differentiation of security & privacy posture?"

On 7/12, G. Panagopoulou, an expert scientist of the Authority, participated in the annual meeting of the Advisory Body of the Greek Center for Safe Internet of ITE, which focused on online child grooming and abuse and measures to address the phenomenon.

****Electronic Newsletter****

During 2022, the Authority issued four new issues of its electronic Newsletter (available at www.dpa.gr □ "Updates" □ "e-Newsletter"), aiming to provide brief but comprehensive information about its work, current developments in the field of personal data at national, European, and international levels, news about recent or upcoming events, useful links to websites related to the above issues, and finally, bibliographic updates.

****Interviews and Publication of Articles in Media****

An article by Dr. Vasilis Zorkadis, Secretary Director of the Authority, titled "Implementation of support for Data Processing Officers for GDPR" was published in network on 7/7. An article by the same author titled "GDPR: Training from the Data Protection Authority" was published on 28/7 also in network. Finally, an article by V. Zorkadis titled "The benefits of byDesign for SME compliance with GDPR and data protection by design" was published on epiheiro.gr on 24/10.

In the article titled "The thousands of predators of our digital life" in Kathimerini (5/12), the responses-positions of Professor and Authority member Kostas Lamprinoudakis and expert scientist Dr. Konstantinos Limniotis were included.

Professor and Authority member Christos Kalloniatis gave an interview on 23/12 on the Church Radio Station, in the program "Every Day, New Day" by Adamantia Bourzinou, discussing cybersecurity and personal data.

****Current Affairs****

Regarding current affairs related to the protection of personal data, the issues that occupied Greek and international media the most in 2022 were:

- The announcement of the Authority on 16/1 regarding the implementation of its decision for the process of modern remote training. Available at <https://www.dpa.gr/el/enimerwtiko/deltia/enimerosi-sh-etika-me-tin-efarmogi-tis-apofasis-tis-arhis-gia-ti-diadikasia>
- The imposition of a fine for a personal data breach incident and unlawful data processing by COSMOTE and OTE. See press release of 31/1 available at <https://www.dpa.gr/el/enimerwtiko/deltia/epiboli-prostimoy-gia-peristatiko-parabiasis-prosopikon-dedomenon-kai-mi-nomimi>
- Participation of the Data Protection Authority in the coordinated action of the ESDP for the use of cloud computing services in the public sector. See press release of 16/1 at <https://www.dpa.gr/el/enimerwtiko/deltia/symmetohi-tis-arhis-prostasias-dedomenon-sti-syntonismeni-drasi-toy-espd-gia-ti>
- The submission of the Annual Report of the Authority to the President of the Parliament. See press release of 11/3 at <https://www.dpa.gr/el/enimerwtiko/deltia/ypoboli-tis-etisias-ekthesis-tis-arhis-ston-proedro-tis-vouli>
- The Authority's action on cookies on informational content websites. See press release of 9/5 at <https://www.dpa.gr/el/enimerwtiko/deltia/drasi-tis-arhis-gia-ta-cookies-se-istoselides-enimerotikoy-perieho-menoy>
- The statements of the President of the Authority Konstantinos Menoudakos regarding the 4 years of GDPR. See press release of 25/5 at <https://www.dpa.gr/el/enimerwtiko/deltia/diloseis-toy-proedroy-tis-arhis-konstantinoy-menoydakoy-gia-ta-4-hronia-gdpr>
- The announcement regarding the imposition of a fine on Clearview AI, Inc. See press release of 14/7 at <https://www.dpa.gr/el/enimerwtiko/deltia/anakoinosi-shetika-me-tin-epiboli-prostimoy-stin-etaireia-clearview-ai-inc>
- The commencement of the operational function of an online tool within the byDesign Project. See press release of 28/7 at <https://www.dpa.gr/el/enimerwtiko/deltia/enarxi-paragogikis-leitoyrgias-diadikt-yakoy-ergaleiyo-sto-plaisio-toy-ergoy>
- The Memorandum of Cooperation between the Data Protection Authority and the Competition Commission. See press release of 5/8 at <https://www.dpa.gr/el/enimerwtiko/deltia/mnimonio-synergasi-as-metaxy-tis-arhis-prostasias-dedomenon-kai-tis-epitropis>
- The statement of the President of the Authority regarding the protection of minors' personal data. See press release of 15/10 at <https://www.dpa.gr/el/enimerwtiko/deltia/statement-of-the-president-of-the-authority-on-the-protection-of-personal-data>
- The case of using spyware to monitor individuals' terminal devices.
- The decision of the Council of State regarding unsolicited political communication (Council of State D' 1343-5/2022).
- The opinions of the Authority 1 and 2/2022 regarding teleworking and the exemption from religious education, respectively.
- The opinion of the Authority 5/2022 on the draft law "Procedure for lifting the confidentiality of communications, cybersecurity, and protection of citizens' personal data."
- The fine imposed by the Irish Authority on Meta.

It is noteworthy that the Authority responded promptly to requests from media outlets (indicatively: Documento, Inside Story, Guardian, Politico, The Daily Dot, MLex) as well as freelance journalists for the provision of informational material or clarifications.

The press releases and announcements of the Authority are available at www.dpa.gr (section "Updates," subsections "Press Releases and Announcements").

Publication of Articles

Kyriaki Karakasi, legal expert and auditor of the Authority, published an article titled "The use of one's

own image as personal data in journalistic research in light of the case law of the European Court of Human Rights," in the journal Greek Justice. Ελληνική, vol. 4/2022, p. 1008 et seq. She also published an article in the electronic journal e-Politeia: "Commentary on the decision No. 55/2021 of the Data Protection Authority," e-Politeia – Electronic Journal of Public Law, vol. 2, p. 306.13

Additionally, an article by K. Karakasi titled "The application of the GDPR in relation to the purpose of preventing money laundering from criminal activities in the field of online gaming and betting" was published in DITE, vol. 2/2022, p. 176.14

Dr. K. Limniotis, scientific expert of the Authority, is a co-author of the work S. Brotsis, N. Kolokotronis, and K. Limniotis, "Towards Post-Quantum Blockchain Platforms," chapter in "Security Technologies and Methods for Advanced Cyber Threat Intelligence, Detection and Mitigation," Now Publishers, pp. 106-130, 2022.

He is also a co-author of articles in the following scientific journals:

A. Patergianakis and K. Limniotis, "Privacy issues in stylometric techniques," Cryptography, vol. 6, no. 17, 2022.15

S. Monogios, K. Magos, K. Limniotis, N. Kolokotronis, S. Shiaeles, "Privacy issues in Android applications: the cases of GPS navigators and fitness trackers," International Journal of Electronic Governance, Inderscience Publishers, vol. 14, no. 1-2, pp. 83-111, 2022.16

3.11. EXTENSION OF O.P.S.

With the co-financed project "Extension and provision of services of the Integrated Information System for managing requests from citizens, businesses, public services, and other entities through the online portal of the DPA," with Code O.P.S. 509498, the Authority will achieve the extension and improvement of the services it provides to citizens and those responsible for processing, in both the private and public sectors. Through the implementation of this specific project, the Data Protection Authority is taking another significant step in its digital transformation process, aiming for more effective operation by providing the appropriate tools both to citizens and internally to its staff.

Additionally, it will ensure a unified, uniform, fast, and transparent way of implementing – applying and complying with the General Data Protection Regulation (EU) 2016/679 of the European Parliament and Council.

Specifically, the project includes the following:

- Design and implementation of a subsystem to assist data processors regarding the management of personal data breach incidents and a tool to assist the DPA regarding the management of notifications of personal data breach incidents,
- Design and implementation of a self-assessment subsystem regarding the security and protection of personal data (primarily aimed at small and medium-sized enterprises and organizations),
- Design and implementation of a subsystem to assist in the planning – execution of administrative audits of the Authority,
- Design and implementation of a subsystem to assist citizens in submitting complaints to the Authority,
- Design and implementation of a subsystem to assist in the exercise of rights by data processors,
- Creation of online informational and awareness content suitable for minors,
- Creation of a chatbot application to facilitate information searches,
- Design and implementation of a Management Information System (M.I.S) and
- Procurement and implementation of a Virtual Workstation environment.

The new services are expected to be operational in the fall of 2023.

131

130

Annual Activity Report 2022

4.

European
and International
Cooperation

4.1. EUROPEAN DATA PROTECTION BOARD

The European Data Protection Board (EDPB) began its operations on May 25, 2018, succeeding the

Article 29 Working Party (WP29), in accordance with the relevant provisions of the GDPR. The EDPB was established as an independent European body, with the primary mission of promoting the consistent application of the GDPR and Directive 2016/680 on law enforcement in the European Union and fostering cooperation among national supervisory authorities. It consists of the chairs or representatives of the supervisory authorities of the member states of the European Union and the European Data Protection Supervisor. Only on GDPR matters, representatives of the supervisory authorities of the countries of the European Economic Area (EEA), Norway, Iceland, and Liechtenstein, can participate as members of the EDPB, but without voting rights or the right to be elected as chair or deputy chair. The European Commission may also participate in the EDPB's work, as well as the supervisory authority overseeing the aforementioned supervisory authorities of the three EEA countries, but without voting rights. The responsibilities and duties of the EDPB include, in particular, the following:

- Providing general guidance for the clarification of legislation, including guiding principles, recommendations, and best practices;
- Advising the European Commission on any matters related to the protection of personal data and new legislative proposals in the European Union;
- Issuing consistency opinions and binding decisions in cases of disagreement between the lead and concerned supervisory authorities in cross-border cases; and
- Promoting cooperation and effective exchange of information and best practices among national supervisory authorities.

The EDPB publishes an annual report on its activities, which is disseminated to the European Parliament, the Council, and the Commission.

For the more effective organization of its work, the EDPB utilizes sub-groups of expert specialists. In 2022, sub-groups of specialists operated on the following subjects:

1. Border surveillance, passenger transport, police and judicial sector (former third pillar),
2. Compliance, e-governance, and health,
3. Cooperation among national data protection authorities,
4. Law enforcement,
5. Financial matters,
6. Data transfers to third countries,
7. Users of information technologies,
8. Uniform interpretation of key concepts,
9. Strategy,
10. Social media, and
11. Technological issues.

Ad hoc sub-groups of specialists are also provided for the processing of current issues.

It is noted that in 2022, the Communication Network of the European Data Protection Board continued its operations, which was established in September 2018 with the aim of enhancing cooperation among European Data Protection Authorities and the EDPB. This network includes the communication officers of the European Data Protection Authorities, the European Data Protection Supervisor, the Directorate-General for Justice of the European Commission, and the EDPB.

The EDPB prepares a biennial work program, which is published. In 2022, the work program for the years 2021 – 2022 was implemented, which includes as main tasks the issuance of opinions, guidelines, recommendations, and best practices to promote the common interpretation and effective application of the GDPR and Directive (EU) 2016/680 for data protection in the area of police and judicial cooperation, providing advice to the European Commission on any matters related to data protection, contributing to the consistent application of the GDPR, particularly in cross-border cases, and promoting...

133

132

Annual Activity Report 2022

of the cooperation and the effective exchange of information and best practices among national supervisory authorities.

In 2022, the EDPB issued 9 guidelines, which are listed below, including links to these texts in their Greek translation—if completed by the time of drafting this report—or otherwise in the English version.

-

Guidelines 1/2022 on data subject rights:

https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-012022-data-subject-rights-right-access_en

This text aims to analyze various aspects of the right of access. Initially, a general overview and explanation of Article 15 of the GDPR is provided, followed by an analysis of practical questions and issues frequently raised regarding the implementation of this right.

-

Guidelines 2/2022 on the application of Article 60 of the GDPR:

https://edpb.europa.eu/system/files/2022-10/guidelines_202202_on_the_application_of_article_60_gdpr_el.pdf

This text analyzes the cooperation relationships of the involved national supervisory authorities, among themselves, with the EDPB, and with third parties, during the examination of cross-border cases, and describes the obligations of the lead authority and the concerned supervisory authorities based on Article 60 of the GDPR.

-

Guidelines 03/2022 on deceptive design patterns in social media platform interfaces: how to recognize and avoid them:

https://edpb.europa.eu/system/files/2023-02/edpb_03-2022_guidelines_on_deceptive_design_patterns_in_social_media_platform_interfaces_v2_en_0.pdf

This text aims to provide recommendations and guidance regarding the design of interfaces for social media platform providers—data controllers. It reminds of the obligations arising from the GDPR, with particular emphasis on the principles of lawful and fair processing, purpose limitation, and data minimization, which should be applied when designing user interfaces for social media platforms.

-

Guidelines 04/2022 on the calculation of administrative fines provided for by the GDPR:

https://edpb.europa.eu/system/files/2023-06/edpb_guidelines_042022_calculationofadministrativefines_en.pdf

These guidelines reflect the consolidated interpretation of the provisions of Article 83 of the GDPR by the EDPB and are addressed to national supervisory authorities for use to ensure the consistent application and enforcement of the GDPR.

-

Guidelines 5/2022 on the use of facial recognition technologies in law enforcement:

https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-052022-use-facial-recognition-technology-area_en

The guidelines aim to inform about certain characteristics of facial recognition technologies and the applicable legal framework, as well as to provide a supportive tool for initial assessment, from a data protection perspective, categorizing a given use and a practical guide for law enforcement authorities intending to procure relevant systems.

-

Guidelines 6/2022 on the practical implementation of amicable settlements:

https://edpb.europa.eu/system/files/2022-06/edpb_guidelines_202206_on_the_practical_implementation_of_amicable_settlements_en.pdf

The guidelines aim to provide best practices for the consistent application of the GDPR in the context of amicable settlements, taking into account differences in national legislations.

-

Guidelines 7/2022 on certification as a transfer tool:

https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-072022-certification-tool-transfers_en

These guidelines provide guidance on the application of Article 46(2)(f) of the GDPR regarding the transfer of personal data to third countries or international organizations based on certification. More

specifically, they complement the existing general guidelines 1/2018 on certification and address specific requirements set out in Chapter V of the GDPR when certification is used as a transfer tool.

- Guidelines 8/2022 on identifying the competent supervisory authority for a controller or processor:
https://edpb.europa.eu/system/files/2023-04/edpb_guidelines_202208_identifying_isa_targeted_update_v2_en.pdf

These guidelines complement the guidelines WP244 rev.01 of the Article 29 Working Party dated 5/4/2017 regarding the concept of 'main establishment' in cases of joint controllers, also taking into account the guidelines 7/2020 on the concepts of 'controller' and 'processor'.

135

134

Annual Activity Report 2022

and 'data processor' under the GDPR.

- Guidelines 9/2022 on the notification of a personal data breach as provided for in the GDPR:
https://edpb.europa.eu/system/files/2023-04/edpb_guidelines_202209_personal_data_breach_notification_v2.0_en.pdf

These guidelines update and complement the guidelines WP250 rev.01 of the Article 29 Working Party dated 5/4/2017 regarding the notification of personal data breaches as provided for in the GDPR.

Additionally, the EDPB issued in 2022 a set of recommendations and 32 opinions, as well as a series of announcements, binding decisions, internal documents, etc., some of which are presented below.

- Recommendations 01/2022 regarding the application for approval and the elements and principles that must be included in Binding Corporate Rules (Art. 47 GDPR):

https://edpb.europa.eu/system/files/2023-06/edpb_recommendations_20221_bcr-c_v2_en.pdf

These recommendations repeal and replace document WP264 of the Article 29 Working Party, which contained Recommendations for the standardized application for the approval of binding corporate rules for the transfer of personal data. The new Recommendations aim to 1) provide a standardized form for the application for BCR approval for data controllers (hereinafter: BCR-C), 2) clarify the necessary content of BCR-C as defined in Article 47 GDPR, 3) distinguish between what must be included in BCR-C and what must be presented in the application submitted to the main supervisory authority for the approval of BCR, and 4) provide clarifications and comments on the requirements of BCR-C.

3 Opinions ensuring consistency on equal drafts of decisions by national supervisory authorities regarding the approval requirements for the accreditation of certification bodies: Opinion 11/2022, 12/2022, and 13/2022.

3 Opinions ensuring consistency on equal drafts of decisions by the national supervisory authority regarding the approval requirements for the accreditation of code of conduct monitoring bodies: Opinion 14/2022, 15/2022, and 16/2022.

23 Opinions on drafts of decisions by competent national supervisory authorities regarding binding corporate rules of groups, of which 17 for data controllers and 6 for data processors: Opinion 2/2022, 4/2022, 5/2022, 6/2022, 7/2022, 8/2022, 10/2022, 17/2022, 18/2022, 19/2022, 20/2022, 22/2022, 23/2022, 26/2022, 29/2022, 30/2022, and 32/2022 for data controllers, and 3/2022, 9/2022, 21/2022, 24/2022, 27/2022, and 31/2022 for data processors.

3 Opinions on drafts of decisions by national supervisory authorities regarding certification schemes: Opinion 1/2022, 25/2022, and 28/2022. Specifically:

- Opinion 1/2022 on the certification criteria of the national Carpa scheme:

https://edpb.europa.eu/our-work-tools/our-documents/opinion-board-art-64/opinion-12022-draft-decision-on-luxembourg_en

This concerns the certification criteria of the national certification scheme CARPA for Luxembourg.

- Opinion 25/2022 on the certification criteria of the national Europrise scheme:

https://edpb.europa.eu/our-work-tools/our-documents/opinion-board-art-64/opinion-252022-regarding-european-privacy-seal_en

This concerns the certification criteria of the national certification scheme for processing operations of data processors Europrise, for which the competent supervisory authority was the Authority of North Rhine-Westphalia (Germany).

•

Opinion 28/2022 on the European Europrivacy seal:

https://edpb.europa.eu/our-work-tools/our-documents/opinion-board-art-64/opinion-282022-europrivacy-criteria-certification_el

This is the first European seal for which the certification criteria were approved by the EDPB. The competent supervisory authority was the Authority of Luxembourg.

4 Joint Opinions of the EDPB and the European Data Protection Supervisor on drafts of EU Regulations. Specifically, the Joint Opinion 1/2022 on the extension of the validity of the COVID-19 certificate (proposal for a Regulation amending Regulation (EU) 2021/953), the 2/2022 regarding the proposal for a Regulation of the European Parliament and of the Council on harmonized rules regarding fair access to data and their fair use (Data Act), the 3/2022 regarding the proposal for a Regulation of the European Parliament and of the Council for the European Health Data Space, and 4/2022 regarding the proposal for a Regulation establishing rules for the prevention and combating of child sexual abuse. For these Opinions, the following is also noted:

•

Joint Opinion 1/2022, together with the EDPS, on the extension of the validity of the COVID-19 certificate (proposal for a Regulation amending Regulation (EU) 2021/953):

https://edpb.europa.eu/our-work-tools/our-documents/edpb-edps-joint-opinion/edpb-edps-joint-opinion-12022-extension-covid_en

Regarding this amendment to Regulation (EU) 2021/953 concerning the extension of the validity period of COVID-19 certificates, the EDPS and the EDPB pointed out, among other things, that the Commission had not conducted an impact assessment of the said legislation due to its urgent nature and that, given that according to Article 16 paragraph 2 of the aforementioned Regulation, the Commission was to submit, by March 31,

137

136

Annual Activity Report 2022

2022, a report to the European Parliament and the Council regarding the assessment of the implementation of the Regulation, including the impact on the protection of personal data, the aforementioned impact assessment should be submitted together with the relevant report.

•

Joint Opinion 2/2022, regarding the proposal for a Regulation of the European Parliament and of the Council on harmonized rules for fair access to data and their fair use (Data Act):

https://edpb.europa.eu/our-work-tools/our-documents/edpb-edps-joint-opinion/edpb-edps-joint-opinion-22022-proposal-european_el

The said proposal for a Regulation aims, among other things, to facilitate access to data and its use by consumers and businesses, while maintaining incentives for investment in value creation through data, in the provision for the use by public sector entities and the institutional and other bodies or agencies of the Union of data held by businesses in certain cases where there is an exceptional need for data, as well as to facilitate the switching of cloud services and the development of interoperability standards for data that will be reused across sectors. The EDPB and the EDPS drew attention to certain general concerns regarding the proposal, such as – among others – that it should be explicitly clarified that data protection legislation "takes precedence" in the event of a conflict with the provisions of the proposal regarding the processing of personal data, that products should be designed in such a way as to provide data subjects with the ability to use devices anonymously or in the least intrusive manner for privacy, that it should be ensured that for any provision of data to a user who is not a data subject there will be a legal basis for processing in accordance with Article 6 of the GDPR, as well as, if it concerns special categories of data, an exception under Article 9 of the GDPR will apply, while in any

case the requirements of Article 5 paragraph 3 of the Directive on privacy in electronic communications must be met. Furthermore, the EDPB and the EDPS recommended establishing clear limits regarding the use of personal data generated by the use of a product or related services for purposes of direct commercial promotion or advertising, monitoring of employees, credit scoring, or determining eligibility for health insurance, for calculating or modifying premiums. Finally, the EDPB and the EDPS requested the co-legislators to designate the national data protection supervisory authorities as competent coordinating authorities under the said proposal.

•

Joint Opinion 3/2022 regarding the proposal for a Regulation of the European Parliament and of the Council for the European Health Data Space:

https://edpb.europa.eu/our-work-tools/our-documents/edpb-edps-joint-opinion/edpb-edps-joint-opinion-032022-proposal_el

The said proposal aims to support individuals in controlling their health data, to support the use of health data for improving healthcare delivery, research, innovation, and policy-making, and to enable the EU to fully leverage the potential offered by the secure and protected exchange, use, and reuse of health data. The EDPS and the EDPB drew attention to certain key concerns raised, such as – among others – that the proposal may even weaken the protection of rights to privacy and data protection, particularly regarding categories of personal data and purposes related to the secondary use of data, that it is important to clarify the relationship between the provisions of the said proposal and the provisions of the GDPR as well as the legislation of the Member States, while they also recommended that, regarding the scope of the proposal, wellness applications and other digital applications, as well as wellness and behavioral data related to health, should be excluded. Furthermore, the EDPS and the EDPB recommended that the scope of the exceptions of the GDPR regarding the rights of the data subject in the proposal should not be extended, as this exception undermines rather than enhances the ability of data subjects to exercise effective control over their personal data.

•

Joint Opinion 4/2022, regarding the proposal for a Regulation to establish rules for the prevention and combating of child sexual abuse:

https://edpb.europa.eu/system/files/2023-02/edpb_edps_jointopinion_202204_csam_el.pdf

The opinion presents the common views of the EDPS and the EDPB regarding the proposal for a regulation, and is limited to aspects of the proposal concerning the protection of privacy and personal data. In particular, the joint opinion highlights areas where the proposal does not ensure adequate protection of fundamental rights to privacy and data protection or where further harmonization with the relevant EU legal framework is required.

Additionally, within the framework of the EDPS, the Data Protection Officers Network (DPO Network) of the supervisory authorities operates, in which the Authority also participates. The work for the year 2022 involved studies on the cooperation mechanism.

139

138

Annual Activity Report 2022

and consistency and the IMI tool, the register of the EDPB regarding the final decisions of Article 60 GDPR, the consistency registers of Article 64, as well as general issues concerning the DPOs and related to providing information to data subjects when the data is not collected directly from them, the concept of the data recipient in practice, as well as technical approaches to the use of trackers by the websites of supervisory authorities.

On the website https://edpb.europa.eu/our-work-tools/general-guidance/guidelines-recommendations-best-practices_en, links are included for the texts of all guidelines and recommendations, while at https://edpb.europa.eu/our-work-tools/consistency-findings/opinions_en, links for the texts of opinions. Additionally, other documents have been posted on the EDPB website, such as binding decisions, reports, notes addressed to the legislators of the EU or the member states, response letters, etc. For more information, see the general website https://edpb.europa.eu/edpb_en or more specific ones, such as https://edpb.europa.eu/our-work-tools/consistency-findings/binding-decisions_en and https://edpb.europa.eu/our-work-tools/general-guidance/other-guidance-and-information-notes_en.

4.1.1. COORDINATED SUPERVISION COMMITTEE – CSC

The Coordinated Supervision Committee was established within the framework of the European Data Protection Board in accordance with Article 37 of the Rules of Procedure of the aforementioned Board and Article 62 for coordinated supervision by the European Data Protection Supervisor and the national supervisory authorities of Regulation (EU) 2018/1725 for the protection of natural persons against the processing of personal data by the institutions and bodies of the Union and the free movement of such data or any Union act that establishes large-scale information systems, entities, offices, and bodies of the EU. The Committee began its work in December 2019 and includes representatives of the national supervisory authorities of the member states, the European Data Protection Supervisor, and representatives of the national supervisory authorities of states that are not EU members but are members of the Schengen area, where provided by Union law. Its mission is to ensure harmonized and coordinated supervision of the large-scale information systems of the EU as well as the entities, offices, and bodies of the EU that fall within its scope.

The main thematic focus of the Committee includes issues of borders – asylum – migration, police and judicial cooperation, and the Digital Single Market. However, currently, its remit includes the supervision of the Internal Market Information System (IMI), the EU Agency for Criminal Justice Cooperation (Eurojust), the European Public Prosecutor's Office (EPPO), and Europol in accordance with Article 44(2) of Regulation (EU) 2016/794 on Europol, as amended by Regulation (EU) 2022/991 and which came into force in 2022.

For the effective performance of its duties, the Committee may exchange information, assist national supervisory authorities in conducting audits – inspections, examine difficulties in the interpretation and application of Union legal acts establishing large-scale information systems or bodies subject to coordinated supervision, conduct studies on issues arising during the exercise of independent oversight or the exercise of data subject rights, promote awareness of data subject rights, and develop harmonized proposals regarding problem-solving.

The Committee prepares a two-year action plan as well as a report on its activities every two years, which it submits to the European Data Protection Board for submission to the European Parliament, Council, and Commission. The Committee meets at least twice a year in Brussels. The coordination of the Committee is managed by a Coordinator elected by its members for a two-year term. The first coordinator of the Committee was elected from the representative of the national supervisory authority of Portugal, who renewed her term for the next two years in elections held in November 2022. Greece participates in the Committee with its representative.

During 2022, two hybrid meetings were held in the sense that both physical participation at the premises of the European Data Protection Supervisor and online participation were possible.

Internal Market Information System (IMI)

Following an action taken the previous year regarding the examination of the information provided to data subjects for the exercise of their rights in the context of personal data processing in the IMI at both European and national levels, and after adopting a report – based on the responses of the member states to a relevant questionnaire – on the rights of data subjects, as well as the overall implementation of the system in accordance with the requirements of the General Data Protection Regulation, particularly concerning the principle of transparency and the resulting obligations of data controllers, it proceeded to draft recommendations for data controllers regarding their transparency obligations. Specifically, the rapporteur of this action presented a draft letter with recommendations to the competent authorities regarding the information that must be provided to data subjects concerning the exercise of their rights in relation to their personal data processed in the IMI. The aim of these recommendations is for data controllers to be aware of the legal...

Their obligations regarding the information that must be provided to data subjects and to assist them with guidance. Each national supervisory authority must send these recommendations, accompanied by a transmittal document in which the deficiencies that the recommendations aim to address are mentioned, to the national contact points of the IMI and possibly emphasize the need to update the information provided on the IMI websites in accordance with the relevant provisions of the GDPR. These contact points can in turn forward the letter and the recommendations to the competent authorities that use the IMI.

EU Agency for Criminal Justice Cooperation (Eurojust)

Regarding the supervision of the EU Agency for Criminal Justice Cooperation (Eurojust), the Commission was concerned with the implementation of the new mandate that Eurojust received to support member states in their actions to combat genocide, crimes against humanity, war crimes, and related criminal offenses, as well as the information systems and secure channels that Eurojust uses (and will use in the future) for this purpose. The consultation of the Commission also included the processing of personal data in the joint investigation teams operating within the broad framework of Eurojust. It particularly focused on the data protection guarantees that may be required in joint investigation teams formed by the authorities of third countries. Furthermore, the Commission explored the possibility of taking action regarding the investigation at the national level of the current regime in the processing of data in Eurojust's counter-terrorism register.

European Public Prosecutor's Office (EPPO)

In the area of oversight for the European Public Prosecutor's Office, the discussion continued from the previous year regarding achieving effective oversight of the European Public Prosecutor's Office. The Commission examined initiatives to obtain additional information for itself and its members regarding the databases that the European Public Prosecutor's Office will use and their interaction with national databases. In this context, it was proposed to facilitate the exchange of information among its members, to organize and conduct joint visits in the future by the European Data Protection Supervisor and national supervisory authorities to the European delegated prosecutorial authorities operating in each member state, to obtain additional information regarding the processing of personal data.

Moreover, the European Data Protection Supervisor informed the Commission about his visit to the European Public Prosecutor's Office, his views on the management of its cases, and the efforts made by the Prosecutor's Office to comply with the applicable data protection regulations.

Europol

The Commission, prompted by the entry into force during 2022 of the amended provisions of the Europol Regulation, highlighted the impact that these amendments have on issues related to data protection, such as purpose limitation, data retention, the right of access, and the categorization of data subjects. In this context, the Commission decided to include in its Work Programme for the years 2022-2024, which was drafted and adopted during the year, certain activities such as the review of the legality of the processing of data concerning minors transmitted to Europol, addressing the challenges of processing Europol's "big data," closely monitoring the determination of the purposes of data processing by national competent authorities and by Europol, in accordance with Articles 18 and 19 of the Europol Regulation, as well as monitoring the implementation of Europol's new capability to propose entries to member states in the SIS.

Regarding the aforementioned actions, the Commission, already during 2022 and with the inclusion of the issue of processing data concerning minors in its Work Programme, engaged in thorough consultations regarding this issue and the actions that need to be taken at both national and European levels to ensure that this processing complies with the Europol Regulation and the national legislation of the member states.

Similarly, within the framework of implementing its Work Programme, the Commission prioritized coordinated action to check how Articles 74a and 74b of the Europol Regulation are applied at the national level and whether national procedural guarantees are upheld.

Additionally, the Commission, having observed that Europol will have access to personal data stored in various and multiple databases, such as VIS, Eurodac, SIS, and others, committed to utilizing its horizontal and holistic approach to address issues arising from these multiple accesses, while taking into account that the data to which Europol has access is entered into these systems at the national level.

Furthermore, the European Data Protection Supervisor informed the Commission about the annulment request of Articles 74(a) and 74(b) of the recently amended Europol Regulation, which was submitted

before the CJEU on September 16, 2022. The EDPS indicated that he believes that the retroactive effect of the aforementioned provisions, which legitimizes Europol's practice of processing a large volume of personal data of individuals without a proven link to criminal activity, affects its independence and institutional integrity.

of the data subjects' rights in Europol, in light of the amendment of the Europol Regulation.

4.2. COMMON SUPERVISORY AUTHORITIES AND COORDINATION GROUPS FOR THE SUPERVISION OF INFORMATION SYSTEMS

4.2.1. COORDINATION GROUP FOR THE SUPERVISION OF THE SECOND GENERATION SCHENGEN INFORMATION SYSTEM (SIS II)

The Authority participates in the Coordination Group for the Supervision of the Schengen Information System, which meets at the premises of the European Data Protection Supervisor in Brussels. The Group was established under Article 46 of Regulation (EC) 1987/2006 of the European Parliament and of the Council of December 20, 2006, concerning the establishment, operation, and use of the second generation Schengen Information System (SIS II) and in accordance with paragraph 3 of the same article, which includes national supervisory authorities and the European Data Protection Supervisor. Its responsibilities include monitoring the technical support of the Schengen Information System (hereinafter SIS) and investigating issues of implementation or interpretation that may arise during the operation of this system, as well as adopting harmonized recommendations to propose common solutions to common problems.

During 2022, two hybrid meetings were held, meaning that both physical participation at the premises of the European Data Protection Supervisor and online participation were possible. In this year, as in previous years, representatives from the European Commission – Directorate-General for Home Affairs (DG Home) and the Data Protection Officer of the European Agency for the Operational Management of Large-Scale IT Systems in the Area of Freedom, Security and Justice (EU-Lisa), which has taken full responsibility for the operational management of the System, were invited and participated in specific discussions. The latter presented, as per its usual practice, to the Group an overview of the system's operation, statistics on the number of entries, data quality information, as well as the latest developments regarding the connection of member states (Ireland, Cyprus) to the system for the first time and developments in the related preparatory work in anticipation of the upcoming implementation of the new legislative framework for SIS II, as well as the progress towards the Agency's compliance with the recommendations received in the last audit conducted by the European Supervisor in view of the upcoming new audit scheduled for 2022.

Representatives from the Directorate-General for Home Affairs of the EU presented updated information regarding the progress of preparations for the implementation of the new SIS legislative framework and specifically the implementation of the new SIS Regulations – Regulation (EU) 2018/1860, Regulation (EU) 2018/1861, and Regulation (EU) 2018/1862 at both member state and central levels, as well as the timeline for its entry into force, which had been postponed at least until the last quarter of 2022, in order to allow time for the final necessary tests and checks. However, the entry into force was postponed to the first four months of the following year to ensure the successful transition and connection of all member states to the new system, given that if a member state is not ready to launch the new operation of SIS, it delays the operation for all member states.

Furthermore, the information campaign for the updated SIS legislative framework, which the Commission is preparing in collaboration with the European Data Protection Supervisor and national supervisory authorities to promote and inform the public about the transition to the new framework, was presented. The Commission stated that the update of the relevant section on its website (Europa) has been completed in two formats – one that will operate before the implementation of the new SIS and a different version that will be uploaded at the start of the SIS implementation – an informational brochure, a presentation with slides (PowerPoint), video clips (in English, French, and German only), presence on the Commission's social media, and press releases. The main informational material prepared by the Commission will mostly be available in all EU languages and in a format that will allow

it to be downloaded by national supervisory authorities for use at the national level.

Additionally, a representative of the Commission informed the Group about the new evaluation mechanism...

of the Schengen acquis. The new Regulation (EU) 2022/922 concerning the establishment and operation of a mechanism for evaluation and monitoring to verify the application of the Schengen acquis, for which the expressed views of the Member States, including the national supervisory authorities (and through the Group), were taken into account,

145

144

Annual Activity Report 2022

will be in force from October. However, transitional provisions are provided, and it will be fully implemented in February 2023. The new Regulation now establishes a seven-year evaluation cycle, the creation of an annual list of expert groups from all Member States, which must commit, as far as possible, to provide personnel each year, and which will be updated annually. The autonomy of the control in the field of data protection in the SIS is also maintained, and thus it is not merged with other thematic controls—although there is legislative provision for conducting thematic controls.

Furthermore, a requirement is introduced for the members of the evaluation group to have a specific security clearance for access to certain documents and facilities. The representative of the Commission further informed about the preparation of the first annual list of experts with active and dynamic participation from the majority of Member States and announced the selection and formation of evaluation teams from this list for the evaluations to be conducted during the next year. She also announced the upcoming organization in 2023 of training seminars regarding the new institutional framework, to which selected members of the evaluation teams for the next year will be invited to participate voluntarily.

A brief update was provided by a representative of the Commission regarding developments in the field of interoperability. Specifically, reference was made to the expected timeline for all systems, the progress being made regarding the implementation of the systems (at the EU level and from the side of the Member States), as well as the progress regarding legislation and, indeed, the adoption of implementing and delegated acts.

During this year, the progress of the control—using the questionnaire method—that had already been decided in 2019 regarding the issue of the apparent increase in entries concerning Article 36 of Decision SIS II 2007/533/JHA (entries for persons and objects for the purpose of discreet monitoring or special control) was also discussed. For this reason, with the assistance of the European Supervisor, a questionnaire had been drafted, which includes an introductory part with the relevant legal provisions and statistics and the main part, which contains the questions, to be used by the national supervisory authorities as a key tool for the control. Due to the pandemic and the actual inability of the national supervisory authorities to carry out the relevant on-site control easily and effectively, delays were observed in the timeline for conducting it, resulting in this year also not being able to gather the results of the questionnaire from most Member States. Given the importance attributed to conducting this control, it was decided to grant a final extension for the submission of the completed questionnaires until the next meeting of the Group in 2023.

Moreover, the Group was informed by a representative of the European Supervisor about the conduct of a control at the European Union Agency for the Operational Management of Large-Scale IT Systems in the Area of Freedom, Security and Justice (EU-Lisa) regarding the SIS, VIS, and Eurodac systems, which took place during the year and included, among other things, the compliance check with previous recommendations issued by the European Supervisor and security issues.

Finally, the Group proceeded, on the one hand, to adopt the updated general part of the Guide on the exercise of the rights of the data subject in the SIS and, on the other hand, to the Activity Report for the period 2020-2022, taking into account that the issuance of this report—albeit without the inclusion of the national actions of the Member States—is urgent due to the upcoming transition in the first quarter

of 2023 of the supervision of the SIS to the Coordinated Supervision Committee (CSC).

4.2.2. COUNCIL OF COOPERATION OF EUROPOL

The European Police Agency (Europol) is the competent agency of the EU for law enforcement. Its mission is to contribute to creating a safer Europe by assisting police authorities and law enforcement agencies in the EU Member States and improving cooperation among them.

With Decision 2009/371/JHA of the Council of April 6, 2009 "establishing the European Police Agency (Europol)," Europol became a full EU agency as of January 1, 2000. As of May 1, 2017, following the entry into force of Regulation (EU) 2016/794 of the European Parliament and of the Council of May 11, 2016 "on the European Union Agency for Law Enforcement Cooperation (Europol) and repealing and replacing Council Decisions 2009/371/JHA, 2009/934/JHA, 2009/935/JHA, 2009/936/JHA, and 2009/968/JHA" (Europol Regulation), Europol officially became the European Union Agency for cooperation in the field of law enforcement.

With the implementation of this regulation, a change occurred in the previous structure of supervision of the processing of personal data by Europol (see Annual Report of the Authority 2017, section 4.3). Specifically, under the new Europol regulation, national authorities continue to oversee the legality of personal data that...

provide the member states to Europol, while the European Data Protection Supervisor (EDPS) oversees the legality of data processing by Europol. However, the EDPS and national supervisory authorities work closely together on specific issues that require member state involvement and must ensure the uniform application of the new regulation throughout the European Union. This cooperation takes place within the framework of the Europol Cooperation Board, an entity established by Article 45 of the new Europol regulation. The Cooperation Board has advisory duties and is composed of one representative from the national supervisory authority of each member state and the EDPS.

147

146

Annual Activity Report 2022

On May 24, 2022, the European Council approved Regulation (EU) 2022/991 of the European Parliament and of the Council, dated June 8, 2022, "amending Regulation (EU) 2016/794 regarding Europol's cooperation with private entities, the processing of personal data by Europol to support criminal investigations, and Europol's role in research and innovation." This regulation ultimately came into force on June 28, 2022.

This regulation, among other things, redefines the supervisory structure of Europol's personal data processing. Specifically, according to Article 44(2) of the said Regulation, coordinated supervision is ensured based on Article 62 of Regulation (EU) 2018/1725. Consequently, the supervisory authority now belongs to the Coordinated Supervision Committee (CSC) of the European Data Protection Board (EDPB) (see Section 4.1.1 of the 2022 Annual Report).

The Europol Cooperation Board, in which the Authority was represented by one regular and one alternate member, at its unique meeting for this year and the last before the aforementioned change in supervision at the headquarters of the European Data Protection Supervisor, as well as through the relevant written procedure, primarily dealt with the following issues:

-

Amendment of the Europol Regulation – Change of personal data supervision

The Cooperation Board completed the necessary pending tasks to ensure a smooth transition to the new supervisory structure of Europol. Specifically, the Board decided to draft a letter to the EDPB regarding the best possible way to transfer the work (documents) that has been done by the Board so far and its continuation by the CSC. It was also decided that, despite the ongoing issue with the Board's website, efforts would be made to complete it to ensure transparency of the Board's work, or at least to make the most significant documents from its work over the years available through the CSC's website after the assumption of its new responsibilities.

-

Update from the EDPS

At the meeting held during the year, representatives of the EDPS informed the members of the Cooperation Board about various supervisory actions undertaken during this period as the supervisory body of Europol, as well as related developments and issues that concerned it. These actions and issues included, among others, the new proposed European Police Records Index System (EPRIS), which fundamentally changes the way data and police records (DNA, fingerprints, and vehicle registration licenses) are exchanged.

-

Participation of the Cooperation Board in the 10th Joint Parliamentary Scrutiny Group of Europol
It is noted that the Joint Parliamentary Scrutiny Group of the European Parliament has oversight and supervisory responsibilities over Europol's activities and is composed of members of the national parliaments of the member states and the European Parliament. This Group met on February 28, 2022, via videoconference, in which the Chair of the Cooperation Board participated by submitting a relevant informative letter regarding the activities of the Board.

-

Activity Report 2021-2022

The Activity Report for the period 2021-2022 was approved through the written procedure shortly before the new regulation came into force and the Cooperation Board was abolished. This report mentions the planned tasks from the Work Program 2021-2023 that are pending, which are expected to provide a good basis for the commencement of the new data protection supervision regime of Europol under the CSC within the EDPB.

For the supervision of Europol by the CSC, see the relevant section 4.1.1 of the Annual Report.

4.2.3. COORDINATION GROUP FOR THE SUPERVISION OF THE CUSTOMS INFORMATION SYSTEM AND JOINT CUSTOMS CONTROL AUTHORITY

The Customs Information System (CIS) was established by Regulation (EC) 515/1997 of the Council of March 13, 1997, "on mutual assistance between the administrative authorities of the member states and cooperation between these authorities and the Commission to ensure the correct application of customs and agricultural regulations," as amended by Regulation (EC) 766/2008 of the European Parliament and of the Council of July 9, 2008, as well as by Decision 917/2009/EU of the Council of November 30, 2009, "on the use of information technology for customs purposes."

The CIS includes exclusively the data, including personal data, which are necessary for the fulfillment of its purpose. According to Article 24 of Regulation (EC) 515/1997, as amended by Regulation (EC) 766/2008, this data is classified into the following categories:

-

goods,

-

means of transport,

-

businesses,

-

persons,

149

148

Annual Activity Report 2022

- Fraud trends,
- Available expertise,
- Seizures, confiscations, or forfeitures of goods,
- Seizures, confiscations, or forfeitures of liquid assets.

The purpose of the Customs Information System (CIS) is, on the one hand, the mutual assistance and cooperation of the competent administrative authorities of the Member States in combating the phenomenon of fraud within the framework of the customs union and the common agricultural policy, through the faster availability of information (formerly the 1st pillar of the EU), and on the other hand, to assist in the prevention, investigation, and prosecution of serious violations of national laws (formerly the 3rd pillar of the EU). The CIS allows a Member State to register data, requesting another Member

State to proceed with one of the following proposed actions:

- Observation and reporting,
- Discreet monitoring,
- Special audits, and
- Operational analysis.

These two different purposes of the system are served by two logically separate databases. Correspondingly, the regimes for the supervision of personal data protection for these two distinct purposes of the CIS are also different.

Specifically, for the purposes related to the former 1st pillar, according to Article 37 of Regulation No. 515/1997, as amended by Regulation (EC) 766/2008, the national Data Protection Authorities are responsible for ensuring that the processing and use of the data contained in the CIS by the respective competent national authorities of each Member State do not violate the rights of data subjects. In particular, however, pursuant to Article 37(4) of the aforementioned Regulation, the Coordination Group for the Supervision of the Customs Information System (hereinafter "the Group") has been established. Specifically, it is provided that the European Data Protection Supervisor, who supervises the compliance of the CIS with Regulation (EC) 45/2001 based on paragraph 3(a) of the same article, convenes at least once a year a meeting with all the national data protection supervisory authorities responsible for the supervision of the CIS.

In 2022, the Group met once. At that meeting, members were informed about the results of the first evaluation of Regulation 515/1997. Specifically, according to the relevant evaluation report, the existing legal framework does not require any revision; therefore, no legislative initiative will be undertaken to amend the regulation.

At the same meeting, the Group continued the discussion on the assessment of training on personal data protection provided to employees of the competent national authorities in each Member State with access to the CIS. It is noted that the previous year, the Group had approved a draft questionnaire, which was sent to the competent authorities. The aim is to identify any problems, deficiencies, or needs for improvement in the training procedures for staff through the responses. Some preliminary findings were presented, which will be finalized once responses from all members are collected, likely within the next year.

Finally, the Group's activity report for the years 2020-2021 was also adopted.

For the purposes related to the former 3rd pillar, the Customs Joint Supervisory Authority (CJSA) has been established, in which the Authority participates and which met at the headquarters of the Council of the European Union in Brussels. The CJSA was established under Article 25 of Decision 917/2009/JHA of the Council of 30 November 2009 "on the use of information technology for customs purposes." It is responsible for supervising the operation of the CIS, examining any implementation or interpretation issues of this system, and assisting national auditing authorities in carrying out their supervisory duties, mainly by finding and adopting common solutions to the problems that arise.

The CJSA did not meet in 2022.

4.2.4. COORDINATION GROUP FOR THE SUPERVISION OF THE VIS INFORMATION SYSTEM

The Authority participates as a regular member in the Coordination Group for the supervision of the VIS system, which meets at the offices of the European Data Protection Supervisor in Brussels at least twice a year. For the period 2020–2022 (June), Greece held the vice-presidency of the Group. The secretariat support is provided by the European Supervisor. The Group consists of one member – representative from each national data protection authority and the European Data Protection Supervisor. It was established under Article 43 of Regulation (EC) 767/2008 of the European Parliament and of the Council of 9 July 2008 on the Visa Information System (VIS) and the exchange of data between Member States for short-stay visas (VIS Regulation).

The purpose of this Group is to ensure a common approach and handling of issues arising in the operation of the VIS database and the unified supervision of the system in the field of personal data protection during the implementation of both the Visa Code (Regulation (EC) 810/2009 of the European Parliament and of the Council of 13 July 2009 establishing a Visa Code) and the aforementioned VIS Regulation.

This central database was developed in accordance with Council Decision 2004/512/EC for the establishment of the Visa Information System (VIS), in order to improve the implementation of the common policy in the area of

151

150

Annual Activity Report 2022

of visas, consular cooperation, and to determine the conditions and procedures for data exchange in the context of issuing visas for short stays and to combat visa trafficking. On this basis, biometric and alphanumeric data, among others, are recorded and maintained. It was gradually implemented from 2011, while the development of the system was completed around the end of 2015.

During 2022, two hybrid meetings were held in the sense that both physical participation at the premises of the European Data Protection Supervisor and online participation were possible. As is customary, an update was provided by the Data Protection Officer of the European Agency for the Operational Management of Large-Scale IT Systems in the Area of Freedom, Security and Justice (EU-Lisa), which has fully taken on the responsibility for the operational management of the System. The update includes a general presentation of the level of technical performance and operation of the system as well as some statistical data regarding the overall usage by member states, the data being entered, their quality, and user access.

A brief update was also provided by a representative of the European Commission regarding the revision of the VIS Regulation, which includes changes to the regulatory framework of VIS, such as the reduction of the age limit for children who can be fingerprinted from 12 years to 6, the inclusion of long-term visas in the regulatory scope of the system, and the storage of travel documents in the system for the purposes of returning third-country nationals. The Group was informed about the latest developments in the legislative process. Specifically, it was initially noted that on July 7, 2021, the VIS Regulation was amended by two new Regulations, Regulation (EU) 2021/1133 establishing the conditions for access to other EU information systems for the purposes of the visa information system (Interoperability) and Regulation (EU) 2021/1134 reforming the Visa Information System. The phase of implementing the Regulations remains, which, however, requires the adoption of a sufficient number of implementing and delegating acts. The representative of the Commission briefly presented the progress made in the field of relevant legislative acts, among other things, regarding the technical characteristics of the biometric data entered into the system, the risks related to security, illegal migration, the list of recognized – acceptable and non-acceptable – travel documents, measures for the technical implementation of the functions of the central VIS, etc.

Moreover, a representative of the Commission was invited again this year to a meeting of the Group to present the latest developments regarding the issuance of digital visas expedited by the Commission. Specifically, the Commission has taken the initiative for the digitization of visa issuance, which will gradually replace the paper format aiming to save time and money for both travelers and consulates. The goal is for the entire process to be conducted online, with the creation of a central platform that will be used by all member states. The members of the Group had the opportunity to ask questions to the representative of the Commission regarding data storage, their quality, and the mandatory use of the platform for digital visas. In the same context, the opinion of the European Data Protection Supervisor is also moving, who, in the exercise of his duties, sent an official opinion to the Commission on the matter during this year.

The Group also dealt this year with the drafting of a common audit plan, as already foreseen in the new action plan for the years 2019 – 2021, following up on the relevant work from previous years. The common audit plan is being developed based on a relevant audit plan for data security that had been previously adopted by the Coordinated Supervision Group for SIS II. Consequently, the subgroup tasked with preparing the audit plan presented an updated draft, having taken into account comments made by members of the Group. The aim is for the outcome of this action to provide national authorities and the European Supervisor with a user-friendly and practical questionnaire – list of items that need to be checked during audits of the national sections of the VIS. The adoption of the questionnaire was postponed to the next meeting of the Group in order to incorporate the new proposals that were made.

Furthermore, during this year, the Group proceeded with the examination of the issue of early data deletion, as provided for in Article 25 of the VIS Regulation, which was also part of the action plan for the years 2019 – 2021. The purpose of this action is to investigate whether and how member states implement the relevant provision of the Regulation for early data deletion. Based on the results of the research, it will be possible in the next stage to identify and highlight best practices, as well as to adopt recommendations for the better implementation of the provision and to correct any deficiencies. This research is being conducted using a questionnaire, which was approved after discussion by the Group and completed by the member states. As the receipt of the completed questionnaires from a small number of members of the Group is pending, it was deemed necessary to set a short-term deadline for their submission.

Moreover, the new Action Plan of the Group for the period 2022 – 2024 was also a subject of discussion. Topics were presented.

, which are proposed to be undertaken for action by the Group, primarily focusing on monitoring the implementation of the new VIS Regulations and completing the action for the early deletion of data. Furthermore, the following issues were proposed to be included in the Action Plan: Coordinated inspections at embassies and consulates, data transmission to third countries or international organizations, self-assessment in terms of collecting and exchanging best practices among national authorities, recommendations for Schengen evaluations, access to data for verification within the territory of the member states, access to data for the examination of asylum applications, as well as monitoring developments regarding the digitization of visas. The Action Plan was adopted by the Group, while discussions began on prioritizing the next actions, after the ongoing actions are first completed.

Finally, a representative of the European Supervisor gave a brief presentation and description of the audit conducted during the year at the central unit of VIS, which included, among other things, monitoring previous recommendations as well as security issues.

4.2.5. COORDINATION GROUP FOR THE SUPERVISION OF EURODAC

The Authority participates with a regular member in the Coordination Group for the supervision of the EURODAC system, which meets at the offices of the European Data Protection Supervisor in Brussels at least twice a year. Since November 2019, Greece has held the presidency of the Group. The secretarial support is provided by the European Supervisor. The objective of this Group is to ensure a common approach and handling by the member states of the issues arising in the operation of the EURODAC database. This database, as is known, was created under the Dublin Treaty, with Regulation (EC) 2725/2000 concerning the establishment of "Eurodac" for the comparison of fingerprints for the effective application of the Dublin Convention, in order to collect fingerprints of asylum seekers and illegal migrants in the European Union, as well as to facilitate the identification of asylum seekers during the asylum examination process. Given that national data protection authorities are responsible for the use and generally the processing of the data sent and collected in the central database, and the European Supervisor for data protection oversees the processing in the central database and the transmission of data to the member states, they actively cooperate within the framework of their responsibilities, conducting regular audits both at the central database and at the competent services of the member states, thereby ensuring coordinated supervision of Eurodac (see Article 32 of Regulation (EU) 603/2013, concerning the establishment of "Eurodac" for the comparison of fingerprints for the effective application of Regulation (EU) No. 604/2013 establishing the criteria and mechanisms for determining the member state responsible for examining an application for international protection submitted to a member state by a third-country national or by a stateless person and regarding requests for comparison with Eurodac data submitted by law enforcement authorities of the member states and Europol for law enforcement purposes and for amending Regulation (EU) No. 1077/2011 establishing a European Agency for the Operational Management of Large-Scale IT Systems in the Area of Freedom, Security, and Justice).

During 2022, two hybrid meetings were held in the sense that both physical participation at the premises of the European Data Protection Supervisor and online participation were possible.

Representatives from the European Agency for the Operational Management of Large-Scale IT Systems in the Area of Freedom, Security, and Justice (eu-LISA) and the European Commission – Directorate-General for Home Affairs (DG Home) attended the Group's meetings to inform the Group about the latest developments as is customary. In particular, a representative of the Commission is invited to each meeting to provide updates on the progress of the review of the "Eurodac" Regulation (Regulation (EU) 603/2013) based on the Commission's 2016 proposal, which had raised concerns within the Group, as this proposal expands the scope of the Regulation beyond asylum issues, aiming to utilize the system for identifying migrants on EU territory and for their return procedures. In the meetings of this year, the representatives of the EU did not attend but sent the Group brief informational notes, which were read. With the aforementioned notes, they reminded the Group that the review of the Regulation is now part of the broader Agreement on Asylum and Migration, consequently being accompanied by other legislative acts, such as the proposal for the new Dublin Regulation. During the French Presidency, consultations on the "Eurodac" Regulation Proposal were resumed in the Council. However, although a mandate was given to restart negotiations in June, which was adopted by the Council, they did not start immediately. The assignment of a mandate to the Parliament to restart negotiations remains pending, although the intention was for the Parliament's rapporteur to receive the relevant mandate by the end of the year. The intention of the French presidency and the Parliament is to proceed gradually and based on the broader legislative package for the Agreement on Asylum and Migration, resulting in the review of the "Eurodac" Regulation being dependent on negotiations regarding the other legislative acts.

****Legal Texts of Asylum and Migration****

Regarding the Agreement on Asylum and Migration, the Group was informed that negotiations have commenced with the support of the Commission in order for the legislative bodies to reach an agreement. During the French and Czech presidencies, an agreement was reached concerning the preliminary approach for the legislative texts on the screening of third-country nationals at the external borders (Screening Regulation) and the "Eurodac" Regulation. Additionally, an agreement was also reached on the Voluntary Solidarity Mechanism, which aims to support primarily Mediterranean states as first reception countries for migrants and to provide a specific, targeted response to the challenges arising from migratory waves. The implementation of this mechanism has been entrusted to the Commission, which will be assisted by member states and European agencies and organizations.

It was emphasized that during the Czech presidency, technical-level consultations continued in order to find the right balance between solidarity and responsibility based on a conceptual framework, which will be submitted for approval to the ministers during the December Justice and Home Affairs Council. Subsequently, work must continue to reflect this conceptual framework in the legislative bodies for the proposals of the Regulation on the Management of Asylum and Migration (AMMR) and the Regulation on the Asylum Procedure (APR) and to resume legislative negotiations during the Swedish presidency. It was also noted that, at an inter-institutional level, an agreement was reached in September between the European Parliament and the presidency of the Council regarding the mapping of the Pact's pathway, where representatives of the two institutions confirmed their commitment to make every possible effort to approve the legislative proposals before the end of the 2019-2024 legislative period.

On the part of EU-Lisa, the Data Protection Officer (DPO) of the Agency attended the Group's meetings to inform about the latest developments regarding the Eurodac system. She presented the level of overall performance and operation of the system while also providing some statistical data on its usage by member states, particularly regarding the volume of data in the system and the number of accesses from member states. Furthermore, the issue of false positive search results and the system's capacity concerning the enormous volume of data being input was discussed.

During this year, the Group continued the discussion on the issue of checks in the national part of Eurodac, which national supervisory authorities are obliged to conduct in national Eurodac systems at regular intervals, and the possibility of seeking a common harmonized way of reporting - presenting the checks, which would allow for comparison of results among member states. For this purpose, a small subgroup of volunteers had been created, which had already presented a draft questionnaire -

checklist of audit points, which national authorities could use as the most suitable tool. Members exchanged views on the final form it would take and made relevant proposals for modification. Based on these proposals and discussions, the final form of the questionnaire was presented, and the Group ultimately proceeded to adopt this tool.

Additionally, the Group was engaged in the drafting of the new action plan for the period 2022-2024. Based on the results of the Group's actions from the previous two years, and taking into account new developments, it was proposed that the following topics be included in the new action plan: monitoring developments regarding the revision of the Eurodac Regulation (a topic that has remained in the respective action plans for the past few years), access of law enforcement authorities - including Europol - to the system, issues that need to be highlighted and studied regarding national-level checks, impacts from legislation on interoperability, the issue of false positive search results, data marking, monitoring of specific searches for entries, and finally, actions of the Group regarding coordinated supervision within the framework of the European Data Protection Board. The above proposals were approved by the Group and adopted in the Action Plan. Regarding the first mentioned action, which had concerned the Group since previous years in light of legislative developments, it had already been decided to draft a relevant opinion by representatives of the Greek authority and the European Supervisor. The opinion letter was drafted during 2022 and was discussed by the Group, which adopted it and ultimately sent it to the European Parliament. As for the action regarding access of law enforcement authorities and Europol to the system, it was decided to thoroughly examine their compliance with the provisions of the Regulation and to understand the statistics provided for accesses by law enforcement authorities at the national level (of the member states) as well as Europol. To this end, the Group agreed to draft a relevant questionnaire with the representatives of France and Portugal as rapporteurs.

Finally, at the meeting in June 2022, at the end of the two-year term of the Group's presidency, the representative of the Greek Authority was re-elected as president for the next two years.

****4.3. GLOBAL PRIVACY ASSEMBLY - INTERNATIONAL CONFERENCE****

The International Conference of Authorities and Commissioners for Data Protection... of Data, which takes place every year in the fall, is divided into two parts: a. the Open Session, which takes the form of an international conference and in which, apart from the official national data protection authorities, representatives from the public and private sectors, non-governmental organizations, as well as the research community participate, and b. the Closed Session, in which only the Authorities or Data Protection Commissioners participate and during which relevant Declarations concerning the subject of the Session are discussed and adopted. The International Session was renamed the Global Privacy Assembly (GPA).

The 44th International Session 2022 was decided, as an emergency solution, after the withdrawal of the supervisory authority of New Zealand, initially chosen to host it, to be organized by the supervisory authority of Turkey. It took place from October 25-28 in Istanbul. It was designed as a hybrid conference. A total of 657 delegates participated in the Session, both in-person and remotely.

The Open Session took place on October 25-26, and its main topics for keynote speeches and discussion panels included the following:

- The challenges of Artificial Intelligence in Law, Ethics, and Democracy
- Big Data: Challenges for Privacy Protection
- The role of the private sector in the use of surveillance technologies
- Digitization and privacy protection: Building trust for the individual
- Convergence of data protection regulations regarding cross-border data transfers
- Privacy risks concerning vulnerable groups of data subjects
- Privacy concerns related to facial recognition technologies
- Assessing emerging technologies through the lens of privacy protection principles
- Interactions between consumer protection, competition, and privacy protection
- Mass surveillance on the global web

- Blockchain and Metaverse technologies: Privacy and data protection
- Effectiveness of mechanisms for cross-border data transfer
- Common approaches to data protection in disaster/crisis management and humanitarian aid
- Data protection for children in the digital age.

The first topic for which a speech was given in the Closed Session, on October 27, related to the promotion of privacy globally in the era of accelerated digitization, followed by discussions on the regulatory environment for data protection and privacy at a global level and by geographical regions. On the second day of the Closed Session, October 28, third-party collaborating organizations, such as the Working Group on Data Protection in Technologies and the United Nations Special Rapporteur on Privacy, presented their actions. Additionally, parallel workshops were held regarding the capacity-building of supervisory authority officials. Finally, in the Closed Session, resolutions – declarations were discussed and adopted on the following topics:

1. Regarding the amendment of the roadmap and timeline for the reorganization of the Assembly and its Secretariat.
2. Regarding the development of international cooperation capacities to improve cybersecurity regulations and understanding the implications of breach incidents.
3. Regarding the principles and expectations concerning the proper use of personal data in facial recognition technologies.

All documents approved at the 44th Closed Session of the Global Privacy Assembly have been posted on the GPA website: <https://globalprivacyassembly.org/>. More information about international sessions and the texts of the adopted declarations-resolutions can be found at the website <https://globalprivacyassembly.org/document-archive/adopted-resolutions/>. The 45th International Session 2023 is to be organized by the supervisory authority of Bermuda, from October 15-20, 2023.

4.4. SPRING SESSION

The Spring Session of the data protection supervisory authorities is a closed session in the sense that participation rights are granted to certified authorities, namely the data protection supervisory authorities of the EU, as well as other countries, such as Switzerland and Norway, the European Supervisor, representatives of the EU, the Council of Europe, as well as authorities certified as permanent observers. Representatives of the EU, the Council of Europe, and authorities with permanent observer status do not have voting rights.

Croatia was initially designated as the host country and organizer of the Spring Session 2020, which, however, due to the pandemic, was postponed to May 2021 and subsequently postponed to 2022, when it took place over two days on May 19-20. Delegates from 40 countries participated in the Session. The first presentation session focused on the recent case law of the European Court of Human Rights, while the second session focused on Convention 108+ and issues of mutual assistance and global convergence. A discussion followed on the following topics:

- Recent developments and challenges regarding data transfers
- Law enforcement cooperation: cross-border cases and Article 50 of the GDPR, mutual assistance between EU countries and third countries
- Perspective, innovation, and monitoring of technology
- Awareness-raising activities and implementation of projects funded by the EU in EU countries and outside the EU.

Presentations were also made regarding the activities of the working subgroup on the future of the Session and the Working Group for sharing experiences from examining cases related to personal data protection (Case Handling Workshop).

Finally, two resolutions were adopted, the first for the acceleration of the ratification of Convention 108+, aimed at protecting the privacy of individuals.

In the new digital age, the second regarding the vision, mission, and guiding team of the Conference, so that it continues to be successfully realized in all priority issues of the data protection supervisory

authorities in Europe. The data protection supervisory authority of Hungary took on the hosting and organization of the Spring Conference 2023. For more information, visit the website of the Spring Conference 2022, <https://springconference2022.hr/>.

4.5. WORKING GROUP FOR THE EXCHANGE OF EXPERIENCES FROM THE HANDLING OF PERSONAL DATA PROTECTION REQUESTS (CASE HANDLING WORKSHOP)

The Authority participates in the Working Group for the exchange of experiences from the examination of personal data protection issues (Case Handling Workshop) organized annually by member states and supervisory authorities in Europe (including non-EU countries such as Montenegro, Albania, Turkey, Serbia, etc.). The Group serves as an internal cooperation forum (workshop) among all EU Data Protection Authorities, aimed at exchanging experiences and discussing practical issues arising during the handling of complaints and requests related to personal data protection. Topics from previous workshops include the right to be forgotten from search engines, data processing by private investigators, video surveillance systems, credit scoring, and the legitimization of proceeds from illegal activities. The Greek Authority hosted the group's meeting in November 2006.

This year's event, held on November 18 and 19, was organized and hosted by the Georgian Authority in the capital of the country, Tbilisi. More than 50 participants, two of whom were from the Greek Authority, from 26 data protection authorities, took part in the two-day event, during which topics were discussed, among others, regarding the extensive examination of audit evidence, the design and stages of the audit, the methodology and structure of the decision, as well as difficulties in the application of administrative sanctions. Also discussed were the shared responsibility of posters and social media in the display and sharing of data through the latter, the use of social networks in humanitarian actions, the handling of complaints from minor subjects, the exchange of data among authorities, cases of exemption due to domestic use of data, personal data in artificial intelligence, as well as aspects of data breach incidents.

Publication: Personal Data Protection Authority

Editing: Secretariat Directorate

Kifisias 1-3, 11523 Athens

www.dpa.gr | e-mail: contact@dpa.gr